# Curso de reversing

## Tomo II · Ramas Especializadas: Kernel, Drivers y Windows Internals

Profundización avanzada en el sistema operativo Windows: arquitectura del kernel NT, drivers WDM/KMDF, IOCTLs, depuración kernel con WinDbg (KDNET), minifiltros, mitigaciones HVCI/VBS, objetos del ejecutivo, procesos/hilos, Registro, servicios, Task Scheduler, COM/DCOM, RPC, WMI, IPC, SEH/VEH/WER, ETW, Hyper-V, subsistema gráfico Win32k (KeServiceDescriptorTableShadow) y cadena de arranque UEFI/bootkits (bootmgfw.efi, winload.efi, LOADER_PARAMETER_BLOCK).

**Contenido y balance de este volumen (Tomo II):** Total consolidado de **160 páginas** (80 hojas físicas para impresión doble faz), que comprende la **Etapa 6 completa (6.1 a 6.7)** y la **Rama 2D completa (2D.1 a 2D.15 + Anexo Hyper-V)**.

**Requisitos previos y consulta rápida:** Este tomo asume el dominio del tronco principal (Etapas 0 a 4 del **Tomo I**). Durante las prácticas con WinDbg, KMDF y estructuras del sistema, mantené abierta la **Separata de Escritorio** (especialmente la *Hoja 2: Offsets PEB/LDR* y la *Hoja 3: CTL_CODE, IRQL y comandos de WinDbg*).

> **Seguridad de laboratorio obligatoria.** Toda práctica con drivers de kernel ( `.sys` ), `bcdedit /debug on` , Driver Verifier, servicios o mecanismos de persistencia debe realizarse exclusivamente dentro de una **máquina virtual descartable y aislada**, nunca en el equipo anfitrión.

# Contenido — Tomo II


**Etapa 6 · Kernel y drivers en Windows (rama optativa)** **p. 3-4 · 2 págs.**

6.1 Arquitectura del kernel p. 5-10 · 6 págs.

6.2 KMDF e IOCTL inocuo p. 11-20 · 10 págs.

6.3 Debugging de kernel p. 21-25 · 5 págs.

6.4 Revisión defensiva de drivers p. 26-36 · 11 págs.

6.5 Minifilters p. 37-44 · 8 págs.

6.6 Mitigaciones para drivers p. 45-49 · 5 págs.

6.7 VBS, HVCI, callbacks ETWti y MDLs p. 50-61 · 12 págs.

**Rama 2D · Windows internals (rama optativa de Etapa 2)** **p. 62-63 · 2 págs.**

2D.1 Objetos y tokens p. 64-68 · 5 págs.

2D.2 Memoria y loader p. 69-73 · 5 págs.

2D.3 Registro p. 74-77 · 4 págs.

2D.4 Servicios p. 78-82 · 5 págs.

2D.5 Task Scheduler p. 83-85 · 3 págs.

2D.6 COM interfaces p. 86-95 · 10 págs.

2D.7 COM activación p. 96-102 · 7 págs.

2D.8 DCOM y RPC p. 103-111 · 9 págs.

2D.9 WMI p. 112-121 · 10 págs.

2D.10 IPC p. 122-130 · 9 págs.

2D.11 Excepciones p. 131-138 · 8 págs.

2D.12 ETW p. 139-144 · 6 págs.

2D.13 Integrador p. 145-148 · 4 págs.

2D.14 Win32k y Shadow Table p. 149-152 · 4 págs.

2D.15 Arranque temprano, UEFI y bootkits p. 153-157 · 5 págs.

Extensión optativa Hyper-V p. 158-159 · 2 págs.

**Referencias cruzadas en Tomo I y Separata de Escritorio**

Tronco principal (Etapas 0 a 5) Tomo I · p. 1–348

Hilo conductor multi-nivel y Kit de 15 plantillas y laboratorios Tomo I · p. 349-367 · 19 págs.

Hojas de referencia rápida (Cheat Sheets 1 a 6) Separata y Tomo I · p. 368-384 · 17 págs.

Glosario y Preguntas frecuentes Tomo I · p. 385–406

# Etapa 6 · Rama optativa · Kernel y drivers

> **Objetivo medible**
>
> Comprender, construir y revisar un driver KMDF didáctico con una interfaz inocua, depurarlo solo en VM descartable y explicar mitigaciones actuales.

**Prerrequisitos:** Etapa 0 (laboratorio aislado), C, assembly, memoria y sincronización, WinDbg y 2D.1 (objetos/tokens), 2D.2 (memoria/loader) y 2D.11 (excepciones/debugging). Etapa 2C es recomendada, no requisito; no hace falta completar toda 2D. **Duración estimada:** 45–65 horas como estimación inicial; puede requerir más tiempo si C, WinDbg o WDK son nuevos.. Es una estimación de esta guía, derivada de la suma de las lecciones; no es una duración rígida de laboratorio.

> **Rama optativa; fuera de la aprobación obligatoria**
>
> La Etapa 6 profundiza en kernel/drivers y no cambia los requisitos de las Etapas 0–4. Sus prácticas de carga requieren una VM descartable; nunca modifiques las protecciones del equipo principal.

## Lecciones

| # | Lección | Qué aprendés |
|---|---|---|
| 6.1 | Arquitectura del kernel y modelo de E/S | user/kernel mode, IRQL, pool, IRP, I/O Manager, sincronización y bugchecks. |
| 6.2 | KMDF: driver propio con IOCTL inocuo | KMDF/UMDF y una respuesta fija con permisos restrictivos; sin acceso arbitrario a memoria. |
| 6.3 | Debugging de kernel y bugchecks | WinDbg en target VM, stacks/dumps y Driver Verifier con rollback. |
| 6.4 | Revisión defensiva de un driver | device interfaces, IOCTLs, SDDL y validación de entradas. |
| 6.5 | Minifilters y callbacks | Pila de filesystem, callbacks pre/post y límites de observación. |
| 6.6 | Mitigaciones de Windows para drivers | firma, Secure Boot, HVCI/VBS, WDAC y vulnerable driver blocklist. |

## Recursos y lecturas de referencia

- 2D · Windows internals (solo lecciones requeridas para esta rama)
- Extensión Hyper-V (optativa, no requisito)

## Evaluación de salida

- Explicar la ruta de una solicitud y los límites de IRQL, memoria y sincronización.

- Revisar un IOCTL propio de salida fija, con acceso limitado y validación completa; si no se puede cargar en VM conforme a la política vigente, entregar revisión estática.
- Leer un stack/dump de driver propio o muestra didáctica, indicando límites de símbolos y causalidad.
- Verificar mitigaciones en solo lectura y explicar qué protegen, sin desactivarlas.
- Demostrar rollback/limpieza de la VM; Driver Verifier no es requisito de aprobación.

> **Entregable de la etapa**
>
> Un archivo en tu bitácora con: lecciones completadas, ejercicios resueltos, dudas abiertas y evidencia (capturas, valores, hashes). Sin evidencia no se considera aprobada.

## Errores frecuentes

- Probar un driver en el equipo principal o desactivar protecciones para forzar su carga.
- Crear IOCTLs de lectura/escritura arbitraria o asumir que una ACL reemplaza la validación.
- Interpretar el módulo del bugcheck como causa raíz sin revisar stack y contexto.

## Qué no entra en esta etapa

Los temas que no tienen material revisado o que exceden el marco se listan en Kernel y otros territorios. No los uses como atajo: cada rama tiene prerrequisitos.

# Arquitectura del kernel y modelo de E/S

**Rama optativa de alto impacto**

Todo el bloque requiere VM descartable con snapshot. Un error en kernel puede colgar o detener el invitado; nunca pruebes un driver en el host ni en un equipo de uso diario.

**Propósito**

Construir el mapa mental de la ruta de una solicitud desde user mode al driver y reconocer qué estado/memoria es válido según IRQL. Al terminar deberías poder mirar una rutina de un driver y decir **a qué IRQL** corre, **en el contexto de qué hilo**, **qué memoria** puede tocar y **qué** podría hacer que el sistema se detenga.

**Prerrequisitos**

- *Obligatorios para Etapa 6:* C básico, assembly, memoria/stack, sincronización elemental, WinDbg y 2D.1 objetos/tokens, 2D.2 memoria/loader, 2D.11 excepciones/debugging.
- *Recomendados:* 2C WinDbg/heap y fundamentos de kernel; no exige COM, Scheduler ni toda 2D.

---

## Puente Pedagógico: De Modo Usuario a Modo Kernel (Transición Etapa 5 $\to$ Etapa 6)

Al culminar la Etapa 5, el analista domina la disección de malware, el análisis estático y dinámico de ejecutables y la auditoría de vulnerabilidades en **espacio de usuario (Ring 3)**. Al ingresar a la Etapa 6 y a la rama de controladores de dispositivo (**Modo Kernel / Ring 0**), las reglas del juego cambian drásticamente. Esta transición exige reconectar los modelos mentales aprendidos previamente:

| Concepto en Modo Usuario (Etapa 5) | Equivalente en Modo Kernel (Etapa 6) | Impacto Arquitectural y Diferencia Crítica |
|---|---|---|
| **Fallo de Acceso / Crash (`0xC0000005`)** | **Bugcheck / BSOD (`0x50`, `0xD1`, `0x3B`)** | En user-mode, un crash termina únicamente el proceso afectado. En kernel-mode, cualquier desreferencia nula o corrupción de memoria detiene por completo el sistema operativo para evitar la corrupción de datos en disco. |
| **Vulnerabilidad en Parser de Archivos (CWE-190/787)** | **Fallo de Validación en Handler de IOCTLs** | Un desbordamiento o cálculo de tamaño incorrecto en un buffer de `DeviceIoControl` permite a un usuario sin privilegios escribir en la memoria del kernel o ejecutar código arbitrario en Ring 0. |
| **Depuración Local con x64dbg** | **Depuración Remota con WinDbg y KDNET** | No se puede pausar un driver desde la misma máquina porque detener el kernel congela la pantalla, el teclado y el scheduler. Es obligatorio depurar con dos máquinas enlazadas por red (VM objetivo + Host depurador). |
| **Asignación de Memoria (`malloc` / `VirtualAlloc`)** | **Asignación en Pools (`ExAllocatePool2` Paged/NonPaged)** | En kernel no existe un heap gestionado automáticamente con protección de usuario: el desarrollador debe elegir explícitamente entre memoria paginable (*PagedPool*) o memoria física no paginable (*NonPagedPoolNx*), condicionada por el **IRQL**. |
| **Mitigaciones de Proceso (DEP, ASLR, CFG)** | **Mitigaciones de Kernel (SMEP, SMAP, kCFG, HVCI/VBS)** | El procesador y el hipervisor impiden activamente que el kernel ejecute código en páginas de usuario (SMEP) o lea memoria de usuario sin intermediación (SMAP). |

## Mapa del kernel

Las aplicaciones corren en **user mode** con privilegios limitados; el kernel y drivers operan en **kernel mode**, donde un fallo puede afectar al sistema entero. El **I/O Manager** traduce solicitudes en IRP y las dirige por una pila de drivers. El **IRQL** limita qué rutinas/operaciones son válidas en cada contexto; a IRQL elevado no se puede asumir que una operación bloqueante o memoria paginable sea segura.

El **pool** es memoria del kernel con políticas de paginación/NX. La sincronización protege estado compartido entre CPU, callbacks e interrupciones. Un **bugcheck** detiene Windows al detectar una condición grave; el dump y stack ayudan a atribuirla, aunque el driver señalado puede no ser el origen.

## IRQL: qué se puede hacer en cada nivel

El IRQL al que corre una rutina determina qué funciones de soporte puede llamar. Los niveles que más vas a ver, de menor a mayor:

| IRQL | Qué rutinas típicas corren ahí | Qué se puede y qué no |
|---|---|---|
| `PASSIVE_LEVEL` | `DriverEntry`, `AddDevice`, `Unload`, la mayoría de las rutinas de despacho, hilos del driver, callbacks de *worker threads* | Hay contexto de hilo; se puede esperar y el código/datos pueden ser paginables |
| `APC_LEVEL` | Algunas rutinas de despacho | Igual que `PASSIVE_LEVEL`, salvo que no se reciben APC; el código puede ser paginable |
| `DISPATCH_LEVEL` | `StartIo`, DPC (`DpcForIsr`, `CustomDpc`), timers, rutinas de completion de drivers de nivel superior, `Cancel` con el spin lock tomado | **No** se puede esperar un objeto con intervalo no nulo; **no** se puede tocar memoria paginable; los spin locks suben a este nivel |
| DIRQL | Rutina de interrupción (ISR), `SynchCritSection` | Lo mínimo indispensable; se difiere el resto a un DPC |

Dos reglas documentadas que explican muchos bugchecks: una rutina por encima de `APC_LEVEL` no puede asignar ni acceder a pool paginado (un fallo de página ahí es fatal), y esperar con intervalo no nulo a `DISPATCH_LEVEL` o más también es fatal. Cuanto más alto el IRQL, más corta debe ser la rutina.

## Contexto de hilo

La mayoría de las rutinas de un driver corren en un **contexto de hilo arbitrario**: el del hilo que estaba ejecutándose cuando se las llamó, que puede no tener nada que ver con la aplicación que pidió la operación. Solo los drivers de más alto nivel (por ejemplo, la parte de un sistema de archivos que atiende la llamada) corren en el contexto del hilo que hizo la solicitud. Consecuencias:

- Una dirección de **user mode** solo tiene sentido en el contexto del proceso que la pasó; por eso los métodos de buffer de 6.2 y el patrón de `METHOD_NEITHER` de 6.4.
- El estado de cada dispositivo se guarda en la **extensión del dispositivo** (en KMDF, en el contexto del objeto), no en variables del hilo.

## Objetos de dispositivo, pilas y stack locations

Cada dispositivo se representa con una **pila de objetos de dispositivo**: el **PDO** que crea el driver de bus, el **FDO** del driver de función y, opcionalmente, **filtros** por encima o por debajo. Un IRP entra por arriba y baja por la pila; cada driver tiene en el IRP su propia **I/O stack location** con los parámetros que le corresponden (código de función, longitudes, código de IOCTL). Al completarse, el IRP sube y los drivers que registraron rutinas de *completion* las ejecutan, normalmente a IRQL elevado. El resultado viaja en `IoStatus.Status` y la cantidad de bytes en `IoStatus.Information`.

En KMDF todo esto existe igual, pero el framework lo encapsula en objetos request, colas y callbacks (6.2).

## Pool y NX

El pool **no paginado** se puede usar a cualquier IRQL, pero es un recurso escaso; el **paginado** solo por debajo de `DISPATCH_LEVEL`. Desde Windows 8, la documentación pide asignar la memoria no paginada desde el pool **no ejecutable** (`NonPagedPoolNx`) y usar el pool ejecutable solo cuando haga falta ejecutar

código ahí. En un análisis, una asignación de pool ejecutable en un driver moderno es algo a explicar; con integridad de memoria (HVCI, ver 6.6) las asignaciones de kernel están más restringidas.

## Ejemplo trabajado

*(Diagrama conceptual.)*

```
app: DeviceIoControl
  -> I/O Manager crea IRP
  -> pila: filtro -> function driver -> bus
  -> completion/status vuelve al cliente
```

En KMDF, el framework recibe/organiza IRP y llama a callbacks del driver. En WDM, el código trabaja más directamente con dispatch routines e IRPs. No deduzcas que una app se comunica con hardware solo por llamar `DeviceIoControl`: puede ser un dispositivo software.

Lectura de un bugcheck **ilustrativo** con los conceptos de esta lección (no es un dump real):

```
Bug check 0xD1 DRIVER_IRQL_NOT_LESS_OR_EQUAL
  Arg1: dirección referenciada
  Arg2: 2              ; IRQL en ese momento = DISPATCH_LEVEL
  Arg3: 0              ; operación de lectura
  Arg4: dirección de la instrucción que leyó
```

Interpretación prudente: a `DISPATCH_LEVEL` se leyó una dirección paginable o inválida. Microsoft lista como causas típicas código o datos paginables usados a ese IRQL (por ejemplo, una función marcada paginable que corre con un spin lock tomado), un puntero inválido o liberado, o una llamada a un driver que ya se descargó. El IRQL no suele ser el problema en sí: lo es la memoria accedida. La 6.3 muestra cómo seguir cada parámetro.

## Práctica de lectura

Usá un diagrama/documentación de un driver propio o una muestra WDK ya compilada. Identificá user/kernel mode, entrada IRP, callback, cola, IRQL declarado y finalización. No cargues ni modifiques drivers en esta lección.

1. Para cada callback de la muestra, anotá a qué IRQL puede llamarse según la documentación.
2. Marcá cada asignación de memoria como paginada, no paginada o no paginada NX, y verificá que las que se usan a `DISPATCH_LEVEL` no sean paginadas.
3. Señalá dónde el driver depende del contexto del hilo llamador, si lo hace.

## Entregable

Diagrama de la ruta de una solicitud (con pila de dispositivos y stack locations), tabla callback–IRQL–memoria usada, glosario IRP/IRQL/pool/DPC/bugcheck y dos condiciones que podrían invalidar una rutina en IRQL elevado.

## Repaso

<details>
<summary>¿Qué transporta un IRP?</summary>

Una solicitud de E/S y su estado/resultado a través de la pila de drivers.
</details>

<details>
<summary>¿Por qué importa IRQL?</summary>

Restringe qué operaciones y memoria son válidas en el contexto actual.
</details>

<details>
<summary>¿Qué no puede hacer una rutina a <code>DISPATCH_LEVEL</code>?</summary>

Esperar con intervalo no nulo ni acceder a memoria paginable; un fallo de página ahí es fatal.
</details>

<details>
<summary>¿Qué significa que un driver corre en contexto de hilo arbitrario?</summary>

Que el hilo actual puede no ser el que pidió la operación; las direcciones de user mode del solicitante no son válidas en general.
</details>

<details>
<summary>¿Qué es una I/O stack location?</summary>

La parte del IRP con los parámetros para un driver concreto de la pila.
</details>

<details>
<summary>¿Por qué se prefiere <code>NonPagedPoolNx</code>?</summary>

Porque es pool no paginado no ejecutable; el ejecutable solo se usa si hace falta ejecutar código en esa memoria.
</details>

<details>
<summary>¿Un bugcheck identifica siempre al culpable?</summary>

No necesariamente; muestra dónde se detectó el problema. El análisis debe reconstruir el estado y las llamadas previas.
</details>

> **Puerta optativa**
>
> Podés explicar la ruta user mode → I/O Manager → pila de dispositivos → driver, decir a qué IRQL corre un callback y qué memoria puede usar, y leer los parámetros de un 0xD1 sin atribuirle una causa única.

> **Lo que queda fuera**
>
> El scheduler, APC en detalle, la arquitectura de la memoria virtual del kernel, PnP y energía (ver el recuadro de 6.4), DMA e interrupciones de hardware no se desarrollan.

## Fuentes

- Microsoft Learn: Overview of the Windows I/O Model, IRQL, POOL_TYPE (pool paginado, no paginado y NX), Synchronization.

- Microsoft Learn, contexto y pilas: Driver Thread Context, Introduction to Device Objects, Device nodes and device stacks, I/O Stack Locations, Introduction to DPC Objects, Introduction to Spin Locks, No-Execute Nonpaged Pool, Bug Check 0xD1.
- **Fundamentos previos:** stack/memoria 1.2; fundamentos user-mode en 2D.1.

**Etiquetas**

**Núcleo conceptual:** conceptos de memoria y procesos. **Conocimiento externo:** arquitectura del kernel/driver, IRQL, contexto de hilo, pilas de dispositivos y pool. **Ejemplo ilustrativo:** diagrama IRP y lectura de 0xD1. **Laboratorio verificado:** no; lectura conceptual.

# KMDF: driver propio con IOCTL inocuo

> **Solo en VM de pruebas**
>
> La carga de drivers altera el kernel. Necesitás VM descartable, snapshot conocido, consola de recuperación y un paquete propio. No cambies Secure Boot, firmas ni protecciones del equipo principal. Si la VM no puede probar un driver firmado según la documentación vigente del WDK, no cargues uno sin firma: completá el análisis estático.

> **Propósito**
>
> Entender cómo WDF traduce solicitudes a callbacks y practicar un canal mínimo con límites estrictos: un IOCTL consulta una estructura fija, sin lectura/escritura arbitraria de memoria. Al terminar deberías poder seguir una solicitud desde la aplicación hasta el driver, decir **en qué puntos** se controla el acceso y **dónde** se puede observar cada paso.

**Prerrequisitos**

- *Obligatorios:* 6.1 arquitectura, C/estructuras, IRP/IRQL y 2D.1 ACL.
- *Recomendados:* 2D.2 memoria/loader; 6.3 debugging de kernel; documentación de instalación WDK para el build exacto de la VM.

## WDF y la interfaz

WDF ofrece dos marcos: **KMDF** ejecuta el driver en kernel; **UMDF** hospeda drivers compatibles en user mode, con menor impacto potencial ante fallos. El marco encapsula parte del modelo WDM, pero no elimina responsabilidades de seguridad.

El laboratorio se limita a un dispositivo software KMDF. Una única solicitud `IOCTL_BLOCLAB_QUERY_VERSION` acepta cero bytes y devuelve una estructura fija `{Size, Version, State}`. El callback verifica código, longitudes y tamaño del buffer; cualquier código desconocido se rechaza. Elegí `METHOD_BUFFERED` para este intercambio pequeño y aplica SDDL restrictiva (por ejemplo, acceso solo a Administrators/SYSTEM en la VM). No incluyas IOCTL de lectura/escritura de direcciones, mapas físicos, procesos o memoria arbitraria.

## Recorrido de una solicitud IOCTL

Seguí el camino completo; cada paso tiene su propio control y su propio punto de observación.

1. **Apertura del dispositivo.** La aplicación abre el dispositivo con `CreateFile`, normalmente a través de una **interfaz de dispositivo** (o, en drivers antiguos, de un nombre o enlace simbólico). El I/O manager compara el token del llamador con el **descriptor de seguridad del dispositivo** y entrega un handle con los derechos concedidos. WDF siempre marca sus objetos de dispositivo con `FILE_DEVICE_SECURE_OPEN`, para que ese descriptor también se aplique a cualquier nombre “dentro” del namespace del dispositivo.

2. **Envío del código.** La aplicación llama a `DeviceIoControl(handle, código, entrada, salida…)`. El I/O manager mira el campo **Access** del código: si exige `FILE_READ_DATA` o `FILE_WRITE_DATA` y el handle no tiene ese derecho, **la solicitud no llega al driver**. Con `FILE_ANY_ACCESS`, basta con tener un handle.
3. **Construcción del IRP.** El I/O manager crea un IRP `IRP_MJ_DEVICE_CONTROL`. Con `METHOD_BUFFERED`, reserva **un único buffer de sistema** del tamaño del mayor entre entrada y salida, copia ahí la entrada y lo expone en `Irp->AssociatedIrp.SystemBuffer`. El driver lee la entrada **antes** de escribir la salida en el mismo buffer.
4. **Del IRP al objeto request.** Como el driver es de WDF, el framework atiende el despacho, crea un **objeto request** (`WDFREQUEST`) que representa el IRP y lo coloca en una **cola** (`WDFQUEUE`). Según cómo se configuró la cola (secuencial, paralela o manual), el framework entrega la solicitud.
5. **Callback del driver.** El framework llama a `EvtIoDeviceControl(Queue, Request, OutputBufferLength, InputBufferLength, IoControlCode)`. El driver ya recibe las longitudes y el código: ahí valida.
6. **Acceso al buffer.** `WdfRequestRetrieveOutputBuffer(Request, MinimumRequiredSize, &buffer, &length)` devuelve el buffer solo si mide al menos `MinimumRequiredSize`; si no, devuelve `STATUS_BUFFER_TOO_SMALL`. Pasar `sizeof(BLOCLAB_INFO)` como mínimo hace que el propio framework rechace buffers cortos.
7. **Finalización.** El driver completa con `WdfRequestCompleteWithInformation(Request, status, bytes)`. El I/O manager copia `bytes` del buffer de sistema al buffer de salida del usuario y `DeviceIoControl` devuelve, con `lpBytesReturned` igual a esos bytes. Después de completar, el driver ya no puede tocar el buffer.

```
App (user)        CreateFile ──► [ACL del dispositivo] ──► handle (derechos)
                  DeviceIoControl(code) ──► [bits Access del código vs. handle]
I/O manager       IRP_MJ_DEVICE_CONTROL + SystemBuffer (METHOD_BUFFERED)
WDF               WDFREQUEST ──► WDFQUEUE ──► EvtIoDeviceControl
Driver            valida código/longitudes ──► RetrieveOutputBuffer(min) ──► llena todo
                  ──► CompleteWithInformation(status, bytes)
I/O manager       copia bytes al buffer de la app ──► DeviceIoControl retorna
```

## Qué recibe el driver según el método del IOCTL

Los dos bits **Method** del código deciden cómo describe el I/O manager los dos buffers de `DeviceIoControl` (el primero, “de entrada”, y el segundo, “de salida” en los nombres de la API). Desde el lado del driver:

| Método | Primer buffer (entrada) | Segundo buffer (salida) | Qué hizo el I/O manager antes | Cómo lo obtiene un driver KMDF |
|---|---|---|---|---|
| `METHOD_BUFFERED` | `Irp->AssociatedIrp.SystemBuffer` | El **mismo** `SystemBuffer` | Reservó un buffer de sistema del tamaño mayor y copió la entrada; al completar copia `Information` bytes a la app. | `WdfRequestRetrieveInputBuffer` y `WdfRequestRetrieveOutputBuffer` (mismo buffer de sistema). |
| `METHOD_IN_DIRECT` / `METHOD_OUT_DIRECT` | `SystemBuffer` (copia, `InputBufferLength`) | Un **MDL** en `Irp->MdlAddress` que describe las páginas del buffer de la app (`OutputBufferLength`) | Verificó el acceso al segundo buffer y bloqueó sus páginas. `IN_DIRECT` asegura acceso de lectura (datos hacia el driver); `OUT_DIRECT`, de escritura (datos hacia la app). | Primer buffer como en buffered; el segundo, con `WdfRequestRetrieveOutputBuffer` (dirección de sistema) o `WdfRequestRetrieveOutputWdmMdl` (el MDL). |
| `METHOD_NEITHER` | `Parameters.DeviceIoControl.Type3InputBuffer`: dirección **de usuario** | `Irp->UserBuffer`: dirección **de usuario** | **Nada**: no copia, no valida, no bloquea. | Solo en `EvtIoInCallerContext` (contexto del hilo llamador): `WdfRequestRetrieveUnsafeUserInputBuffer` / `…OutputBuffer` y luego `WdfRequestProbeAndLockUserBufferForRead` / `…ForWrite`, antes de devolver la solicitud a una cola. |

Tres consecuencias para leer un driver:

- Con `METHOD_BUFFERED` el driver no toca memoria de usuario… **salvo** que la estructura de entrada contenga punteros. Un puntero embebido es una dirección de usuario sin validar, con los mismos riesgos que `METHOD_NEITHER`.
- Con direct I/O las páginas del segundo buffer están bloqueadas y accesibles, pero siguen perteneciendo al proceso: conviene tratar su contenido como dato no confiable que puede cambiar mientras el driver lo lee (conocimiento externo; la documentación citada describe el bloqueo, no esta garantía).
- Con `METHOD_NEITHER`, el driver asume todo el trabajo que en los otros métodos hace el I/O manager, y solo un driver del nivel más alto, en el contexto del hilo que llamó, puede hacerlo. Por eso en la 6.4 se trata como **patrón de revisión de riesgo**.

El laboratorio de esta lección usa `METHOD_BUFFERED` y no tiene punteros embebidos a propósito.

## Controles de acceso: cuatro capas que no se reemplazan

| Capa | Qué controla | Cómo se fija | Límite |
|---|---|---|---|
| Exposición del dispositivo | Qué caminos existen para abrirlo. | Preferir **interfaces de dispositivo**; nombrar el objeto o crear enlaces simbólicos solo si hace falta. | Cada nombre adicional es otro camino de apertura. |
| Descriptor de seguridad del dispositivo | **Quién** puede abrir un handle y con qué derechos. | `WdfDeviceInitAssignSDDLString` en el driver o seguridad declarada en el INF. Si el driver nombra el dispositivo sin SDDL propia, WDF aplica `SDDL_DEVOBJ_SYS_ALL_ADM_ALL`. | No valida el contenido de las solicitudes. |
| Bits **Access** del código IOCTL | **Qué derechos** del handle exige cada operación. | En `CTL_CODE`: `FILE_ANY_ACCESS`, `FILE_READ_DATA`, `FILE_WRITE_DATA`. Microsoft advierte que `FILE_ANY_ACCESS` solo se use si se está seguro de que no abre un camino de abuso. `IoValidateDeviceIoControlAccess` permite controles más estrictos. | Solo mira derechos del handle, no los datos. |
| Validación en el callback | **Qué datos** acepta el driver. | Lista cerrada de códigos, longitudes exactas, tamaño mínimo al pedir buffers, inicialización completa de la salida. | Es la última línea: si falla, las capas anteriores no compensan. |

## Ejemplo trabajado

*(Contrato ilustrativo, no salida de compilación ni de una VM.)*

```
IOCTL: BLOCLAB_QUERY_VERSION
  = CTL_CODE(0x8000, 0x800, METHOD_BUFFERED, FILE_READ_DATA)
  = (0x8000 << 16) | (1 << 14) | (0x800 << 2) | 0
  = 0x80006000
Input bytes: 0
Output bytes: sizeof(BLOCLAB_INFO) = 12   ; tres ULONG
Respuesta fija: { Size=12, Version=1, State=READY }
Otros códigos / buffer corto -> error y sin escritura fuera del buffer
```

Lectura del código: `DeviceType` `0x8000` (rango de fabricante, con el bit *Common* encendido), función `0x800` (rango de fabricante, bit *Custom*), `METHOD_BUFFERED` y `FILE_READ_DATA`: un handle abierto sin derecho de lectura **no** llega al driver con esta solicitud. El mismo desglose sirve en reversing para leer constantes que aparecen en el `switch` de un driver ajeno.

Tabla de casos que debería producir el diseño:

| Caso | Dónde se decide | Resultado esperado |
|---|---|---|
| Handle sin `FILE_READ_DATA` | I/O manager (bits Access) | La solicitud no llega a `EvtIoDeviceControl`; error de acceso. |
| Código desconocido | Callback (`default:` del `switch`) | `STATUS_INVALID_DEVICE_REQUEST`, 0 bytes. |
| Salida menor que 12 bytes | `WdfRequestRetrieveOutputBuffer` con mínimo 12 | `STATUS_BUFFER_TOO_SMALL`, 0 bytes, sin escritura. |
| Entrada distinta de 0 bytes | Callback (comparación de `InputBufferLength`) | `STATUS_INVALID_PARAMETER` (decisión de diseño del laboratorio). |
| Caso válido | Callback | `STATUS_SUCCESS`, 12 bytes, estructura completa. |

La verificación del tamaño debe ocurrir antes de obtener o copiar buffers. La respuesta se inicializa por completo para no filtrar pool; no contiene punteros ni direcciones del kernel.

## Puntos de observación defensiva

Sirven tanto para tu driver como para revisar uno ajeno en la 6.4. Separá lo que se puede ver **sin cargar nada** de lo que requiere la VM.

**Estático (sin cargar el driver):**

- **INF y paquete:** clase de dispositivo, seguridad declarada, servicio que crea.
- **Cadenas SDDL** en el binario o en el INF, y llamadas a `WdfDeviceInitAssignSDDLString`, `WdfDeviceInitAssignName`, `WdfDeviceCreateSymbolicLink` o `WdfDeviceCreateDeviceInterface`.
- **Configuración de colas:** dónde se asigna `EvtIoDeviceControl` y con qué modo de despacho.
- **Códigos IOCTL:** constantes del `switch`, desglosadas en `DeviceType`, función, método y acceso. Prestá atención a `METHOD_NEITHER` y a `FILE_ANY_ACCESS`.
- **Validaciones:** si cada rama compara longitudes antes de pedir buffers y si usa un `MinimumRequiredSize` razonable.

**Dinámico (solo en la VM de pruebas, con el debugger de kernel de la 6.3):**

- Extensiones de WDF (`wdfkd.dll`): `!wdfldr` para ver la versión del framework cargada y `!wdflogdump` para leer el **In-flight Recorder** (IFR), un registro circular que WDF mantiene por driver con el progreso de IRPs y requests.
- Breakpoint en tu `EvtIoDeviceControl` para comparar longitudes y código recibidos con lo que envió la app.
- Driver Verifier y WDF Verifier sobre **tu** driver, en la VM, para detectar usos incorrectos de buffers o de IRQL.
- Desde user mode: el `GetLastError` de `DeviceIoControl` y `lpBytesReturned` para cada caso de la tabla.

**Plantilla 6: esqueleto mínimo de `BlocLab.sys` para análisis estático**

La lección describe el *contrato* de `BlocLab.sys`, pero el código de referencia vive acá, para que puedas **compilarlo y abrirlo en IDA/Ghidra** (revisión estática de 6.4) o cargarlo en una VM descartable. Es el KMDF mínimo: `DriverEntry`, `EvtDeviceAdd` y `EvtIoDeviceControl`.

```
// bloclab_kmdf_min.c — KMDF mínimo. El SDDL restringe la apertura a SYSTEM +
Administradores.
#include <ntddk.h>
#include <wdf.h>
#include <wdmsec.h>

#define IOCTL_BLOCLAB_QUERY_VERSION \
    CTL_CODE(0x8000, 0x800, METHOD_BUFFERED, FILE_READ_DATA)   // 0x80006000

typedef struct _BLOCLAB_INFO { ULONG Size; ULONG Version; ULONG State; } BLOCLAB_INFO,
*PBLOCLAB_INFO;

EVT_WDF_DRIVER_DEVICE_ADD          BlocLabEvtDeviceAdd;
EVT_WDF_IO_QUEUE_IO_DEVICE_CONTROL BlocLabEvtIoDeviceControl;

NTSTATUS DriverEntry(PDRIVER_OBJECT DriverObject, PUNICODE_STRING RegistryPath) {
    WDF_DRIVER_CONFIG config;
    WDF_DRIVER_CONFIG_INIT(&config, BlocLabEvtDeviceAdd);      // +0x08 en x64 =
EvtDriverDeviceAdd
    return WdfDriverCreate(DriverObject, RegistryPath, WDF_NO_OBJECT_ATTRIBUTES, &config,
WDF_NO_HANDLE);
}

NTSTATUS BlocLabEvtDeviceAdd(WDFDRIVER Driver, PWDFDEVICE_INIT DeviceInit) {
    UNREFERENCED_PARAMETER(Driver);
    DECLARE_CONST_UNICODE_STRING(ntName,  L"\\Device\\BlocLab");
    DECLARE_CONST_UNICODE_STRING(symLink, L"\\DosDevices\\BlocLab");
    NTSTATUS st = WdfDeviceInitAssignName(DeviceInit, &ntName);
    if (!NT_SUCCESS(st)) return st;
    st = WdfDeviceInitAssignSDDLString(DeviceInit, &SDDL_DEVOBJ_SYS_ALL_ADM_ALL);  // solo
SYSTEM + Admin
    if (!NT_SUCCESS(st)) return st;
    WDFDEVICE device;
    st = WdfDeviceCreate(&DeviceInit, WDF_NO_OBJECT_ATTRIBUTES, &device);
    if (!NT_SUCCESS(st)) return st;
    st = WdfDeviceCreateSymbolicLink(device, &symLink);
    if (!NT_SUCCESS(st)) return st;
    WDF_IO_QUEUE_CONFIG q;
    WDF_IO_QUEUE_CONFIG_INIT_DEFAULT_QUEUE(&q, WdfIoQueueDispatchSequential);
    q.EvtIoDeviceControl = BlocLabEvtIoDeviceControl;          // +0x28 en x64
    return WdfIoQueueCreate(device, &q, WDF_NO_OBJECT_ATTRIBUTES, WDF_NO_HANDLE);
}

VOID BlocLabEvtIoDeviceControl(WDFQUEUE Queue, WDFREQUEST Request, size_t OutLen, size_t
InLen, ULONG Ioctl) {
    UNREFERENCED_PARAMETER(Queue); UNREFERENCED_PARAMETER(OutLen);
    if (Ioctl != IOCTL_BLOCLAB_QUERY_VERSION) { WdfRequestComplete(Request,
STATUS_INVALID_DEVICE_REQUEST); return; }
    if (InLen != 0)                           { WdfRequestComplete(Request,
STATUS_INVALID_PARAMETER);      return; }
    PBLOCLAB_INFO out = NULL;
    // valida automáticamente OutputBufferLength >= sizeof(BLOCLAB_INFO) (12 bytes):
    NTSTATUS st = WdfRequestRetrieveOutputBuffer(Request, sizeof(BLOCLAB_INFO),
(PVOID*)&out, NULL);
    if (!NT_SUCCESS(st)) { WdfRequestComplete(Request, st); return; }   //
STATUS_BUFFER_TOO_SMALL
    RtlZeroMemory(out, sizeof(BLOCLAB_INFO));
    out->Size = sizeof(BLOCLAB_INFO); out->Version = 1; out->State = 1; // READY
```

```
    WdfRequestCompleteWithInformation(Request, STATUS_SUCCESS, sizeof(BLOCLAB_INFO));
}
```

## Práctica controlada

1. Partí de una muestra KMDF de Microsoft/plantilla WDK y documentá el WDK/SDK, Visual Studio, arquitectura y build de Windows usados; solo completá versiones después de verificarlas localmente.
2. Implementá el contrato fijo de consulta y las comprobaciones de longitud/código; revisá SDDL, exposición del dispositivo y configuración INF con la lista de seguridad de Microsoft. Elegí los bits Access del código y justificalos.
3. Compilá y analizá el paquete con la lista de **puntos de observación estática**. La carga es opcional y solo en VM compatible con firma de prueba siguiendo WDK actual; no uses comandos de relajación en el host.
4. Si cargaste el driver, la app cliente prueba todos los casos de la tabla: respuesta correcta, buffer de salida corto, entrada no vacía, código no admitido y handle sin derecho de lectura. Resultado esperado: respuesta fija o error limpio; nunca acceso genérico a memoria.
5. Desinstalá el paquete propio con el procedimiento documentado para esa VM, confirmá que ya no está cargado/registrado y revertí el snapshot.

**Alternativa sin carga:** si no compilaste o no podés cargar el driver en una VM compatible, hacé solo análisis estático del código fuente y del binario compilado (o de una muestra KMDF de Microsoft): recorré los siete pasos del recorrido señalando en qué línea ocurre cada uno, completá la tabla de controles y marcá cada caso de la tabla de pruebas como “esperado según el código, no ejecutado”.

## Entregable

Contrato IOCTL con el desglose del código, diagrama del recorrido, modelo de amenaza, SDDL y exposición del dispositivo, tabla de casos válidos/negativos (indicando cuáles se ejecutaron), log de build y verificación de limpieza/snapshot. Si no se cargó, marcá el ejercicio como revisión estática.

## Repaso

▼ **¿Por qué el IOCTL devuelve una estructura fija?**

> Reduce superficie y permite validar longitudes y contenido de forma acotada.

▼ **¿Qué riesgo resuelve una SDDL restrictiva?**

> Limita qué identidades pueden abrir el dispositivo; no reemplaza la validación dentro del driver.

▼ **¿Qué controla el campo Access de un código IOCTL y quién lo aplica?**

> Qué derechos debe tener el handle para enviar ese código. Lo aplica el I/O manager antes de crear el IRP: si no se cumple, la solicitud no llega al driver.

▼ **Con `METHOD_BUFFERED`, ¿por qué el driver debe leer la entrada antes de escribir la salida?**

> Porque entrada y salida comparten un único buffer de sistema; escribir la salida primero puede pisar la entrada.

▼ **¿Qué hace `WdfRequestRetrieveOutputBuffer` si el buffer es menor que `MinimumRequiredSize`?**

> Devuelve `STATUS_BUFFER_TOO_SMALL` y no entrega el buffer.

▼ **Con `METHOD_OUT_DIRECT`, ¿dónde está el buffer de salida desde el punto de vista del driver?**

> En un MDL ( `Irp->MdlAddress` ) que describe las páginas bloqueadas del buffer de la app; en KMDF se obtiene con `WdfRequestRetrieveOutputBuffer` o `WdfRequestRetrieveOutputWdmMdl`.

▼ **¿Por qué un IOCTL `METHOD_BUFFERED` puede tener los mismos riesgos que uno `METHOD_NEITHER`?**

> Si la estructura de entrada trae punteros embebidos: esas direcciones son de usuario y el I/O manager no las valida.

▼ **¿Por qué se rechaza un IOCTL desconocido?**

> Porque una solicitud no definida no debe llegar a una operación implícita o permisiva.

▼ **No pudiste cargar el driver en la VM. ¿Qué entregás?**

> Una revisión estática: el recorrido señalado en el código, la tabla de controles y los casos marcados como esperados y no ejecutados.

**Puerta optativa**

Podés explicar el flujo KMDF desde `DeviceIoControl` hasta la finalización, desglosar un código IOCTL, distinguir las cuatro capas de control de acceso, señalar puntos de observación estática y dinámica, y demostrar (o justificar estáticamente) validación de buffers/códigos y respuesta sin datos no inicializados.

**Lo que queda fuera**

Escribir drivers con direct I/O o `METHOD_NEITHER`, DMA, la gestión de MDL propios y la firma de producción no se desarrollan. La revisión de `METHOD_NEITHER`, colas, cancelación y PnP/power sigue en la 6.4, como lectura de flujo. El laboratorio no demuestra que un driver real sea seguro: solo practica un contrato mínimo.

## Fuentes


- Microsoft Learn, modelo y recorrido: Differences between WDM and WDF, Creating Framework Request Objects, Dispatching Methods for I/O Requests, IOCTL callback, WdfRequestRetrieveOutputBuffer, WdfRequestCompleteWithInformation.

- Microsoft Learn, códigos y acceso: Defining I/O Control Codes, Buffer Descriptions for I/O Control Codes, Methods for Accessing Data Buffers, Using Direct I/O, Accessing Data Buffers in WDF Drivers, KMDF device access control, WdfDeviceInitAssignSDDLString, IoValidateDeviceIoControlAccess, Driver security checklist.
- Microsoft Learn, observación y firma: Using the Framework's Event Logger (IFR), Wdfkd.dll extensions, Driver Verifier, Test signing.

**Etiquetas**

**Núcleo conceptual:** ninguno específico. **Conocimiento externo:** WDF, KMDF, recorrido de IOCTL, buffers y MDL por método, controles de acceso, herramientas de observación y firma. **Ejemplo ilustrativo:** contrato BlocLab, cálculo del código y tabla de casos (no compilados ni ejecutados en esta edición). **Laboratorio verificado:** no; requiere toolchain/VM y revisión de seguridad. La alternativa de análisis estático no requiere cargar nada.

**Ampliación editorial basada en fuentes externas — Verificación de MinimumRequiredSize y EvtIoInCallerContext en KMDF**

Según WdfRequestRetrieveOutputBuffer y Accessing Data Buffers in WDF Drivers en Microsoft Learn *(Hecho confirmado)*:

- **Validación de tamaño en `WdfRequestRetrieveInputBuffer` / `WdfRequestRetrieveOutputBuffer`:** El segundo parámetro ( `RDX` en x64) es `MinimumRequiredLength` / `MinimumRequiredSize`. Si el buffer es menor, KMDF devuelve `STATUS_BUFFER_TOO_SMALL` ( `0xC0000023` ). Al revisar un driver en IDA/Ghidra (6.4), comprobá siempre que ese segundo argumento no sea `0` cuando luego se escribe una estructura de tamaño fijo.
- **Por qué `METHOD_NEITHER` requiere `EvtIoInCallerContext`:** Como las colas WDF pueden despachar solicitudes en un hilo arbitrario, las direcciones de usuario ( `Type3InputBuffer` y `UserBuffer` ) solo son válidas en el contexto del llamador. Por eso deben tomarse en `EvtIoInCallerContext` con `WdfRequestRetrieveUnsafeUserInputBuffer` y bloquearse con `WdfRequestProbeAndLockUserBufferForRead` / `ForWrite` antes de encolar la solicitud.

# Debugging de kernel y bugchecks

> **Driver Verifier puede detener la VM**
>
> Microsoft advierte que Driver Verifier puede generar bugchecks. Usalo solo sobre el driver didáctico propio en una VM descartable, con snapshot previo y método de recuperación probado. No verifiques todos los drivers del host.

> **Propósito**
>
> Separar depuración user-mode de kernel, obtener un stack reproducible de un driver propio y explicar qué evidencia aporta un dump. Al terminar deberías poder recorrer un bugcheck con un método fijo —código, parámetros, contexto, stack, módulo, memoria— y escribir una conclusión que diga qué está probado y qué no.

**Prerrequisitos**

- *Obligatorios:* 6.1, driver propio revisado de 6.2, WinDbg y 2D.11 excepciones.
- *Recomendados:* 2C WinDbg/heap; test-target VM configurada según WDK vigente.

## Flujo de depuración

WinDbg puede depurar el kernel local o un equipo de prueba conectado. En la VM, símbolos correspondientes al build permiten resolver funciones y tipos; sin ellos, direcciones/nombres pueden quedar incompletos. Ante bugcheck, guarda código, parámetros, dump y estado del snapshot. `!analyze -v` es un punto de partida, no una conclusión automática.

Driver Verifier comprueba reglas de drivers y puede provocar deliberadamente un bugcheck al detectar violaciones. Configurá solo el driver objetivo de prueba a través de su UI/documentación, mantén el rollback disponible y apágalo/revierte la VM al finalizar según el procedimiento Microsoft aplicable.

## Símbolos

Sin símbolos correctos, el stack muestra direcciones o nombres aproximados y cualquier conclusión se debilita. La ruta de símbolos combina el servidor público de Microsoft (para el sistema) y la carpeta con el PDB **de tu build** del driver. Después de cambiarla se recargan con `.reload`. Anotá en el informe qué símbolos estaban disponibles; un frame que dice `BlocLab+0x1a2b` en lugar de un nombre de función es un límite, no un dato.

## Qué contiene un dump y qué no

Windows ofrece cinco configuraciones de volcado de kernel, que difieren sobre todo en tamaño:

| Tipo | Qué guarda | Para qué alcanza |
|---|---|---|
| Completo | Toda la memoria física, incluida parte de user mode | El análisis más amplio; es el más grande |
| Activo | Similar al completo para la mayoría de los fines, algo más chico | Casi todo lo del completo |
| De kernel | Memoria del kernel; en general omite user mode | Stacks, objetos y pool del kernel |
| Automático | Igual que el de kernel, con más flexibilidad en el archivo de paginación | Ídem kernel |
| Pequeño (minidump) | 64 KB | Código, parámetros, stack básico y lista de módulos |

Microsoft aclara que ningún dump da tanta información como depurar en vivo: es una **foto** de un instante. Si el dump es pequeño, declarar que no se pudo inspeccionar memoria que no está incluida.

## Lectura guiada de un bugcheck

Un orden de trabajo que evita saltar a conclusiones:

| Paso | Comando | Qué responde | Límite |
|---|---|---|---|
| 1. Código y parámetros | `.bugcheck`, `!analyze -v` | Qué condición detectó el sistema y con qué argumentos | El "módulo sospechoso" es una heurística |
| 2. Significado de los parámetros | Página del código en la referencia de bugchecks | Qué representa cada argumento para **ese** código | Cada código tiene su propia tabla |
| 3. Contexto | `.trap` (si hay trap frame) o `.cxr` | Registros y stack en el punto del fallo | No siempre hay trap frame |
| 4. Stack | `k`, `kv` | Ruta de llamadas | Depende de símbolos |
| 5. Instrucción y memoria | `ln`, `u` sobre la dirección; `!pool`, `!address`, `!pte` sobre la memoria referenciada | Qué función accedió a qué y si era pool paginado | Interpretación técnica, no causa raíz automática |
| 6. IRQL y módulos | `!irql`, `lm t n` | Nivel en el momento y versiones de los módulos | `!irql` refleja lo guardado por el depurador |
| 7. Objetos del driver | `!drvobj`, `!devobj`, `!irp`; `!wdfkd.*` en KMDF (6.2) | Qué dispositivo y qué solicitud estaban en curso | Requiere saber qué objeto mirar |

Para un 0xD1, por ejemplo, la documentación indica usar `ln` con el cuarto parámetro para ver la función que hizo el acceso, `!pool` sobre el primero para saber si era pool paginado y `dx KiBugCheckDriver` para leer el nombre del driver que el sistema registró como responsable. También advierte que, en la mayoría de los casos de ese código, el problema no es el IRQL sino la memoria accedida.

## Ejemplo trabajado

*(Esquema ficticio, no dump real.)*

```
Bugcheck observado: DRIVER_VERIFIER_DETECTED_VIOLATION
!analyze -v: módulo sospechoso = BlocLab.sys
stack: nt!Verifier -> Wdf01000!callback -> BlocLab!EvtIoDeviceControl
Conclusión: revisar la longitud del buffer en el callback; confirmar parámetros y código fuente
```

El módulo señalado es evidencia para investigar; comprueba stack, parámetros, build/símbolos y si el driver estaba realmente activo en esa solicitud.

Informe de ese caso, separando observación de inferencia (ilustrativo):

| Afirmación | Tipo | Evidencia |
|---|---|---|
| Driver Verifier detectó una violación | Observación | Código de bugcheck y parámetros |
| La violación ocurrió durante `EvtIoDeviceControl` de BlocLab | Observación con símbolos | Stack con PDB del build propio |
| La solicitud en curso era el IOCTL `0x80006000` | Observación | `!wdfkd` / `!irp` sobre la solicitud del frame |
| La causa es una validación de longitud ausente | Inferencia | Coincide con el parámetro y el código fuente; falta reproducir |
| Ningún otro driver intervino | No determinado | El dump pequeño no incluye toda la memoria |

**Conectar KDNET a una VM: los pasos que faltan**

`bcdedit /dbgsettings net` genera una **clave** ( `Key=w.x.y.z` ) que hay que copiar en WinDbg; sin ella —o con un adaptador de red que `kdnet.sys` no soporta— WinDbg se queda en *Waiting to reconnect*.... Secuencia que funciona:

```
:: 1. Hipervisor (VirtualBox/VMware): adaptador de red en Host-Only, tipo "Intel PRO/1000 MT
Desktop (82540EM)".
:: 2. En la VM (cmd como Administrador), apuntando a la IP Host-Only del HOST:
bcdedit /debug on
bcdedit /dbgsettings net hostip:192.168.56.1 port:50000
:: 3. Copiá la clave que imprime (Key=1.2.3.4).
:: 4. En el host:
windbg -k net:port=50000,key=1.2.3.4
:: 5. Reiniciá la VM: shutdown /r /t 0
```

Para inspeccionar requests de KMDF, el nombre del módulo va **sin** `.sys` : `!wdfkd.wdflogdump bloclab` .

## Práctica

En VM con snapshot, conecta el debugger a un target de prueba ya configurado y carga solo el driver propio permitido. Captura una solicitud válida, inspecciona lista de módulos/stack y unload. Driver Verifier es opcional y solo si el docente confirma el rollback; no provoques un fallo deliberado ni fuerces un bugcheck. Si aparece uno, conserva el dump, analiza offline y revierte.

1. Configurá la ruta de símbolos con el PDB de tu build y verificá con `lm` que el driver propio tiene símbolos.
2. Con el target vivo, ubicá tu driver con `!drvobj` y su dispositivo con `!devobj`; si estás en el callback, seguí la solicitud con `!wdfkd` o `!irp`.
3. Si tenés un dump (propio o de un ejercicio provisto), recorré la tabla de lectura guiada paso por paso y completá la tabla de afirmaciones.

## Entregable

Registro de build/VM, símbolos, tipo de dump, comandos de inspección usados, stack, tabla de afirmaciones (observación/inferencia/no determinado) y evidencia de que driver/verifier ya no están activos o snapshot revertido.

## Repaso

▼ **¿`!analyze -v` da siempre la causa raíz?**

> No. Resume el bugcheck y pistas; hay que correlacionar parámetros, stack, símbolos y estado.

▼ **¿Por qué no usar Driver Verifier sobre el host?**

> Puede causar bugchecks y afectar estabilidad; se limita a un target de pruebas recuperable.

▼ **¿Qué no podés esperar de un minidump?**

> La memoria completa: tiene 64 KB; alcanza para código, parámetros y stack básico, no para inspeccionar estructuras grandes.

▼ **¿Para qué sirve `.trap` o `.cxr` antes de `k`?**

> Para poner el contexto en el punto del fallo, de modo que el stack corresponda a ese momento.

▼ **En un 0xD1, ¿qué parámetro llevás a `ln` y cuál a `!pool`?**

> El cuarto (dirección de la instrucción) a `ln`, para ver la función; el primero (memoria referenciada) a `!pool`, para ver si era pool paginado.

▼ **Un frame dice `BlocLab+0x1a2b`. ¿Qué te falta?**

> Símbolos correctos del build; sin ellos, el nombre de la función es una suposición.

**Puerta optativa**

Podés capturar un stack/dump del driver propio, configurar y declarar símbolos, recorrer un bugcheck con el orden código–parámetros–contexto–stack–memoria–objetos, explicar límites del tipo de dump y salir del ejercicio con target restaurado.

**Lo que queda fuera**

La configuración del enlace de depuración de kernel paso a paso (se sigue la documentación del WDK vigente), el análisis de hangs y deadlocks, la depuración de hipervisor y el análisis de dumps de terceros no se desarrollan.

## Fuentes

- Microsoft Learn: Setting up kernel-mode debugging, Live kernel-mode debugging using WinDbg, Driver Verifier, Bug check analysis.
- Microsoft Learn, lectura: Symbol path, Varieties of Kernel-Mode Dump Files, !analyze, .bugcheck, !drvobj, !devobj, !irp, Bug Check 0xD1, Wdfkd.dll extensions.

**Etiquetas**

**Núcleo conceptual:** WinDbg de user mode. **Conocimiento externo:** depuración kernel, símbolos, tipos de dump, lectura de bugchecks y verifier. **Ejemplo ilustrativo:** bugcheck e informe ficticios. **Laboratorio verificado:** no; el target de kernel no se probó.

# Revisión defensiva de un driver

> **Sin explotación**
>
> Esta revisión busca defectos de diseño y evidencia para corregirlos. No pruebes IOCTLs contra drivers de terceros ni intentes conseguir acceso privilegiado. Los patrones de riesgo de esta lección se usan para **leer** código y binarios propios o didácticos, no para construir pruebas contra un kernel cargado.

> **Propósito**
>
> Reconstruir la superficie de acceso de un driver desde nombre/interfaz y permisos hasta cada IOCTL y su validación, y leer el ciclo de vida de una solicitud (colas, propiedad, cancelación) para encontrar rutas donde la validación o la finalización fallan.

**Prerrequisitos**

- *Obligatorios:* 6.1 modelo E/S, 6.2 KMDF, 2D.1 objetos/ACL.
- *Recomendados:* 2D.2 memoria, 2D.11 excepciones, seguridad de 6.6.

## Lista de lectura

1. ¿El driver crea un nombre de dispositivo solo cuando hace falta? ¿La interfaz usa ACL/SDDL limitada?
2. ¿Qué IOCTLs exporta, con qué **método** y qué permisos de acceso exige cada uno?
3. ¿Valida tamaño, versión, enum, flags, longitud de salida y estado antes de operar?
4. ¿Evita punteros del usuario, direcciones físicas, handles sin validar y salida no inicializada? Si usa `METHOD_NEITHER` o punteros embebidos, ¿aplica el patrón de la sección siguiente?
5. ¿Completa solicitudes en todas las rutas, una sola vez, y sincroniza estado compartido?
6. Si retiene solicitudes, ¿las marca como cancelables o comprueba la cancelación?

La **superficie de ataque** es el conjunto de entradas accesibles y efectos asociados; una interfaz amplia aumenta revisión necesaria, pero no basta para afirmar vulnerabilidad.

## Patrón de revisión: `METHOD_NEITHER` y punteros de usuario

Con `METHOD_NEITHER`, el I/O manager entrega al driver las **direcciones de usuario** originales (`Type3InputBuffer`, `UserBuffer`) sin validarlas ni bloquearlas (ver la tabla de métodos en la 6.2). Lo mismo pasa con un **puntero embebido** dentro de una estructura que llegó por `METHOD_BUFFERED`: el buffer es de sistema, pero el puntero que trae adentro sigue siendo de usuario. Que un driver use cualquiera de los dos no es un defecto en sí, pero marca código que hay que leer con este patrón.

**Dónde aparece.** En el código: el bit de método `3` en las definiciones `CTL_CODE` (`METHOD_NEITHER`), accesos a `Type3InputBuffer` o `UserBuffer`, o en KMDF un `EvtIoInCallerContext` con `WdfRequestRetrieveUnsafeUserInputBuffer` / `…OutputBuffer`. En un binario: las mismas constantes en el

`switch` del código de control (los dos bits bajos en `11`) y lecturas de esos campos del IRP o llamadas a esas funciones.

**Por qué `ProbeForRead` no alcanza por sí solo.** `ProbeForRead` / `ProbeForWrite` comprueban que el rango esté en la parte de usuario del espacio de direcciones y alineado, **en ese momento**. Microsoft documenta además que:

- con `Length = 0` no comprueba nada;
- deben llamarse dentro de `try/except`;
- **todo acceso posterior** también debe estar protegido, porque otro hilo de la aplicación puede liberar, sustituir o cambiar la protección del rango en cualquier momento, incluso durante o después del sondeo;
- el contenido puede cambiar mientras el driver lo usa.

Es decir: el sondeo valida una **dirección**, no una **decisión** basada en el contenido.

**Preguntas de revisión** (sobre código propio o didáctico):

| Pregunta | Qué buscar | Señal de riesgo |
|---|---|---|
| ¿Distingue llamadas desde user mode y kernel mode? | Uso de `RequestorMode` antes de sondear | Sondeo incondicional o ausencia de distinción |
| ¿La longitud sondeada es la que después se usa? | Misma variable para sondear y copiar; cálculo de tamaños sin desbordamiento | Sondeo con un tamaño y copia con otro, o multiplicaciones sin control |
| ¿Cada acceso al buffer de usuario está dentro de `try/except`? | Bloques de excepción alrededor de **todas** las lecturas y escrituras | Solo el sondeo protegido |
| ¿Captura los datos una sola vez? | Copia a un buffer del kernel y validación sobre la copia | Validar un campo en memoria de usuario y volver a leerlo para usarlo (doble lectura) |
| ¿Se usa el buffer fuera del hilo que llamó? | Bloqueo (`WdfRequestProbeAndLockUserBufferForRead` / `…ForWrite` o MDL propio) antes de encolar | Dirección de usuario guardada y usada desde otra cola, un DPC o un hilo del sistema |
| ¿Hacen falta estos punteros? | Diseño alternativo con offsets relativos o buffers de longitud variable | Punteros embebidos en una interfaz que podría ser `METHOD_BUFFERED` puro |

Lectura **ilustrativa** de un fragmento hipotético, para practicar el patrón (no es código de un driver real ni una receta):

```
// handler hipotético, METHOD_NEITHER
p = Type3InputBuffer
ProbeForRead(p, sizeof(REQ), 4)        // dentro de try/except: OK
if (p->Len > MAX) fail                  // valida en memoria de usuario...
memcpy(local, p->Data, p->Len)          // ...y vuelve a leer Len: doble lectura
                                        // memcpy fuera del try/except: acceso sin protección
```

Hallazgos que debería registrar el informe: la validación y el uso leen `Len` dos veces de memoria de usuario; la copia no está protegida por el manejador de excepciones. Corrección propuesta: capturar la estructura completa en un buffer del kernel dentro de `try/except`, validar la copia y usar solo la copia; o rediseñar el IOCTL como `METHOD_BUFFERED` sin punteros.

## Leer el flujo de una solicitud: colas, propiedad y cancelación

Muchos defectos no están en la validación sino en **quién es dueño** de la solicitud y **cuántas veces** se completa. En WDF el modelo es explícito:

- **Propiedad.** Mientras la solicitud está en una cola, es del **framework**. Cuando la entrega a un callback, pasa a ser del **driver**, que debe hacer exactamente una de estas cosas: completarla, reencolarla, reenviarla a un destino de E/S o cancelarla. Después de eso ya no la posee y no puede tocarla (ni sus buffers).
- **Colas y despacho.** Cada cola tiene un modo de despacho (secuencial, paralelo o manual) y unos callbacks registrados; `WdfDeviceConfigureRequestDispatching` puede desviar tipos de solicitud a colas distintas. Al revisar, armá una tabla cola → modo → callbacks → tipos de solicitud.
- **Cancelación.** Si la operación se cancela, el framework cancela con `STATUS_CANCELLED` las solicitudes que **todavía no entregó** al driver. Una vez entregada, solo el driver puede cancelarla, y para enterarse debe haberla marcado con `WdfRequestMarkCancelable` / `…Ex` (registrando `EvtRequestCancel`) o consultar `WdfRequestIsCanceled` mientras la posee. Si la reencola en una cola con `EvtIoCanceledOnQueue`, el framework llama a ese callback en lugar de cancelarla, y el driver debe completarla.

Ejemplo de lectura **ilustrativo** de una solicitud retenida (no corresponde al driver de 6.2, que completa en el acto):

```
EvtIoDeviceControl(R)          // el driver ahora posee R
  WdfRequestMarkCancelableEx(R, EvtCancel)
  guarda R en la lista "pendientes"      // espera un evento del dispositivo
--- más tarde, una de dos rutas ---
(a) llega el evento:  WdfRequestUnmarkCancelable(R) -> completa R con STATUS_SUCCESS
(b) la app cancela:   EvtCancel(R) -> quita R de la lista -> completa R con STATUS_CANCELLED
```

Preguntas de revisión: ¿hay alguna ruta en la que **ambas** ramas completen la misma solicitud? ¿Se respeta el resultado de `WdfRequestUnmarkCancelable` antes de completar? ¿La lista de pendientes está protegida contra acceso concurrente? ¿Una solicitud retenida mucho tiempo **sin** marcarse cancelable puede dejar colgado al proceso que la envió? Microsoft dedica una página a sincronizar cancelación y finalización; si el código no la sigue, es un hallazgo a documentar con archivo y línea.

**Recuadro conceptual: PnP y energía**

Un driver de función KMDF suele registrar callbacks de PnP y energía: `EvtDevicePrepareHardware` / `EvtDeviceReleaseHardware` (recursos del hardware) y `EvtDeviceD0Entry` / `EvtDeviceD0Exit` (entrada y salida del estado de trabajo D0). Las colas **administradas por energía** solo entregan solicitudes cuando el dispositivo está en D0; si no lo está, las solicitudes esperan. En la revisión basta con saber dos cosas: si la cola de IOCTL es administrada por energía (lo que explica solicitudes que "no avanzan") y si algún callback de energía libera estado que un callback de E/S todavía puede usar. El dispositivo software de la 6.2 apenas usa esta maquinaria; el diseño de PnP/energía queda fuera del curso.

## Ejemplo trabajado

*(Checklist ilustrativo para el driver de 6.2.)*

```
Device interface: acceso solo a Administrators/SYSTEM
IOCTL 0x80006000 (BLOCLAB_QUERY_VERSION, contrato ilustrativo de 6.2)
  METHOD_BUFFERED, FILE_READ_DATA -> input=0, output=12
  sin punteros embebidos; no hay METHOD_NEITHER
Otras solicitudes: rechazadas con STATUS_INVALID_DEVICE_REQUEST
Buffer: longitud comprobada; respuesta inicializada por completo
Cola: una cola por defecto; la solicitud se completa en el mismo callback
Cancelación: no aplica (no se retienen solicitudes)
Conclusión: diseño acotado en el fragmento revisado; falta validar build/configuración INF
```

El código `0x80006000` sale del contrato **ilustrativo** de la 6.2; en un driver real se toma de su header, no se supone.

**Ampliación editorial basada en fuentes externas — Resolución de la tabla `WdfFunctions` ( `WDFFUNCTIONS` ) en drivers KMDF sin símbolos en IDA y Ghidra**

Al analizar estáticamente un driver KMDF sin archivo `.pdb`, las llamadas a la API del framework ( `WdfDriverCreate`, `WdfDeviceCreate`, `WdfIoQueueCreate`, `WdfRequestRetrieveInputBuffer`, etc.) **no aparecen en la tabla de importaciones (IAT)** (*Microsoft Learn: KMDF Driver Entry and Binding / `wdffuncenum.h` del WDK*) (**Hecho confirmado**):

1. **Mecanismo de enlace dinámico de KMDF:**

El binario solo importa `WdfVersionBind` desde `WdfLdr.sys`. Durante el arranque, el stub del compilador llena una estructura `WDF_BIND_INFO` que contiene la versión del framework (p. ej. `1.15` o `1.33` ) y un puntero a un puntero global en `.data`: `WdfFunctions` (de tipo `const WDFFUNCTIONS*` ), junto con `WdfDriverGlobals` ( `PWDF_DRIVER_GLOBALS` ).

1. **Patrón en ensamblador x64:**

Toda llamada a una función `Wdf*` se compila como una llamada indirecta indexada sobre esa tabla global, pasando siempre `WdfDriverGlobals` como primer argumento oculto en `RCX` (lo que desplaza un lugar todos los argumentos documentados de la función):

```
; Llamada en código C: WdfIoQueueCreate(device, &q, WDF_NO_OBJECT_ATTRIBUTES,
WDF_NO_HANDLE);
mov     rax, cs:WdfFunctions_01015   ; Carga la base de la tabla de punteros KMDF
mov     rcx, cs:WdfDriverGlobals     ; 1.er arg oculto (RCX): PWDF_DRIVER_GLOBALS
mov     rdx, rbx                     ; 2.° arg (RDX): WDFDEVICE Device
lea     r8, [rsp+40h]                ; 3.er arg (R8) : PWDF_IO_QUEUE_CONFIG Config (+0x28 =
EvtIoDeviceControl)
xor     r9d, r9d                     ; 4.° arg (R9) : WDF_NO_OBJECT_ATTRIBUTES
mov     qword ptr [rsp+20h], 0       ; 5.° arg (stack): Queue (NULL)
call    qword ptr [rax+4C0h]         ; Offset +0x4C0 (índice 152 * 8) = pfnWdfIoQueueCreate
```

1. **Tabla de offsets de funciones críticas en `WDFFUNCTIONS` ( `wdffuncenum.h` , KMDF 1.15–1.33):**

| Función KMDF ( `WDFFUNCENUM` ) | Índice decimal ( `TableIndex` ) | Offset en x64 ( `Índice * 8` ) | Offset en x86 ( `Índice * 4` ) | Qué recibe en `RDX / R8` (x64, tras `DriverGlobals` en `RCX` ) |
|---|---|---|---|---|
| `WdfDeviceInitAssignName` | `29` | `+0x0E8` | `+0x074` | `RDX` = `DeviceInit` , `R8` = `PCUNICODE_STRING` ( `\Device\...` ) |
| `WdfDeviceInitAssignSDDLString` | `31` | `+0x0F8` | `+0x07C` | `RDX` = `DeviceInit` , `R8` = `PCUNICODE_STRING` (cadena SDDL) |
| `WdfDeviceCreate` | `45` | `+0x168` | `+0x0B4` | `RDX` = `&DeviceInit` , `R8` = `Attributes` , `R9` = `&Device` |
| `WdfDeviceCreateSymbolicLink` | `46` | `+0x170` | `+0x0B8` | `RDX` = `Device` , `R8` = `PCUNICODE_STRING` ( `\DosDevices\...` ) |
| `WdfDeviceCreateDeviceInterface` | `47` | `+0x178` | `+0x0BC` | `RDX` = `Device` , `R8` = `const GUID* InterfaceClassGUID` |
| `WdfDriverCreate` | `118` | `+0x3B0` | `+0x1D8` | `RDX` = `DriverObject` , `R8` = `RegistryPath` , `R9` = `Attributes` , `[rsp+20h]` = `WDF_DRIVER_CONFIG*` |
| `WdfIoQueueCreate` | `152` | `+0x4C0` | `+0x260` | `RDX` = `Device` , `R8` = `WDF_IO_QUEUE_CONFIG*` ( `+0x28` = `EvtIoDeviceControl` ) |
| `WdfRequestComplete` | `263` | `+0x838` | `+0x41C` | `RDX` = `Request` , `R8D` = `NTSTATUS` |
| `WdfRequestCompleteWithInformation` | `265` | `+0x848` | `+0x424` | `RDX` = `Request` , `R8D` = `NTSTATUS` , `R9` = `ULONG_PTR Information` |
| `WdfRequestRetrieveInputBuffer` | `275` | `+0x898` | `+0x44C` | `RDX` = `Request` , `R8` = `MinimumRequiredSize` , `R9` = `&Buffer` |
| `WdfRequestRetrieveOutputBuffer` | `276` | `+0x8A0` | `+0x450` | `RDX` = `Request` , `R8` = `MinimumRequiredSize` , `R9` = `&Buffer` |

1. **Tipado rápido en IDA 9.0+ y Ghidra:**

Si asignás el tipo `WDFFUNCTIONS*` a la variable global `WdfFunctions` (o importás `wdf.h` / `wdffuncenum.h` ), el decompilador convierte instantáneamente `(*(void (**)(...))(WdfFunctions + 0x4C0))(...)` en `WdfFunctions->pfnWdfIoQueueCreate(...)` .

## Práctica

Revisá el source de tu driver o una muestra didáctica de Microsoft:

1. Enumerá device interfaces, SDDL, definiciones de IOCTL (con método y acceso) y callbacks.
2. Trazá un IOCTL desde la entrada hasta la finalización.
3. Si hay `METHOD_NEITHER` o punteros embebidos, completá la tabla de preguntas del patrón para cada uno. Si no hay, decilo explícitamente.
4. Armá la tabla de colas (modo, callbacks, tipos de solicitud) y, para cada solicitud que el driver retenga, dibujá las rutas de finalización y de cancelación.
5. Verificá casos límite por pruebas unitarias en user mode, sin fuzzing contra un kernel cargado.

## Entregable

Tabla entrada–control–validación–resultado; tabla de colas y rutas de finalización/cancelación; hallazgos con archivo/línea, severidad razonada y corrección propuesta. No publiques el driver o detalles sensibles sin autorización.

## Repaso

▼ **¿Una DACL fuerte vuelve seguro un IOCTL?**

> No. Reduce quién puede llamarlo, pero el callback debe validar toda entrada y salida.

▼ **¿Por qué limitar IOCTLs?**

> Cada operación exportada amplía lo que un cliente puede pedir y debe tener contrato y permisos explícitos.

▼ **¿Qué implica "superficie de ataque"?**

> Entradas y operaciones accesibles desde una frontera; es una guía de revisión, no un veredicto.

▼ **¿Por qué `ProbeForRead` no vuelve seguro todo acceso posterior?**

> Porque solo comprueba rango y alineación en ese momento (y nada si la longitud es 0); otro hilo puede cambiar el contenido o la protección después. Cada acceso posterior debe estar protegido y los datos deben capturarse una vez.

▼ **¿Qué es una doble lectura en este contexto?**

> Validar un valor en memoria de usuario y volver a leerlo para usarlo: entre las dos lecturas el valor puede cambiar.

▼ **¿Cuándo deja el driver de poseer una solicitud WDF?**

> Cuando la completa, la reencola, la reenvía o la cancela; desde ese momento no puede acceder a ella ni a sus buffers.

▼ **¿Quién cancela una solicitud que todavía está en una cola del driver?**

> El framework, con `STATUS_CANCELLED`, sin entregarla. Una vez entregada, solo el driver puede cancelarla.

▼ **Una solicitud de IOCTL "queda colgada" y el dispositivo está en un estado de bajo consumo. ¿Qué revisás?**

> Si la cola es administrada por energía: esas colas solo entregan solicitudes en D0.

> **Puerta optativa**
>
> Podés rastrear una operación desde la interfaz hasta su callback y demostrar permisos, validación de longitudes y tratamiento de errores; aplicar el patrón de revisión a `METHOD_NEITHER` y punteros embebidos; y leer las rutas de propiedad, finalización y cancelación de una solicitud.

---

## 6.4.b — Fuzzing de IOCTLs en Kernel

La superficie de ataque primaria y más crítica de cualquier controlador de dispositivo en Windows reside en su interfaz de control de E/S: los códigos `IOCTL` despachados a través del manejador `IRP_MJ_DEVICE_CONTROL` (`EvtIoDeviceControl` en KMDF). Mientras que el fuzzing en espacio de usuario (Lección 2.24) prueba parsers de archivos, el **Kernel Fuzzing** somete al controlador a combinaciones anómalas de códigos de control, tamaños de buffer incongruentes y punteros no válidos para descubrir fallos de validación antes de que causen una vulnerabilidad en producción.

### Arquitectura del Harness de Fuzzing en Modo Usuario

A diferencia de un ejecutable clásico que lee de `stdin` o de un archivo, un fuzzer de kernel ejecuta un **harness en espacio de usuario** que interactúa directamente con el objeto de dispositivo del driver:

1. **Apertura del Dispositivo:** Obtiene un handle con `CreateFileW(L"\\.\MiDriver", GENERIC_READ | GENERIC_WRITE, ...)` utilizando el enlace simbólico (*Symbolic Link*) expuesto por el driver.
2. **Bucle de Mutación de IOCTLs:** Genera o permuta códigos `CTL_CODE` iterando a través de:

- *DeviceType:* Códigos estándar o reservados (`0x8000`..`0xFFFF`).
- *Function:* Rango de índices de función del driver (`0x800`..`0xFFF`).
- *Method:* `METHOD_BUFFERED` (`0`), `METHOD_IN_DIRECT` (`1`), `METHOD_OUT_DIRECT` (`2`), `METHOD_NEITHER` (`3`).

1. **Manejo Estricto de Excepciones:** Como el envío de punteros inválidos hacia un driver con `METHOD_NEITHER` puede provocar un fallo en el propio llamador si no se captura, el harness encapsula `DeviceIoControl` dentro de un bloque `__try / __except`.

## Esqueleto de Código C: Harness de Fuzzing de IOCTLs

```
// Archivo: plantillas_codigo/ioctl_fuzzer_harness.c
// Compilar con MSVC x64: cl /Zi /O2 ioctl_fuzzer_harness.c /Fe:IoctlFuzzer.exe

#include <windows.h>
#include <stdio.h>
#include <stdlib.h>
#include <time.h>

#define MAX_PAYLOAD_SIZE 4096

// Generador de payloads mutados con patrones límite
void GenerarPayloadMutado(BYTE* buffer, DWORD size) {
    static const DWORD patrones[] = { 0x00000000, 0xFFFFFFFF, 0x7FFFFFFF, 0x80000000, 0x41414141
};
    for (DWORD i = 0; i < size; i++) {
        buffer[i] = (BYTE)(rand() % 256);
    }
    // Sobrescribir los primeros 4 bytes con valores límite enteros
    if (size >= 4) {
        *(DWORD*)buffer = patrones[rand() % 5];
    }
}

int main(int argc, char* argv[]) {
    LPCWSTR deviceName = L"\\.\BlocLabDevice";
    HANDLE hDevice = CreateFileW(deviceName, GENERIC_READ | GENERIC_WRITE, 0, NULL, OPEN_EXISTING,
0, NULL);
    if (hDevice == INVALID_HANDLE_VALUE) {
        printf("[-] Error abriendo dispositivo %ls (Error: %lu)\n", deviceName, GetLastError());
        return 1;
    }

    printf("[+] Iniciando fuzzing de IOCTLs sobre %ls...\n", deviceName);
    srand((unsigned int)time(NULL));

    BYTE inBuffer[MAX_PAYLOAD_SIZE];
    BYTE outBuffer[MAX_PAYLOAD_SIZE];
    DWORD bytesReturned = 0;

    // Rango típico de IOCTLs definidos por el desarrollador (0x800 a 0x8FF)
    for (DWORD func = 0x800; func < 0x850; func++) {
        // Probar los 4 métodos de transferencia I/O
        for (DWORD method = 0; method < 4; method++) {
            DWORD ioctl = CTL_CODE(FILE_DEVICE_UNKNOWN, func, method, FILE_ANY_ACCESS);

            for (int iter = 0; iter < 100; iter++) {
                DWORD inSize = rand() % MAX_PAYLOAD_SIZE;
                DWORD outSize = rand() % MAX_PAYLOAD_SIZE;
                GenerarPayloadMutado(inBuffer, inSize);

                __try {
                    // Envío del IOCTL fuzzeado al driver de kernel
                    DeviceIoControl(
                        hDevice,
                        ioctl,
```

```
                        inBuffer,
                        inSize,
                        outBuffer,
                        outSize,
                        &bytesReturned,
                        NULL
                    );
                }
                __except (EXCEPTION_EXECUTE_HANDLER) {
                    // Capturar excepciones generadas en usermode si el driver usa METHOD_NEITHER
                    printf("[!] Excepción en usermode con IOCTL 0x%08X (InSize: %lu)\n", ioctl,
inSize);
                }
            }
        }
    }

    CloseHandle(hDevice);
    printf("[+] Campaña de fuzzing de IOCTLs finalizada.\n");
    return 0;
}
```

### Instrumentación Guiada y Captura de Crashes con KDNET

Para que el fuzzing sea eficiente y no un mero bombardeo a ciegas:

1. **Instrumentación (Intel PT / DynamoRIO):** Herramientas avanzadas como **WinAFL** (modo `-m` para targeting de módulos) o **kAFL / syzkaller** utilizan trazas de hardware de **Intel PT (Processor Trace)** para guiar la mutación hacia bloques básicos no explorados del driver en kernel.
2. **Detección y Captura de Crashes vía KDNET:**

- La VM de pruebas se ejecuta con depuración de kernel activa mediante KDNET conectada a una máquina anfitriona con WinDbg.
- Cuando el fuzzer desencadena una corrupción de memoria en el driver, el sistema no se reinicia a ciegas; WinDbg captura de inmediato el **Bugcheck**:
- `0x50` (`PAGE_FAULT_IN_NONPAGED_AREA`)**:** El driver desreferenció un puntero inválido proveniente de `inBuffer` sin validación previa.
- `0xD1` (`DRIVER_IRQL_NOT_LESS_OR_EQUAL`)**:** El driver intentó acceder a memoria paginada mientras se ejecutaba a `DISPATCH_LEVEL`.
- `0x7E` (`SYSTEM_THREAD_EXCEPTION_NOT_HANDLED`)**:** Excepción no capturada por un bloque `__try / __except` en el driver.
- En WinDbg, el comando `!analyze -v` desglosa el call stack exacto y señala la instrucción culpable en el desensamblado del `.sys`.

## Fuentes

- Microsoft Learn: Driver security checklist, Controlling device access in KMDF, Using I/O control codes.
- Microsoft Learn, memoria de usuario: Methods for Accessing Data Buffers, Using Neither Buffered Nor Direct I/O, Errors in Referencing User-Space Addresses, ProbeForRead, Handling Exceptions, Accessing

Data Buffers in WDF Drivers.

- Microsoft Learn, colas y cancelación: Request Ownership, Configuring Dispatch Mode for an I/O Queue, Canceling I/O Requests, Synchronizing Cancel and Completion Code.
- Microsoft Learn, PnP y energía: Supporting PnP and Power Management in Function Drivers, Power Management for I/O Queues.

**Etiquetas**

**Núcleo conceptual:** superficie/mitigaciones de user mode. **Conocimiento externo:** seguridad de drivers, métodos de buffer, sondeo de memoria de usuario, propiedad y cancelación de solicitudes WDF, PnP/energía (recuadro). **Ejemplo ilustrativo:** checklist, fragmento `METHOD_NEITHER` y flujo de cancelación hipotéticos. **Laboratorio verificado:** no; revisión de código fuente.

**Ampliación editorial basada en fuentes externas — Localización estática de Dispatch Routines (WDM vs. KMDF) en IDA y Ghidra**

Al abrir un driver `.sys` sin símbolos en IDA Pro o Ghidra, la ausencia de una función `main` clásica desorienta al analista; la clave operativa para encontrar el manejador de IOCTLs radica en rastrear cómo el punto de entrada `DriverEntry(PDRIVER_OBJECT DriverObject, PUNICODE_STRING RegistryPath)` —donde `DriverObject` se recibe en `RCX` (x64) o `[esp+4]` (x86)— inicializa sus tablas de despacho (Microsoft Learn: *DRIVER_OBJECT* y *WDF_IO_QUEUE_CONFIG*) *(Hecho confirmado)*:

- **Drivers WDM clásicos ( `MajorFunction` ):** El código escribe los punteros a sus rutinas directamente sobre el arreglo `DriverObject->MajorFunction` (offset `+0x70` en x64; `+0x38` en x86). Los desplazamientos clave en x64 son:
  - `DriverUnload` : `[rcx + 0x68]` ( `+0x34` en x86).
  - `IRP_MJ_CREATE (0x00)` : `[rcx + 0x70]` ( `0x70 + 0 * 8` ).
  - `IRP_MJ_CLOSE (0x02)` : `[rcx + 0x80]` ( `0x70 + 2 * 8` ).
  - `IRP_MJ_DEVICE_CONTROL (0x0E = 14)` : **`[rcx + 0xE0]`** ( `0x70 + 14 * 8` ; en x86 es `[reg + 0x70]` ). En el desensamblado se reconoce típicamente por una instrucción como:

    ```
    mov qword ptr [rcx + 0xE0], sub_DispatchIoctl  ; Enlaza el procesador de
    DeviceControl
    ```

- **Drivers KMDF ( `EvtIoDeviceControl` ):** `DriverEntry` no puebla `MajorFunction` manualmente; en su lugar, inicializa la estructura `WDF_DRIVER_CONFIG` colocando el puntero a `EvtDriverDeviceAdd` en el offset **`+0x08`** (x64), enlaza el runtime con **`WdfVersionBind`** e invoca `WdfDriverCreate` (vía tabla global `WdfFunctions` ). Posteriormente, dentro de `EvtDriverDeviceAdd` , se busca la inicialización de `WDF_IO_QUEUE_CONFIG` (96 bytes en x64), donde el puntero a **`EvtIoDeviceControl`** se almacena en el offset **`+0x28`** antes de invocar a `WdfIoQueueCreate` .

# Minifilters y callbacks: observación del sistema de archivos

> **Alcance de lectura**
>
> No construyas un filtro para bloquear, cambiar o capturar archivos de terceros. La práctica usa documentación, una muestra didáctica y archivos descartables de la VM. No cargues, descargues, adjuntes ni separes filtros del sistema.

> **Propósito**
>
> Ubicar un minifilter en la pila de filesystem y describir pre/post callbacks, orden y límites de observación. Al terminar deberías poder leer la lista de filtros de una VM, ubicar cada uno por su altitud y explicar qué puede y qué no puede haber visto de una operación.

**Prerrequisitos**

- *Obligatorios:* 6.1 I/O y stacks, 6.3 WinDbg.
- *Recomendados:* 6.4 revisión de drivers.

## Funcionamiento

Un minifilter se conecta a una o más pilas de filesystem y puede recibir callbacks antes y después de operaciones de I/O. El Filter Manager y el registro de operaciones ordenan la interacción con otros filtros. Según propósito puede observar, modificar o impedir operaciones; esta lección estudia la observación y el orden conceptual, no modifica contenido.

Una operación visible en un callback no necesariamente llega al disco ni representa una acción completa: puede fallar, cancelarse, ser reintentada o transformarse en otra operación. Correlacioná status, contexto, proceso y archivo de prueba.

## Filter Manager, instancias y frames

El **Filter Manager** (`FltMgr.sys`) es un driver del sistema que se activa cuando se carga un minifilter y se adjunta a la pila de filesystem de cada volumen. Un minifilter **no** se adjunta directamente: se **registra** ante el Filter Manager con los tipos de operación que quiere ver. La adhesión de un minifilter a un volumen, a una altitud determinada, se llama **instancia**. Para convivir con filtros heredados (*legacy*), el Filter Manager puede tener varios **frames** en la pila, cada uno cubriendo un rango de altitudes.

Un minifilter puede recibir tres clases de operaciones: las basadas en IRP, las de **fast I/O** y las de callbacks del sistema de archivos. Una misma acción del usuario puede llegar por un camino u otro, así que “no vi el IRP” no significa “no hubo operación”.

## Altitudes y grupos de carga

Cada minifilter tiene una **altitud**: un número (interpretado como decimal) que fija su posición en la pila. Microsoft asigna las altitudes y define **grupos de carga** con rangos por tipo de producto. Algunos ejemplos de la tabla oficial:

| Grupo de carga | Rango de altitud | Propósito declarado |
|---|---|---|
| FSFilter Activity Monitor | 360000–389999 | Observar e informar sobre la E/S de archivos |
| FSFilter Anti-Virus | 320000–329999 | Detectar y desinfectar durante la E/S |
| FSFilter Replication | 300000–309999 | Replicar datos a servidores remotos |
| FSFilter Content Screener | 260000–269999 | Impedir la creación de ciertos archivos o contenidos |
| FSFilter Encryption | 140000–149999 | Cifrar y descifrar durante la E/S |
| FSFilter Virtualization | 130000–139999 | Virtualizar rutas de archivo |

Para el análisis, la altitud es una **pista de propósito**: un filtro en el rango de antivirus probablemente pertenece a un producto de seguridad. Microsoft publica además una lista de altitudes asignadas con empresa y nombre de archivo, útil para identificar un filtro desconocido. Que la altitud caiga en un rango no prueba qué hace el filtro, pero un filtro sin correspondencia en la lista pública es algo a preguntar.

## Orden de los callbacks

Cuando el Filter Manager recibe una operación, llama a los **preoperation callbacks** en orden de altitud **de mayor a menor**, y después, al completarse, a los **postoperation callbacks** en orden **inverso**, de menor a mayor. Un filtro alto ve la operación primero en la ida y último en la vuelta.

**Qué puede decidir un preoperation callback** (valores documentados):

| Valor devuelto | Significado |
|---|---|
| `FLT_PREOP_SUCCESS_NO_CALLBACK` | Deja pasar la operación y no quiere su postoperation |
| `FLT_PREOP_SUCCESS_WITH_CALLBACK` | Deja pasar y quiere ver el resultado final en el postoperation |
| `FLT_PREOP_PENDING` | La deja pendiente para completarla o continuarla después |
| `FLT_PREOP_SYNCHRONIZE` | Pide que el postoperation corra en el mismo hilo que el pre |
| `FLT_PREOP_COMPLETE` | Termina la operación ahí, con un estado final propio |

`FLT_PREOP_COMPLETE` es el caso en que un filtro **impide** o **responde** una operación sin que llegue a los filtros inferiores ni al sistema de archivos: por eso un filtro alto puede hacer que otro, más bajo, nunca vea algo.

**IRQL y contexto.** Un preoperation se llama a `PASSIVE_LEVEL` o `APC_LEVEL`, casi siempre en el hilo que originó la E/S. Un postoperation, como una rutina de completion, se llama a IRQL de hasta `DISPATCH_LEVEL` y en un hilo arbitrario, salvo excepciones documentadas (post-create a `PASSIVE_LEVEL` en el hilo original,

operaciones sincronizadas y fast I/O). Esto explica por qué un filtro bien escrito toma en el pre la información que necesitará en el post.

## Inspección de solo lectura

- **En la VM, con privilegios de administrador:** `fltmc filters` lista los minifilters cargados con su altitud y cantidad de instancias, y `fltmc instances` muestra en qué volúmenes está cada uno. Las otras órdenes de `fltmc` (cargar, descargar, adjuntar, separar) **no** se usan en este curso.
- **Con el depurador de kernel de la 6.3:** la extensión `!fltkd` ofrece `!filters`, `!frames`, `!instance` y `!volumes`, y `!cbd`, el equivalente de `!irp` para los datos de callback del Filter Manager.

## Ejemplo trabajado

*(Flujo esquemático ficticio.)*

```
app solicita abrir C:\Lab\sample.txt
  -> pre-operation callback (observa operación/flags)
  -> filesystem y filtros inferiores
  -> post-operation callback (status final/contexto)
  -> app recibe resultado
```

El callback de pre-op no prueba que la apertura haya tenido éxito; el status final aparece después. Un driver distinto puede alterar el orden observado.

Ficha de inventario de una VM (ilustrativa; nombres y altitudes ficticios):

| Filtro | Altitud | Grupo inferido | Instancias | Lectura |
|---|---|---|---|---|
| `labmon` | 370100 | Activity Monitor | C:, D: | Observa E/S en ambos volúmenes |
| `labav` | 321500 | Anti-Virus | C: | Ve la operación **después** de `labmon` en la ida y **antes** en la vuelta |
| `labcrypt` | 141000 | Encryption | D: | Si cifra, los filtros más altos ven datos en claro y los más bajos, cifrados |

Lo que **no** se puede afirmar con esta ficha: qué hace cada filtro con las operaciones, si alguno completa operaciones en el pre, ni a qué producto pertenece sin contrastar la lista pública de altitudes y el inventario de software.

## Práctica

Lee el diagrama y callbacks de una muestra oficial de minifilter sin instalarla. Opcionalmente, inspecciona un minifilter ya presente en una VM con herramientas administrativas de solo lectura y registra nombre/altitud/estado. No descargues ni cambies filtros del sistema. Si se usa una muestra cargada por el instructor, solo observa accesos a archivos creados para el lab y revierte snapshot.

1. En la muestra, enumerá qué operaciones registra, qué devuelve cada pre y si hay post.

2. En la VM, completá la ficha de inventario con `fltmc filters` y `fltmc instances`.
3. Ubicá cada filtro en su grupo por la altitud y contrastalo con la lista pública de altitudes asignadas.

## Entregable

Diagrama de stack con altitudes, puntos pre/post, ficha de inventario, datos observados, límites y confirmación de que no se alteraron archivos ni filtros de la máquina.

## Repaso

▼ **¿Pre-operation demuestra que la operación se completó?**

> No. La operación aún puede fallar o cancelarse; hay que leer resultado/post-op.

▼ **¿Un minifilter siempre modifica datos?**

> No. Puede observar, filtrar o modificar; depende de su implementación.

▼ **¿En qué orden se llaman los callbacks de varios minifilters?**

> Los pre, de mayor a menor altitud; los post, en orden inverso.

▼ **¿Qué significa `FLT_PREOP_COMPLETE` para los filtros inferiores?**

> Que la operación terminó en ese filtro: los inferiores y el sistema de archivos no la ven.

▼ **¿Por qué un postoperation no puede usar memoria paginada en general?**

> Porque puede correr hasta `DISPATCH_LEVEL` en un hilo arbitrario, salvo las excepciones documentadas.

▼ **¿Qué te dice la altitud de un filtro?**

> Su posición en la pila y, por el rango, el tipo de producto declarado; no prueba qué hace.

▼ **¿Por qué no retirar un filtro desconocido durante análisis?**

> Puede pertenecer al sistema o producto crítico; documenta y consulta al administrador para preservar estabilidad/evidencia.

> **Puerta optativa**
>
> Podés explicar el recorrido de una operación, ubicar filtros por altitud y grupo, distinguir callback previo de resultado final, explicar el efecto de cada valor de retorno del pre y documentar un inventario con alcance y límites.

## 6.5.b — Windows Filtering Platform (WFP): El "Minifilter" de la Red

Así como el **Filter Manager** (`FltMgr.sys`) gobierna la intercepción de archivos en disco, el subsistema de red de Windows implementa **WFP (Windows Filtering Platform)** para mediar, inspeccionar, autorizar y modificar el tráfico de red en modo kernel. WFP es la base técnica de los firewalls de próxima generación, soluciones EDR, proxies locales y sistemas de prevención de intrusiones corporativos.

### Arquitectura Interna de WFP vs. Minifilters de Filesystem

A diferencia del modelo de altitudes de filesystem, WFP está integrado directamente en el stack TCP/IP (`tcpip.sys`) y en el driver del cliente de filtrado (`fwpkclnt.sys`). Opera mediante una jerarquía de capas (*Filtering Layers*), filtros, subcapas y módulos de llamada (*Callouts*):

1. **Capas de Filtrado Clave (*Layers*):**

- **`FWPM_LAYER_ALE_AUTH_CONNECT_V4` / `_V6`:** *Application Layer Enforcement* para conexiones salientes. Intercepta la llamada de red en el momento exacto en que un proceso invoca `connect()`, **antes** de que el paquete TCP SYN salga al cable. Provee el PID del proceso emisor, el path completo del ejecutable y las tuplas IP/puerto de origen y destino.
- **`FWPM_LAYER_ALE_AUTH_RECV_ACCEPT_V4` / `_V6`:** Intercepta intentos de conexión entrante (`listen()` / `accept()`), permitiendo bloquear puertos a nivel de proceso.
- **`FWPM_LAYER_INBOUND_TRANSPORT_V4` / `FWPM_LAYER_OUTBOUND_TRANSPORT_V4`:** Intercepción a nivel de paquete de transporte (TCP/UDP) post-reasignación. Provee acceso al descriptor de memoria de red `NET_BUFFER_LIST` (`NBL`).
- **`FWPM_LAYER_DATAGRAM_DATA_V4` / `_V6`:** Inspección de payloads UDP crudos.

1. **Callouts de Kernel (`FWPS_CALLOUT`):**

Un controlador de seguridad registra un Callout llamando a `FwpsCalloutRegister`. La estructura define tres punteros de función fundamentales:

- **`classifyFn`:** La función principal invocada por WFP cada vez que un paquete o conexión coincide con las reglas de filtrado.
- **`notifyFn`:** Notifica al driver cuando se añaden o eliminan reglas asociadas al Callout.
- **`flowDeleteFn`:** Notifica cuando un flujo de red contextual se termina, permitiendo liberar memoria de rastreo.

### Anatomía de la Función de Clasificación ( `classifyFn` )

```
void ClassifyCallback(
    const FWPS_INCOMING_VALUES0* inFixedValues,
    const FWPS_INCOMING_METADATA_VALUES0* inMetaValues,
    void* layerData,
    const void* classifyContext,
    const FWPS_FILTER0* filter,
    UINT64 flowContext,
    FWPS_CLASSIFY_OUT0* classifyOut
) {
    // 1. Obtener el PID del proceso desde los metadatos ALE
    UINT64 processId = 0;
    if (FWPS_IS_METADATA_FIELD_PRESENT(inMetaValues, FWPS_METADATA_FIELD_PROCESS_ID)) {
        processId = inMetaValues->processId;
    }

    // 2. Extraer dirección IP y puerto de destino (en FWPM_LAYER_ALE_AUTH_CONNECT_V4)
    UINT32 ipDest = inFixedValues-
>incomingValue[FWPS_FIELD_ALE_AUTH_CONNECT_V4_IP_REMOTE_ADDRESS].value.uint32;
    UINT16 puertoDest = inFixedValues-
>incomingValue[FWPS_FIELD_ALE_AUTH_CONNECT_V4_IP_REMOTE_PORT].value.uint16;

    // 3. Decisión defensiva de filtrado:
    // FWP_ACTION_PERMIT  : Permite el tráfico sin restricciones.
    // FWP_ACTION_BLOCK   : Descarta el paquete o rechaza la conexión TCP de inmediato.
    // FWP_ACTION_CONTINUE: Pasa la decisión a las subcapas siguientes.
    if (puertoDest == 4444) { // Detección de puerto sospechoso de reversa
        classifyOut->actionType = FWP_ACTION_BLOCK;
        classifyOut->flags |= FWPS_CLASSIFY_OUT_FLAG_ABSORB; // Absorbe el paquete para evitar RST
        return;
    }

    classifyOut->actionType = FWP_ACTION_PERMIT;
}
```

### Herramientas de Inspección Defensiva de WFP

Un analista de malware o respuesta a incidentes debe auditar qué filtros y callouts están instalados en una máquina para verificar si una amenaza o software de seguridad está interceptando el tráfico de red:

1. **Inspección Nativa con `netsh` :**

```
   netsh wfp show state
```

Este comando genera un archivo **`wfpstate.xml`** en el directorio actual. Al parsearlo, se listan todos los proveedores ( `providers` ), filtros activos ( `filters` ) con sus condiciones booleanas, y los GUIDs de los callouts enlazados a drivers de terceros.

1. **Inspección con `wfptool` y WinDbg:**

- La herramienta de auditoría `wfptool.exe` permite listar filtros activos filtrando por PID del proceso o por capa (`ALE_AUTH_CONNECT_V4`).
- En WinDbg kernel mode:

```
!wfp layers
!wfp callouts
```

Permite inspeccionar los punteros a `classifyFn` en la memoria del kernel para identificar qué driver (`.sys`) maneja cada capa de red.

## Fuentes

- Microsoft Learn: About File System Filter Drivers, Filter Manager concepts, Writing Preoperation Callback Routines, Writing Postoperation Callback Routines.
- Microsoft Learn, altitudes y herramientas: Load Order Groups and Altitudes for Minifilter Drivers, Allocated filter altitudes, Tools for Minifilter Development and Testing (Fltmc, !fltkd).

> **Etiquetas**
>
> **Núcleo conceptual:** monitoreo de procesos como contexto. **Conocimiento externo:** Filter Manager/minifilters, altitudes, valores de retorno e IRQL de callbacks. **Ejemplo ilustrativo:** flujo de archivo y ficha de inventario ficticia. **Laboratorio verificado:** no.

**Ampliación editorial basada en fuentes externas — Estructuras FLT_REGISTRATION y callbacks de monitoreo en Kernel**

Al auditar en IDA o Ghidra drivers defensivos, EDRs o módulos de filtrado de archivos sin símbolos, el reverser necesita identificar de inmediato qué operaciones y eventos del sistema están siendo interceptados (Microsoft Learn: *FLT_REGISTRATION* y *ObRegisterCallbacks*) *(Hecho confirmado)*:

**1. Minifiltros de Filesystem ( `FltRegisterFilter` ):** El segundo argumento ( `RDX` en x64) apunta a la estructura estática `FLT_REGISTRATION` en `.rdata` / `.data`. Su campo **`OperationRegistration`** (offset **`+0x20`** en x64) apunta a un arreglo de estructuras `FLT_OPERATION_REGISTRATION` de 32 bytes cada una:

| Offset (x64) | Campo | Tipo y Significado |
|---|---|---|
| **`+0x00`** | `MajorFunction` | `UCHAR` (ej. `0x00` = `IRP_MJ_CREATE`, `0x04` = `IRP_MJ_WRITE`; termina con `0x80` = `IRP_MJ_OPERATION_END`). |
| **`+0x04`** | `Flags` | `ULONG` (banderas de operación, ej. `FLTFL_OPERATION_REGISTRATION_SKIP_CACHED_IO`). |
| **`+0x08`** | `PreOperation` | `PFLT_PRE_OPERATION_CALLBACK` (puntero a la rutina previa a la E/S). |
| **`+0x10`** | `PostOperation` | `PFLT_POST_OPERATION_CALLBACK` (puntero a la rutina posterior a la E/S). |
| **`+0x18`** | `Reserved1` | `PVOID` (reservado para el sistema, completa los 32 bytes de la estructura). |

**2. Callbacks de Kernel no relacionados con Filesystem (Telemetría y Protección):**

| API de Registro | Estructura / Parámetro Clave | Propósito Defensivo / Intercepción |
|---|---|---|
| **`PsSetCreateProcessNotifyRoutineEx`** | `NotifyRoutine` (1.er arg, `RCX`) | Notifica creación y terminación de procesos en el sistema; permite denegar la creación retornando error en `CreateInfo->CreationStatus`. |
| **`PsSetLoadImageNotifyRoutine`** | `NotifyRoutine` (1.er arg, `RCX`) | Intercepta cada mapeo de ejecutables ( `.exe` ), bibliotecas ( `.dll` ) o módulos de kernel ( `.sys` ) en el espacio de memoria virtual. |
| **`ObRegisterCallbacks`** | `OB_CALLBACK_REGISTRATION` → arreglo `OB_OPERATION_REGISTRATION` ( `+0x20` ) | Intercepta apertura y duplicación de handles sobre `PsProcessType` y `PsThreadType`, despojando máscaras de acceso críticas como `PROCESS_VM_WRITE` o `PROCESS_TERMINATE` para blindar procesos. |

# Mitigaciones de Windows para drivers

> **Solo observación**
>
> La práctica consulta el estado vigente. No deshabilites Secure Boot, HVCI, WDAC, firma de drivers ni driver blocklist para que una muestra cargue. No apliques políticas ni actives modos de prueba en el equipo principal.

> **Propósito**
>
> Relacionar controles de integridad y política con el riesgo de drivers vulnerables, y evitar confundir "activo" con "cobertura total". Al terminar deberías poder leer el estado real de cada control en una VM, distinguir "configurado" de "en ejecución" y escribir qué protege y qué no.

**Prerrequisitos**

- *Obligatorios:* 6.1 arquitectura, 6.4 revisión.
- *Recomendados:* 2D.1 tokens, Etapa 0 snapshots y nociones de Secure Boot.

## Qué protege cada control

- **Firma de driver**: ayuda a establecer origen/integridad aceptable bajo política de carga; no demuestra ausencia de bugs.
- **Secure Boot**: protege la cadena de arranque con verificación de componentes firmados; política y soporte dependen del hardware/firmware.
- **VBS/HVCI (Memory Integrity)**: usa virtualización para aislar decisiones de integridad de código del kernel y restringir código ejecutable en kernel.
- **WDAC/App Control**: permite definir qué software/drivers pueden ejecutarse según política.
- **Vulnerable driver blocklist**: bloquea un conjunto de drivers conocidos vulnerables; versión, habilitación y excepciones dependen de la versión/política.

Se complementan y pueden afectar compatibilidad. La configuración cambia entre Windows cliente/servidor y administración organizacional; registra build y fuente consultada.

## Firma de drivers: qué exige hoy la política

Desde Windows 10 versión 1607, con Secure Boot activo, Windows no carga drivers de kernel **nuevos** que no estén firmados a través del portal de hardware de Microsoft. La documentación lista excepciones para drivers con firma cruzada (equipos actualizados desde versiones anteriores, Secure Boot desactivado y certificados emitidos antes de una fecha de corte). Para probar en clientes existe la firma por **atestación**, y para laboratorio, la firma de **prueba**, que requiere un modo de arranque específico.

Consecuencias para el análisis: "está firmado" dice **quién** y **bajo qué programa** se firmó; no dice que el código sea correcto ni benigno. Un driver vulnerable legítimamente firmado sigue siendo vulnerable: para

eso existe la blocklist. Y un sistema en modo de firma de prueba tiene una política de carga distinta, que hay que anotar si la VM lo usa.

## Integridad de memoria (HVCI) y VBS

La integridad de memoria, también llamada HVCI, ejecuta la integridad de código del kernel dentro del entorno aislado de VBS (con el hipervisor de Windows) y restringe asignaciones de memoria del kernel que podrían usarse para comprometerlo; también protege, entre otras cosas, el mapa de bits de CFG de los drivers. Microsoft advierte que hay drivers incompatibles y que activarla puede causar fallos de arranque, por eso en esta lección **solo se consulta**.

Cómo leer el estado, sin cambiarlo:

- `Get-CimInstance -ClassName Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard` (PowerShell elevado).
- `msinfo32`: las características de VBS aparecen al final del Resumen del sistema.

Campos de `Win32_DeviceGuard` que importan:

| Campo | Qué dice | Valores clave |
|---|---|---|
| `VirtualizationBasedSecurityStatus` | Si VBS está habilitada y corriendo | 0 no habilitada · 1 habilitada pero **no** corriendo · 2 habilitada y corriendo |
| `SecurityServicesConfigured` | Qué servicios están **configurados** | contiene 2 si la integridad de memoria está configurada |
| `SecurityServicesRunning` | Qué servicios están **corriendo** | contiene 2 si la integridad de memoria está corriendo |
| `CodeIntegrityPolicyEnforcementStatus` | Aplicación de la política de integridad de código | 0 apagada · 1 auditoría · 2 aplicada |
| `AvailableSecurityProperties` | Capacidades de hardware disponibles | hipervisor, Secure Boot, protección DMA, MBEC/GMET… |

La distinción entre **configurado** y **corriendo** es la que más errores evita: una política puede pedir HVCI y el sistema no poder ejecutarlo (por hardware, por un driver incompatible o, como documenta Microsoft para ciertas VM de Azure, por la opción de Secure Boot elegida).

## Vulnerable driver blocklist

Según la documentación vigente, desde la actualización 2022 de Windows 11 la blocklist está habilitada por defecto y puede activarse o desactivarse desde Seguridad de Windows; también se aplica cuando están activos la integridad de memoria, Smart App Control o el modo S (salvo en Windows Server 2016). Se actualiza trimestralmente y llega además con las actualizaciones mensuales.

Límites que Microsoft declara: la lista **no garantiza** bloquear todo driver vulnerable, y la versión incluida en el sistema suele ser **menos completa** que la descargable, porque algunas entradas se retienen para no romper compatibilidad. Si se aplica la versión descargable como política de App Control, el registro

*CodeIntegrity/Operational* registra el evento 3099 con el nombre e identificador de la política: es una forma de **verificar** qué política está cargada sin cambiar nada.

## Secure Boot y App Control

**Secure Boot** verifica que los componentes de arranque estén firmados por autoridades confiables del firmware; su estado aparece en `msinfo32` ("Estado de arranque seguro"). Es requisito de varias de las otras protecciones y condición de la política de firma descrita arriba.

**App Control for Business** (antes WDAC) define qué código puede ejecutarse, incluidos drivers, y puede estar en modo **auditoría** (registra lo que bloquearía) o **aplicado**. Para el análisis, una política en auditoría no protege: solo deja evidencia.

## Ejemplo trabajado

*(Matriz ficticia para discusión, no estado de una máquina.)*

| Señal | Control relacionado | Qué no concluye |
|---|---|---|
| HVCI activo | integridad de código en kernel | que todo driver sea libre de fallos |
| paquete firmado | política de firma | que el código sea benigno |
| driver en blocklist | bloqueo por política | que todos los vulnerables estén listados |

Lectura de una VM de laboratorio (ilustrativa):

| Control | Estado leído | Fuente | Lectura prudente |
|---|---|---|---|
| Secure Boot | Activado | `msinfo32` | La política de firma estricta aplica a drivers nuevos |
| VBS | `VirtualizationBasedSecurityStatus = 2` | `Win32_DeviceGuard` | VBS habilitada y corriendo |
| Integridad de memoria | Configurada: sí (2); corriendo: sí (2) | `Win32_DeviceGuard` | HVCI efectiva en este arranque |
| Blocklist | Activada en Seguridad de Windows | Interfaz | Aplica la versión incluida en el sistema, no necesariamente la más reciente |
| App Control | Sin política propia; solo la del sistema | Registro *CodeIntegrity* | No hay lista de permitidos de la organización |

> **Por qué los drivers x64 no parchean el kernel: PatchGuard (KPP) y el bugcheck 0x109**
>
> En Windows x64, **Kernel Patch Protection (PatchGuard / KPP)** verifica periódicamente la integridad de las estructuras críticas del kernel: el código y las secciones de solo lectura de `ntoskrnl.exe` / `hal.dll`, la **SSDT** ( `KeServiceDescriptorTable` ), la **IDT/GDT**, MSRs críticos ( `IA32_LSTAR` → `KiSystemCall64` ) y estructuras internas. Si cualquier driver modifica un byte de esas regiones, PatchGuard detiene el sistema de forma diferida con el bugcheck **`0x109`** **(CRITICAL_STRUCTURE_CORRUPTION)**. Esa es la razón arquitectónica por la que, en x64, los productos de seguridad y los drivers legítimos **abandonaron el SSDT/inline hooking** de la era de 32 bits y usan solo las interfaces de notificación documentadas de 6.5 ( `FltRegisterFilter` , `ObRegisterCallbacks` , `PsSetCreateProcessNotifyRoutineEx` ).

## Práctica de solo lectura

En la VM, consulta Windows Security / System Information y la política administrada disponible. Registra build/edición, estado informado de Secure Boot/VBS/HVCI y fuente de la blocklist. Si la política está oculta por organización, anota “no disponible”; no cambies ajustes ni instales drivers para probarla.

1. Ejecutá la consulta de `Win32_DeviceGuard` y anotá los campos de la tabla, distinguiendo configurado de corriendo.
2. Anotá el estado de Secure Boot desde `msinfo32` y si la VM usa algún modo de firma de prueba.
3. Revisá en el Visor de eventos el registro *CodeIntegrity/Operational* solo para leer qué políticas están cargadas.

## Entregable

Matriz control–estado–fuente–alcance–límite, con la distinción configurado/corriendo para VBS y HVCI. Incluí fecha/build y no publiques identificadores del equipo.

## Repaso

<details>
<summary>¿Firma significa que el driver es seguro?</summary>

No. Indica una propiedad de identidad/integridad bajo una política de confianza, no corrección ni ausencia de comportamiento malicioso.
</details>

<details>
<summary>¿La blocklist cubre cualquier driver vulnerable?</summary>

No. Es una lista mantenida con criterios y actualizaciones; hay límites de versión y compatibilidad.
</details>

<details>
<summary><code>SecurityServicesConfigured</code> contiene 2 pero <code>SecurityServicesRunning</code> no. ¿Qué significa?</summary>

Que la integridad de memoria está pedida por configuración pero no está corriendo en este arranque; no protege.
</details>

▼ **¿Qué exige la política de firma desde Windows 10 1607 con Secure Boot activo?**

> Que los drivers de kernel nuevos estén firmados a través del portal de Microsoft, con las excepciones documentadas.

▼ **¿Protege una política de App Control en modo auditoría?**

> No bloquea: solo registra lo que bloquearía.

▼ **¿Qué hacer si una prueba requiere desactivar controles?**

> No hacerlo en el equipo principal; si el entorno de laboratorio no está aprobado y documentado, abandonar la carga y continuar con análisis estático.

**Puerta optativa**

Podés explicar qué aporta firma, Secure Boot, HVCI/VBS, App Control y blocklist, leer su estado sin modificarlos, distinguir configurado de corriendo y declarar estado/fuente/límites.

**Continuidad y Profundización**

La arquitectura interna de VBS, el Secure Kernel en VTL1, HVCI por hardware y la auditoría en memoria viva de los vectores de notificación y telemetría de kernel (PspCreateProcessNotifyRoutine, ObRegisterCallbacks y ETWti) se desarrollan operativamente en la lección siguiente: 6.7 Seguridad profunda en kernel x64.

## Fuentes


- Microsoft Learn: Driver security checklist, HVCI compatible code, Microsoft recommended driver block rules, Windows Defender Application Control.
- Microsoft Learn, estado y firma: Enable memory integrity (incluye Win32_DeviceGuard), Driver Signing Policy, The TESTSIGNING boot configuration option, Secure Boot.


**Etiquetas**

**Núcleo conceptual:** mitigaciones de user mode como contexto. **Conocimiento externo:** política de firma, VBS/HVCI y lectura de su estado, blocklist, Secure Boot y App Control. **Ejemplo ilustrativo:** matrices ficticias. **Laboratorio verificado:** no; consulta en solo lectura.

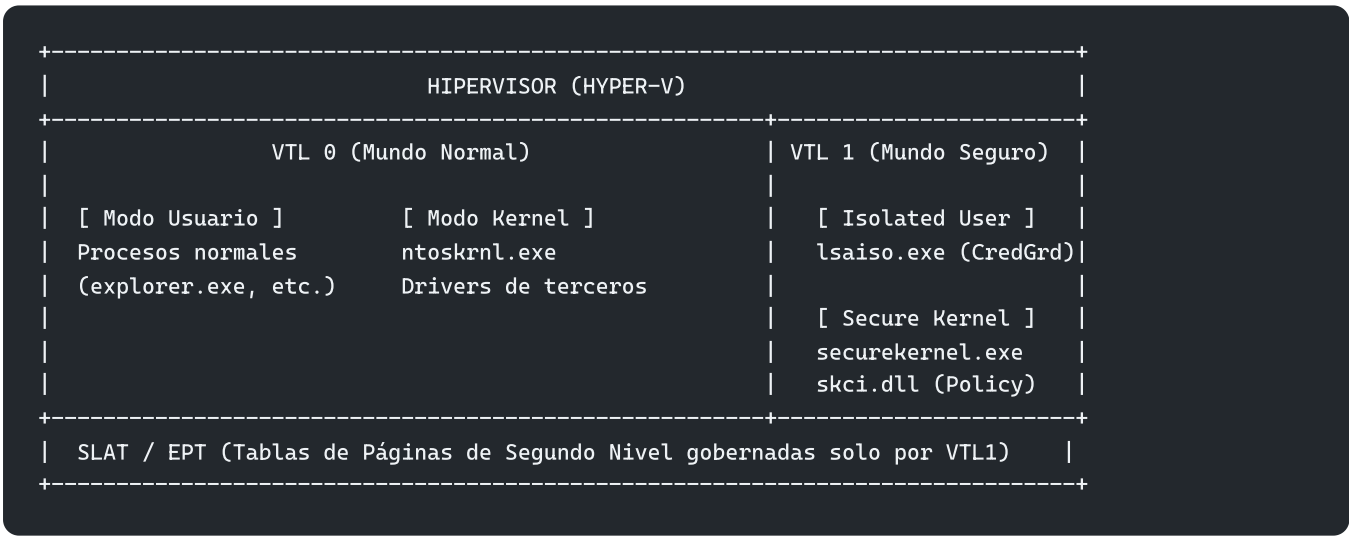
# Seguridad Profunda en Kernel x64: VBS/HVCI (VTL1), Callbacks y Mecánicas BYOVD

> **Propósito**
>
> Esta lección profundiza la arquitectura de seguridad del Kernel en Windows 11 contemporáneo, eliminando la frontera de lo que antes se consideraba "fuera de alcance". Aquí se estudian los mecanismos internos que rigen la protección por hipervisor (**VBS / HVCI**), el aislamiento de **Credential Guard con trustlets IUM**, el flujo exacto de validación de imágenes ( `NtCreateSection` $\to$ `VtlCall` ), las estructuras en memoria que sustentan los vectores de notificación y telemetría de kernel (**PspCreateProcessNotifyRoutine**, **ObRegisterCallbacks**, **ETWti**, **CmCallbackListHead**, **InstrumentationCallback**), el vector **BYOVD** con inspección de **PiDDBCacheTable**, y el análisis forense de fallos por **Double Fetch** en controladores **KMDF**.

---

## 1. Arquitectura Interna de VBS y Secure Kernel (VTL0 vs. VTL1)

Desde Windows 10 versión 1709 y por defecto en Windows 11, el modelo de seguridad del sistema operativo se basa en **Virtualization-Based Security (VBS)**. El hipervisor de Windows (Hyper-V) divide el hardware en dos mundos o **Virtual Trust Levels (VTL)**:




### Transiciones de Privilegio: `VtlCall` / `VtCall` y `VtlReturn`

- `VTL 0` **:** Contiene el kernel clásico ( `ntoskrnl.exe` ), drivers de terceros y aplicaciones de usuario.
- `VTL 1` **:** Contiene el **Secure Kernel** ( `securekernel.exe` ) y bibliotecas de integridad aisladas como `skci.dll` .
- Las comunicaciones entre mundos no ocurren mediante interrupciones de software clásicas, sino a través de la instrucción de hipervisor `vmcall` (en Intel) o `vmmcall` (en AMD), encapsulada en la rutina `VtlCall` (también referenciada como `VtCall` ). Cuando VTL 1 concluye la operación, devuelve el control a VTL 0 mediante `VtlReturn` .

### Integridad de Código por Hipervisor (HVCI) y $W \oplus X$

Bajo **HVCI (Hypervisor-Protected Code Integrity)**, las decisiones sobre qué páginas de memoria pueden ejecutarse en modo kernel se delegan a VTL 1. El hipervisor configura las tablas de páginas de segundo nivel (**SLAT / EPT**) de modo que ninguna página en VTL 0 pueda ser simultáneamente escribible y ejecutable ($W \oplus X$). Si un driver intenta asignar memoria en el pool ejecutable ( `NonPagedPoolExecute` ) o desproteger el bit de escritura de una página de código en `CR0`, el hipervisor intercepta el fallo de página anidado (*EPT Violation*) e interrumpe inmediatamente la ejecución antes de que el código no firmado pueda ejecutarse.

### Credential Guard, LSAISO y Trustlets en Modo de Usuario Aislado (IUM)

En sistemas convencionales sin VBS, el proceso `lsass.exe` almacenaba hashes NTLM, credenciales en claro y tickets Kerberos directamente en su propio espacio de direcciones en modo usuario (VTL 0), haciéndolos vulnerables a lecturas de memoria con herramientas como Mimikatz si el atacante obtenía privilegios de `SeDebugPrivilege` o ejecutaba un driver en modo kernel.

Bajo **Credential Guard**:

1. El kernel crea un proceso especial en **Modo de Usuario Aislado (IUM - Isolated User Mode)** que reside dentro de **VTL 1**: `lsaiso.exe` (*LSA Isolated*).
2. El proceso `lsass.exe` en VTL 0 pasa a funcionar como un mero intermediario de RPC/ALPC: no contiene claves criptográficas ni hashes en claro.
3. Cada vez que se requiere autenticar un usuario o firmar un ticket Kerberos, `lsass.exe` envía una solicitud a través de llamadas ALPC canalizadas mediante una transición `VtlCall` / `VtCall` hacia `lsaiso.exe` en VTL 1.
4. El Secure Kernel en VTL 1 procesa la operación criptográfica usando claves protegidas por hardware (TPM) y devuelve únicamente el resultado de la autenticación a VTL 0.
5. Las tablas de páginas de VTL 1 no están mapeadas en el espacio de direcciones de VTL 0: ni siquiera un driver en modo kernel ejecutándose con máximos privilegios en VTL 0 puede leer la memoria de `lsaiso.exe`.

### Flujo de Validación de Imágenes: `NtCreateSection` $\to$ `VtlCall` / `VtCall` $\to$ `skci.dll`

Cuando se carga un binario ejecutable o controlador en el sistema:

1. El llamador invoca `NtCreateSection` con la bandera `SEC_IMAGE`.
2. El gestor de memoria ( `nt!MiCreateSection` ) analiza las cabeceras PE y transfiere la validación de firma a la biblioteca de integridad de código del kernel ( `ci.dll!CiValidateImageHeader` ).
3. Si la política de HVCI está activa, `ci.dll` no toma la decisión de ejecución de manera local en VTL 0: emite una transición de hipervisor **`VtlCall`** hacia **`skci.dll`** (*Secure Kernel Code Integrity*) en VTL 1.
4. `skci.dll` valida los certificados digitales, la cadena de confianza y las reglas WDAC (*Windows Defender Application Control*), computando los hashes criptográficos de cada página física.
5. Si la validación es exitosa, el Secure Kernel programa las tablas de páginas SLAT/EPT del hipervisor marcando las páginas físicas correspondientes como ejecutables de solo lectura ($R \oplus X$). Si la

validación fracasa, VTL 1 retorna un estado de error (`STATUS_IMAGE_CERT_REVOKED` o `STATUS_INVALID_IMAGE_HASH`) y `NtCreateSection` es abortada inmediatamente.

### Código C: Gatillo de Mapeo con Validación Criptográfica en Kernel

```
// Invocación nativa para mapear una imagen PE sujeta a verificación de HVCI
HANDLE hFile = NULL, hSection = NULL;
OBJECT_ATTRIBUTES objAttr;
IO_STATUS_BLOCK ioStatus;
UNICODE_STRING uPath;

RtlInitUnicodeString(&uPath, L"\\??\\C:\\drivers\\vulnerable_or_untrusted.sys");
InitializeObjectAttributes(&objAttr, &uPath, OBJ_CASE_INSENSITIVE, NULL, NULL);

NtOpenFile(&hFile, FILE_EXECUTE | SYNCHRONIZE, &objAttr, &ioStatus,
           FILE_SHARE_READ, FILE_NON_DIRECTORY_FILE | FILE_SYNCHRONOUS_IO_NONALERT);

// Al invocar NtCreateSection con SEC_IMAGE (0x01000000), ntoskrnl transfiere el control a CI /
VTL1
NTSTATUS status = NtCreateSection(
    &hSection,
    SECTION_ALL_ACCESS,
    NULL,
    NULL,
    PAGE_EXECUTE,
    SEC_IMAGE,   // 0x01000000: Gatillo de verificación de firma y validación SLAT/EPT
    hFile
);
// Si HVCI rechaza la firma en VTL1, status retornará STATUS_INVALID_IMAGE_HASH (0xC0000428)
```

### Receta WinDbg para Rastrear el Pipeline `NtCreateSection` $\to$ `VtlCall`

```
$$ 1. Breakpoint en la entrada de creación de sección y análisis PE
bp nt!NtCreateSection "r @rcx; gc"
bp nt!MiCreateSection

$$ 2. Breakpoint en la biblioteca de integridad de código (VTL 0)
bp ci!CiValidateImageHeader "du poi(@rcx+0x30); gc"
bp ci!CiValidateImagePages

$$ 3. Breakpoint en la llamada de transición de hipervisor (VtlCall / VtCall hacia Secure Kernel)
$$ (Nota técnica: En ci.dll, la rutina nativa exportada que ensambla la transición VtlCall/VtCall
hacia VTL1 se denomina ci!IvtCallHypervisor, citada también como ci!VtCallHypervisor)
bp ci!IvtCallHypervisor
$$ Al alcanzar ci!IvtCallHypervisor, examinar los argumentos de la llamada:
$$ RCX = Código de comando VTL1 (ej. 0x17 = SECURE_IMAGE_VALIDATE_PAGES)
$$ RDX = Puntero al bloque de contexto con las PFNs físicas a verificar
r rcx, rdx

$$ 4. Breakpoint en el Secure Kernel (VTL 1) (si el depurador está conectado a VTL1)
bp skci!SkciValidateImagePages
```

### kCFG (Kernel Control Flow Guard) Respaldado por VTL 1

En modo kernel, **kCFG** verifica cada llamada indirecta (`call rax`) comprobando si la dirección de destino está registrada en el bitmap de funciones válidas del kernel (`nt!guard_dispatch_icall`). Bajo VBS, el mapa de bits de CFG se almacena en memoria de solo lectura para VTL 0 y solo puede ser actualizado por el Secure Kernel en VTL 1.

---

## 2. Auditoría en Memoria de los Vectores de Telemetría y Notificación de Kernel

El reverser o analista defensivo debe dominar la inspección en **WinDbg** de los arreglos no exportados de notificación, registro y telemetría en memoria viva.

### A. Notificaciones de Creación de Procesos (`PspCreateProcessNotifyRoutine`)

Windows mantiene una tabla interna de 64 punteros de tipo `EX_FAST_REF` que registran los callbacks suscritos con `PsSetCreateProcessNotifyRoutineEx`:

- En x64, los 4 bits inferiores de cada entrada corresponden al conteo de referencias concurrentes.
- Para obtener la dirección del bloque de datos se aplica una máscara de bits: `Puntero & ~0x0F`.
- En el bloque resultante (`_EX_CALLBACK_ROUTINE_BLOCK`), el offset `+0x08` contiene el puntero a la función del driver.

```
$$ Script WinDbg para auditar todos los slots de PspCreateProcessNotifyRoutine
r $t0 = nt!PspCreateProcessNotifyRoutine
.for (r $t1 = 0; @$t1 < 0x40; r $t1 = @$t1 + 1) {
    r $t2 = poi(@$t0 + @$t1 * 8) & 0xfffffffffffffff0
    .if (@$t2 != 0) {
        r $t3 = poi(@$t2 + 8)
        .printf "[Slot %02d] Callback en %p : ", @$t1, @$t3; ln @$t3
    }
}
```

### B. Callbacks de Objetos de Proceso (`ObRegisterCallbacks`)

Los drivers de seguridad registran rutinas `PreOperation` y `PostOperation` sobre objetos `PsProcessType` para despojar permisos peligrosos (como `PROCESS_VM_WRITE` o `PROCESS_VM_OPERATION`):

- En Windows 10 y 11 x64, la cabeza de lista `CallbackListHead` se ubica en el offset `+0xC8` de la estructura `_OBJECT_TYPE` apuntada por `*PsProcessType`.
- Cada elemento de la lista apunta a una estructura `OB_CALLBACK_CONTEXT_BLOCK` donde `+0x28` es el puntero `PreOperation` y `+0x30` es `PostOperation`.

### C. Callbacks de Registro: `nt!CmCallbackListHead` y `CmRegisterCallbackEx`

Los drivers de auditoría e integridad registran filtros de transacciones sobre el Registro mediante `CmRegisterCallbackEx`:

- Los callbacks activos se encadenan en la lista doblemente enlazada no exportada `nt!CmCallbackListHead`.
- Cada nodo corresponde a una estructura `_CM_CALLBACK_CONTEXT_BLOCK` donde el offset `+0x28` almacena el puntero `Function` (la rutina del driver) y `+0x30` contiene el puntero `Context`.

```
$$ Recorrer en WinDbg todos los callbacks de registro registrados
!list -t nt!_CM_CALLBACK_CONTEXT_BLOCK.List -x "dps @$extret+0x28 L1" nt!CmCallbackListHead
```

### D. Sensor en Proceso: `KPROCESS->InstrumentationCallback`

Para evitar el monitoreo invasivo mediante inline hooking en modo usuario, Windows expone un mecanismo nativo de instrumentación en el despachador de syscalls:

- En la estructura `_KPROCESS` (`nt!_KPROCESS`), el campo `InstrumentationCallback` (offset `+0x3D8` en Windows 10 x64, `+0x3E8` en Windows 11 x64) almacena un puntero a una función en espacio de usuario.
- Se configura desde user mode mediante `NtSetInformationProcess` pasando la clase no documentada `ProcessInstrumentationCallback` (`0x28`).
- **Mecánica de intercepción:** Cuando este puntero está activo, cada vez que una llamada al sistema (`syscall`) o interrupción retorna desde el kernel al modo usuario, la CPU no regresa inmediatamente a la instrucción siguiente (`RIP`), sino que desvía la ejecución a la dirección configurada en `InstrumentationCallback`. Sensores defensivos y EDRs lo utilizan para inspeccionar el estado de los registros y el stack post-syscall.

### Implementación en C: Registro de `InstrumentationCallback`

```
#include <windows.h>
#include <stdio.h>

#define ProcessInstrumentationCallback 0x28

typedef struct _PROCESS_INSTRUMENTATION_CALLBACK_INFORMATION {
    ULONG Version;      // 0 en x64
    ULONG Reserved;     // 0
    PVOID Callback;     // Puntero a la rutina en espacio de usuario
} PROCESS_INSTRUMENTATION_CALLBACK_INFORMATION;

typedef NTSTATUS (NTAPI *pfnNtSetInformationProcess)(
    HANDLE ProcessHandle,
    ULONG ProcessInformationClass,
    PVOID ProcessInformation,
    ULONG ProcessInformationLength
);

// Stub en ensamblador que recibe el control tras cada syscall
extern void InstrumentationCallbackEntry(void);

void InstalarInstrumentationCallback(void) {
    pfnNtSetInformationProcess NtSetInformationProcess =
        (pfnNtSetInformationProcess)GetProcAddress(GetModuleHandleA("ntdll.dll"),
"NtSetInformationProcess");
    if (!NtSetInformationProcess) return;

    PROCESS_INSTRUMENTATION_CALLBACK_INFORMATION info;
    info.Version = 0;
    info.Reserved = 0;
    info.Callback = (PVOID)(ULONG_PTR)InstrumentationCallbackEntry;

    NTSTATUS status = NtSetInformationProcess(
        GetCurrentProcess(),
        ProcessInstrumentationCallback,
        &info,
        sizeof(info)
    );
    if (status == 0) {
        printf("[+] InstrumentationCallback registrado correctamente.\n");
    }
}
```

### Stub en Ensamblador x64 (`instrumentation_entry.asm`)

Al regresar de la syscall, el kernel coloca la dirección de retorno original (`RIP` en modo usuario) en el registro **`R10`**, y las banderas en **`R11`**:

```
.code
PUBLIC InstrumentationCallbackEntry
EXTRN AuditarRetornoSyscall:PROC

InstrumentationCallbackEntry PROC
    ; Preservar el contexto volátil completo del hilo
    pushfq
    push    rax
    push    rcx
    push    rdx
    push    r8
    push    r9
    push    r10
    push    r11

    ; Invocar función C pasando R10 (RIP original de retorno) como 1er argumento (RCX)
    sub     rsp, 20h
    mov     rcx, r10
    call    AuditarRetornoSyscall
    add     rsp, 20h

    ; Restaurar contexto
    pop     r11
    pop     r10
    pop     r9
    pop     r8
    pop     rdx
    pop     rcx
    pop     rax
    popfq

    ; Saltar a la dirección de retorno original que el kernel dejó en R10
    jmp     r10
InstrumentationCallbackEntry ENDP
END
```

### Script WinDbg: Auditoría de `InstrumentationCallback` en Todos los Procesos

Un analista forense o investigador de evasión puede inspeccionar qué procesos del sistema tienen activo un sensor `InstrumentationCallback`:

```
$$ Script WinDbg: Recorrer todos los procesos y detectar callbacks activos
!for_each_process "r @$t0 = @#Process; .if (poi(@$t0+@@(#FIELD_OFFSET(nt!_KPROCESS,
InstrumentationCallback))) != 0) { .printf \"PID %p (%s) -> InstrumentationCallback: %p\n\",
poi(@$t0+@@(#FIELD_OFFSET(nt!_EPROCESS, UniqueProcessId))),
poi(@$t0+@@(#FIELD_OFFSET(nt!_EPROCESS, ImageFileName))), poi(@$t0+@@(#FIELD_OFFSET(nt!_KPROCESS,
InstrumentationCallback))) }"
```

### E. Proveedor de Telemetría de Kernel `ETWti` (*Microsoft-Windows-Threat-Intelligence*)

El subsistema ETWti alimenta a los EDRs con telemetría de bajo nivel:

- Su handle de registro global reside en `nt!EtwThreatIntProvRegHandle`.

- Apunta a una estructura `_ETW_REG_ENTRY`. En el offset `+0x10` reside el puntero a `_ETW_GUID_ENTRY`.
- Dentro de `_ETW_GUID_ENTRY`, el campo `ProviderEnableInfo` define si el proveedor está activo (`EnableMask != 0`) y a qué nivel de detalle registra eventos de kernel.

---

## 3. Mecánicas BYOVD (Bring Your Own Vulnerable Driver) y Detección Defensiva

El vector **BYOVD** (*Bring Your Own Vulnerable Driver*) es la técnica predilecta para eludir DSE (*Driver Signature Enforcement*) sin necesidad de vulnerar `ntoskrnl.exe`.

### Mecánica de Abuso de Drivers Legítimos Firmados

1. El atacante selecciona un driver legítimo antiguo firmado con un certificado comercial válido (utilidades de placa madre, herramientas de overclocking o versiones antiguas de antivirus).
2. El driver se carga en el sistema mediante la API legítima `NtLoadDriver` o a través del Service Control Manager (`CreateServiceW` / `StartServiceW`). Dado que la firma digital es válida y no ha sido explícitamente bloqueada por la lista de revocación de Windows (WDAC Blocklist), DSE permite su carga.
3. El proceso atacante abre un handle hacia el objeto dispositivo del driver y despacha códigos IOCTL vulnerables que exponen primitivas de lectura/escritura arbitraria de memoria física (`MmMapIoSpace`), manipulación de registros de control (desactivación del bit SMEP en `CR4`) o copia no validada de memoria (`RtlCopyMemory`).
4. Con estas primitivas, el atacante modifica en memoria viva las estructuras del kernel (desactiva callbacks de EDR en `PspCreateProcessNotifyRoutine`, neutraliza `ETWti` o altera el token de seguridad en `_EPROCESS`).

### Detección Defensiva: La Tabla de Caché `nt!PiDDBCacheTable`

Para llevar un registro forense de todos los controladores cargados, el kernel NT mantiene una tabla hash en memoria protegida por el recurso `nt!PiDDBLock`: **`nt!PiDDBCacheTable`**.

### Estructura Interna de `_RTL_AVL_TABLE` (x64):

```
dt nt!_RTL_AVL_TABLE
   +0x00 BalancedRoot          : _RTL_BALANCED_LINKS (Árbol balanceado AVL)
   +0x20 OrderedPointer        : Ptr64 Void
   +0x28 WhichOrderedElement   : Uint4
   +0x30 NumberGenericTableElements : Uint4 (Cantidad total de drivers cacheados)
   +0x38 DepthOfTree           : Uint4
   +0x40 RestartKey            : Ptr64 _RTL_BALANCED_LINKS
   +0x48 DeleteCount           : Uint4
   +0x50 CompareRoutine        : Ptr64
   +0x58 AllocateRoutine       : Ptr64
   +0x60 FreeRoutine           : Ptr64
   +0x68 TableContext          : Ptr64 Void
```

### Estructura de Entrada `_PiDDBCacheEntry`:

Cada entrada dentro del árbol AVL contiene los metadatos de un controlador:

- `+0x00` `List` (`_LIST_ENTRY`): Enlace doble en la lista de entradas.
- `+0x10` `DriverName` (`_UNICODE_STRING`): Nombre del archivo del driver (ej. `RTCore64.sys`, `gdrv.sys`).
- `+0x20` `TimeDateStamp` (`ULONG`): Marca de tiempo de compilación del encabezado PE del driver.
- `+0x24` `LoadStatus` (`NTSTATUS`): Estado de carga del controlador (`STATUS_SUCCESS = 0x00000000`).

### Técnicas de Evasión y Auditoría Forense:

- **Técnica de evasión:** Herramientas de carga clandestina intentan localizar la tabla `nt!PiDDBCacheTable`, adquirir `nt!PiDDBLock` mediante `ExAcquireResourceExclusiveLite` y desvincular el nodo del driver vulnerable llamando a `RtlDeleteElementGenericTableAvl` para no dejar rastro en la memoria del kernel.
- **Auditoría Forense en WinDbg:** Un analista de incidentes puede volcar la tabla para comprobar si un driver vulnerable fue cargado, incluso si el archivo ya fue eliminado del disco:

```
$$ Localizar la tabla de caché de drivers y su lock en WinDbg
x nt!PiDDBCacheTable
x nt!PiDDBLock

$$ Inspeccionar las entradas del árbol AVL
dt nt!_RTL_AVL_TABLE poi(nt!PiDDBCacheTable)
dt nt!_PiDDBCacheEntry poi(poi(nt!PiDDBCacheTable) + 0x20)
```

---

## 4. Condiciones de Carrera y Reversing de MDLs en Drivers KMDF

En drivers reales el análisis de seguridad debe verificar el manejo de **MDLs (Memory Descriptor Lists)** y la sincronización asíncrona.

### El Peligro del *Double Fetch* en `METHOD_IN_DIRECT` / `METHOD_OUT_DIRECT`

Cuando un driver utiliza E/S directa (`METHOD_IN_DIRECT` o `METHOD_OUT_DIRECT`):

1. El I/O Manager bloquea las páginas físicas del buffer de usuario en memoria mediante una estructura MDL (`Irp->MdlAddress`).
2. El driver mapea esas páginas en el espacio virtual del sistema llamando a `MmGetSystemAddressForMdlSafe(Mdl, NormalPagePriority)`.
3. **La trampa de seguridad:** La memoria virtual devuelta por `MmGetSystemAddressForMdlSafe` comparte exactamente los mismos marcos de página física (PFNs) que el buffer en modo usuario. Si el driver lee un parámetro de tamaño o un puntero interno desde ese buffer dos veces (por ejemplo, una vez para validar y otra para copiar), un hilo atacante en espacio de usuario puede modificar el valor concurrentemente en la memoria compartida entre ambas lecturas (**Double Fetch**), desbordando buffers internos del kernel.

### Reenvío Asíncrono a I/O Targets en KMDF

En drivers KMDF desensamblados sin símbolos, las llamadas indirectas a través de la tabla `WdfFunctions` que gestionan solicitudes asíncronas se identifican por sus índices fijos:

- `WdfRequestSend` **(Índice 285 / Offset** `+0x8E8`**):** Reenvía un paquete de E/S a un dispositivo inferior o destino de E/S.
- `WdfRequestSetCompletionRoutine` **(Índice 290 / Offset** `+0x910`**):** Registra la rutina de finalización que se ejecutará cuando el dispositivo inferior complete la operación. En el desensamblado x64:

```
; Registro de CompletionRoutine en KMDF (offset +0x910)
mov     rax, [rbx]                  ; RBX = Puntero a WdfFunctions
mov     r8, offset MiCompletionRoutine ; R8 = Puntero al callback
mov     rdx, r14                    ; RDX = WDFREQUEST
mov     rcx, [rbx + 0x910]          ; Índice 290 = WdfRequestSetCompletionRoutine
call    rcx                         ; Invocación indirecta
```

---

## 6.7.b — Detección de DKOM mediante Cross-View (VTL0 vs. VTL1 y PspCidTable)

Los atacantes avanzados y herramientas de evasión basadas en **BYOVD** (*Bring Your Own Vulnerable Driver*) intentan ocultar procesos maliciosos manipulando directamente las estructuras de datos del kernel (**DKOM - Direct Kernel Object Manipulation**). La técnica clásica consiste en desvincular el proceso de la lista doblemente enlazada `nt!_EPROCESS->ActiveProcessLinks`:

```
[Proceso Legítimo A] <---> [Proceso Oculto X] <---> [Proceso Legítimo B]
                                    |
             (Atacante reasigna Flink y Blink con BYOVD)
                                    ▼
[Proceso Legítimo A] <------------------------------> [Proceso Legítimo B]
```

Al desvincularse, el proceso `X` desaparece completamente de las herramientas de administración convencionales (`tasklist.exe`, `Process Explorer`, APIs `CreateToolhelp32Snapshot` y `EnumProcesses`), ya que todas ellas recorren la lista `ActiveProcessLinks` en VTL 0. Sin embargo, el hilo del proceso sigue ejecutándose porque el planificador de la CPU (*scheduler*) despacha hilos a través de `_ETHREAD` y de la tabla de identificadores globales.

### La Técnica Defensiva de Inspección Cruzada (*Cross-View Detection*)

La detección rigurosa de DKOM se basa en contrastar la vista estándar de VTL 0 contra fuentes inmutables o no enlazadas del sistema:

1. **Cruce contra** `nt!PspCidTable`**:**

En Windows, cada identificador de proceso (PID) y de hilo (TID) se registra obligatoriamente en una tabla de handles interna no exportada del kernel: `nt!PspCidTable` (de tipo `_HANDLE_TABLE`).

- `ActiveProcessLinks` es una lista meramente informativa para enumeración.
- `PspCidTable` es la estructura que el kernel consulta cada vez que despacha una llamada o valida un handle de proceso. Si un atacante desvincula un proceso de `PspCidTable`, el sistema operativo entra inmediatamente en Bugcheck por inconsistencia de scheduler.
- **Regla Cross-View:** Si un PID existe en `PspCidTable` pero no aparece al recorrer `ActiveProcessLinks`, **el proceso ha sido ocultado mediante DKOM**.

1. **Cruce VTL0 vs. VTL1 (Secure Kernel):**

Bajo Virtualization-Based Security (VBS), el **Secure Kernel** (`securekernel.exe`) en VTL 1 mantiene su propio inventario de páginas físicas y contextos de ejecución respaldado por las tablas SLAT/EPT del hipervisor. Ningún driver en VTL 0 (incluso con privilegios de kernel absolutos) puede alterar la memoria de VTL 1. Los sensores defensivos de última generación consultan al hipervisor para comparar los contextos de ejecución activos contra la lista visible en VTL 0.

1. **Telemetría de Kernel `ETWti`:**

El proveedor `Microsoft-Windows-Threat-Intelligence` emite eventos inmutables de creación de procesos (`PROCESS_CREATE`) generados en la ruta nativa `nt!PspInsertProcess`. Aunque el atacante desvincule el proceso a posteriori en memoria, la traza de auditoría de ETWti ya registró la creación con su PID legítimo.

### Script Conceptual de WinDbg para Detección Cross-View

El siguiente script en WinDbg compara los procesos enumerados por la lista circular contra los registros de la tabla de identificadores `PspCidTable`:

```
$$ ============================================================================
$$ Detección Cross-View de Procesos Ocultos por DKOM en WinDbg
$$ ============================================================================

$$ 1. Recorrer la lista clásica ActiveProcessLinks (Vista VTL 0)
!process 0 0

$$ 2. Inspeccionar la tabla global de PIDs (PspCidTable)
r $t0 = poi(nt!PspCidTable)
.printf "[+] PspCidTable ubicada en %p\n", @$t0

$$ 3. Volcar los objetos de proceso referenciados por sus handles en PspCidTable
!handle 0 3 0 Process

$$ 4. Algoritmo de detección heurística en WinDbg:
$$ Para cada handle válido en PspCidTable, desreferenciar el puntero EPROCESS:
$$ Si EPROCESS->ActiveProcessLinks.Flink == &EPROCESS->ActiveProcessLinks
$$ o si Flink->Blink != EPROCESS, se delata una desvinculación maliciosa (DKOM).
!for_each_process "r @$t1 = @#Process; .if (poi(@$t1 + @@(#FIELD_OFFSET(nt!_EPROCESS,
ActiveProcessLinks.Flink))) == (@$t1 + @@(#FIELD_OFFSET(nt!_EPROCESS, ActiveProcessLinks)))) {
.printf \"[ALERTA DKOM] Proceso oculto detectado: PID %p (%s) en %p\n\", poi(@$t1 +
@@(#FIELD_OFFSET(nt!_EPROCESS, UniqueProcessId))), poi(@$t1 + @@(#FIELD_OFFSET(nt!_EPROCESS,
ImageFileName))), @$t1 }"
```

## 5. Laboratorio Verificado

1. Inspeccioná la plantilla `plantillas_codigo/minifilter_obcallback_min.c`. Observá cómo interactúan las estructuras de `FLT_REGISTRATION` y `OB_CALLBACK_REGISTRATION`.
2. En una sesión de depuración con WinDbg KDNET en tu VM de kernel, ejecutá el script de auditoría completa:

```
$$><plantillas_codigo\auditar_callbacks.wdbg
```

1. Verificá que la lista de callbacks enumera los drivers de tu entorno y localiza el módulo exacto que atiende la creación de procesos en tu sistema.

# Etapa 2 · Rama optativa 2D — Windows internals

> **Rama optativa, fuera de la aprobación obligatoria**
>
> 2D es una **rama optativa asociada a la Etapa 2**, después de 2A–2C. Profundiza Windows internals, pero **no** forma parte del recorrido obligatorio ni es prerrequisito general: el recorrido base siguen siendo las Etapas 0–4 y la Etapa 5 agrupa otras ramas optativas. Aporta prerrequisitos selectivos para la Etapa 6 · Kernel y drivers, también optativa. Llegás acá desde el mapa de la Etapa 2 o desde las ramas optativas de la Etapa 5.

> **Marco defensivo y de laboratorio**
>
> Todo acá es para **entender, analizar, depurar y detectar**, sobre **programas propios o didácticos** en **VMs aisladas con snapshot**. Nada de rootkits, persistencia encubierta, evasión de protecciones, ocultamiento de tareas ni objetivos de terceros. Cada laboratorio que registre servicios, tareas, claves o consumidores WMI **termina con pasos de limpieza** y evidencia de que quedó limpio.

## Prerrequisitos

- **Obligatorios:** Etapa 1 (memoria, PE), Etapa 2A–2B (assembly, debugger, IDA, PE fino). C básico (1.5).
- **Recomendados:** Etapa 2C (WinDbg/heap, scripting) y la rama de malware estática (5.1).

## Las lecciones

13 lecciones redactadas. Estimación editorial **55–70 h**, todavía no medida con alumnos ni laboratorios verificados. El rango se amplió porque COM/DCOM, WMI y la integración requieren preparación y documentación además de lectura. En las revisiones del 28/10/2026 pasó de 45–60 h a 50–65 h (2D.6, 2D.8 y 2D.9 sumaron unas diez páginas y pasos de práctica) y luego a 55–70 h (2D.10–2D.13 sumaron unas once páginas y pasos de práctica: revisión de pipes y registro RPC, lectura de excepciones con `.exr` / `.ecxr`, inventario de sesiones ETW y fichas del integrador):

1. Objetos, handles, tokens, privilegios e integridad
2. Memoria y loader: PEB/TEB, VAD e image mapping
3. Registro de Windows: hives, permisos, WOW64 y análisis defensivo
4. Servicios: SCM, ciclo de vida, cuentas y auditoría
5. Task Scheduler: leer tareas y detectar cambios
6. COM: interfaces, IUnknown y vida de los objetos
7. COM: registro, activación y configuración
8. DCOM y RPC: activación remota y límites de confianza
9. WMI: proveedores, filtros y consumidores
10. IPC en Windows: named pipes, RPC y ALPC
11. Excepciones de Windows y debugging

12. ETW y telemetría defensiva
13. Integrador Windows internals

### Extensión optativa: Hyper-V y virtualización

Separada del núcleo de 2D y **no requisito** de 2D ni de la Etapa 6. La práctica es de lectura conceptual, sin modificar Hyper-V ni enseñar evasión anti-VM.

## Puerta de salida (optativa)

2D no tiene puerta obligatoria. Cada lección trae la suya. Si hacés el integrador (2D.13), el criterio es: analizar un programa propio, producir un **inventario con evidencia** y demostrar que **limpiaste** todos los cambios que hiciste en el sistema.

> **Estado y honestidad**
>
> Las lecciones de 2D son, en su mayoría, **conocimiento externo** (documentación de Microsoft Learn), con **ejemplos ilustrativos** cuando no hay un laboratorio compilado con datos reales en esta edición. Los ejercicios de registro, servicio y tareas indican sus límites y limpieza; el resto no se declara reproducible si no fue ejecutado. Donde algo se apoya en material del corpus CLS, se cita; donde no se pudo verificar, se declara. No se inventan versiones, hashes, salidas ni citas.

## Etapa 6 · Kernel y drivers (optativa)

La Etapa 6 no es requisito para completar el curso y no exige COM, tareas programadas ni completar toda 2D. Requiere C, assembly, memoria/sincronización, WinDbg y las lecciones 2D.1, 2D.2 y 2D.11. 2C es recomendado. Para ver prerrequisitos por lección, alcance y estimación, consultá el mapa de Etapa 6.

## Alcance de las prácticas

Las lecciones 2D.6–2D.13 son redacción editorial basada en documentación primaria; sus ejemplos son ilustrativos y sus laboratorios **no están verificados**. La Etapa 6 requiere VM descartable con snapshot. La carga de drivers es opcional: si la política de firma/arranque de la VM no permite probarlos con la configuración vigente, la alternativa segura es análisis estático. No se modifican protecciones del equipo principal.

# Objetos, handles, tokens, privilegios e integridad

**Rama optativa 2D**

Lección de la rama optativa 2D, fuera del recorrido obligatorio. Defensiva: entender el contexto de seguridad para **analizar**, no para escalar privilegios.

**Propósito**

Entender cómo Windows modela el acceso: todo es un **objeto** al que se llega por **handle**, y lo que un proceso puede hacer lo define su **token** (SIDs, privilegios, nivel de integridad) contra la **ACL** del objeto. Saber leer ese contexto en Process Explorer/WinDbg.

**Prerrequisitos**

- *Obligatorios:* procesos e hilos (1.3), debugger (2.6).
- *Recomendados:* anti-análisis/PEB (2.15), WinDbg (2.19).

## El modelo de objetos

En Windows casi todo recurso del kernel —procesos, hilos, archivos, claves de registro, eventos, secciones— es un **objeto** gestionado por el *Object Manager*. Un proceso no toca el objeto directamente: pide un **handle** (un índice en su tabla de handles privada) y opera a través de él. Cada handle guarda, además, los **permisos concedidos** (access mask) con los que se abrió. **Conocimiento externo** (Microsoft Learn).

Para el análisis, los handles abiertos de un proceso son una **radiografía de qué toca**: qué archivos, qué claves, qué objetos de sincronización (un **mutex** con nombre suele ser el "ya estoy corriendo" de un malware).

## El token de acceso

Cuando un proceso quiere hacer algo sobre un objeto, Windows compara el **token** del proceso con la **ACL** del objeto. El token contiene:

- **SID de usuario y grupos:** quién sos y a qué grupos pertenecés.
- **Privilegios:** capacidades con nombre ( `SeDebugPrivilege` , `SeBackupPrivilege` , `SeLoadDriverPrivilege` ...) que el token puede tener **habilitadas** o solo presentes.
- **Nivel de integridad (IL):** Low / Medium / High / System. Con la política obligatoria predeterminada de Windows, un proceso de IL bajo normalmente no puede escribir en objetos de IL mayor (no es una regla universal para toda operación; también intervienen las etiquetas y políticas del objeto). Es una de las barreras usadas por sandboxes.

## ACL: quién puede qué

Un objeto asegurable tiene un **descriptor de seguridad** con su **DACL** (lista de ACEs: a qué SID se permite/niega qué acceso) y su **SACL** (auditoría). El chequeo de acceso recorre la DACL con el token del que pide. Para el reversing defensivo: una DACL **demasiado permisiva** en un servicio, una clave o un objeto con nombre es una debilidad a **reportar** (no a explotar).

## Ejemplo trabajado

*(Ejemplo **ilustrativo**: vista típica de Process Explorer / `!token` en WinDbg; valores construidos.)*

```
bloc_lab.exe (PID 4312)   Integrity: Medium       ← editor de texto propio de laboratorio
  Token:
    User:  PC\lab  (S-1-5-21-...-1001)
    Grupos: BUILTIN\Users, ...
    Privilegios (habilitados en MAYÚSCULA):
       SeChangeNotifyPrivilege (ON)   SeShutdownPrivilege (off)
       SeDebugPrivilege (off)         ← presente pero deshabilitado
  Handles (extracto):
    0x0F8  File   C:\Users\lab\Documents\notas.txt              (el archivo que abriste)
    0x120  Key    HKCU\Software\BlocLab\Settings                (su propia config)
    0x134  Mutant \Sessions\1\BaseNamedObjects\BlocLab_SingleInstance
```

Lectura: proceso propio de integridad **Medium**, con `SeDebugPrivilege` **presente pero apagado** (no está usando debug de otros procesos ahora). Los handles muestran el documento que abriste, su **propia** clave de configuración y un **mutex** de instancia única. En un análisis real, el nombre del mutex o una ruta son **pistas** a corroborar, no evidencia por sí solos.

**Los offsets de `nt!_EPROCESS` cambian entre builds: nunca los fijes**

A diferencia de los primeros campos del PEB, la estructura `_EPROCESS` es opaca y el kernel **reorganiza sus campos entre versiones de Windows**. Un controlador que asuma offsets estáticos fijos fallará o provocará Bugchecks al actualizar el sistema operativo (por ejemplo, el desplazamiento de `Protection` a `+0x8FA` y de `MitigationFlags` a `+0xA58` en Windows 11 24H2 frente a `+0x87A` y `+0x9D8` en 23H2, o frente a compilaciones históricas de Windows 10 como 1507–1809 donde `UniqueProcessId` residía en `+0x2E0` y `Token` en `+0x358`). En x64 (consistente con la Hoja 6 de referencia rápida):

| Campo ( `nt!_EPROCESS` ) | Win10 1507–1809 | Win10 2004–22H2 (Build 19045) | Win11 21H2–23H2 (Build 22631) | Win11 24H2 (Build 26100) |
|---|---|---|---|---|
| `UniqueProcessId` | `+0x2E0` | `+0x440` | `+0x440` | `+0x440` |
| `ActiveProcessLinks` | `+0x2E8` | `+0x448` | `+0x448` | `+0x448` |
| `Token` ( `_EX_FAST_REF` ) | `+0x358` | `+0x4B8` | `+0x4B8` | `+0x4B8` |
| `Protection` ( `_PS_PROTECTION` ) | `+0x6CA` | `+0x87A` | `+0x87A` | `+0x8FA` |
| `MitigationFlags` / `Flags2` | `+0x828` | `+0x9D0` | `+0x9D8` | `+0xA58` |

Nunca asumas un offset fijo: verificá el build o corré `dt nt!_EPROCESS UniqueProcessId ActiveProcessLinks Token Protection MitigationFlags` contra los símbolos ( `.pdb` ) de `ntoskrnl.exe` de **esa** máquina, o utilizá las macros dinámicas `#FIELD_OFFSET`.

## Práctica segura

En tu VM, con un **programa propio** (o Process Explorer sobre uno benigno):

1. Con **Process Explorer**, abrí un proceso propio y mirá su cuenta y sus **handles**. Para los grupos y privilegios de tu sesión, ejecutá `whoami /all`; anotá cuáles figuran habilitados y cuáles no.
2. Identificá handles a un archivo, una clave y un objeto con nombre (evento/mutex). Si el proceso no tiene uno de esos objetos, anotalo: no hace falta crearlo para completar la observación.
3. Compará el token del proceso propio con el de la sesión solo si ambos pertenecen a la misma cuenta y nivel de integridad; no eleves privilegios para la práctica.
4. Mirá la **DACL** de un objeto propio (p. ej. `icacls` sobre un archivo tuyo) y explicá quién tiene qué.

## Entregable

Una ficha del proceso: nivel de integridad, privilegios habilitados, 3–5 handles relevantes (con qué objeto) y una observación sobre la DACL de uno de esos objetos. Solo observación, sin modificar permisos.

## Preguntas de repaso

▼ **¿Qué es un handle y qué guarda además del objeto?**

> Un índice en la **tabla de handles** privada del proceso que apunta a un objeto del kernel; guarda también la **access mask** (los permisos con que se abrió). El proceso opera por el handle, no sobre el objeto directo.

▼ **¿Qué define lo que un proceso puede hacer sobre un objeto?**

> La comparación de su **token** (SIDs, privilegios, nivel de integridad) contra la **DACL** del objeto. Si la DACL no concede el acceso pedido para ese SID, se rechaza.

▼ **¿Qué diferencia hay entre un privilegio "presente" y uno "habilitado"?**

> Presente = el token lo tiene en su lista; habilitado = está **activo** ahora. Muchos privilegios potentes vienen presentes pero deshabilitados y hay que habilitarlos para usarlos; en el análisis te fijás cuáles están **ON**.

▼ **¿Para qué sirve el nivel de integridad?**

> Es una barrera: un proceso de integridad **baja** no puede escribir en objetos de integridad **mayor**. Es la base de los sandboxes (p. ej. el del navegador).

▼ **¿Por qué un mutex con nombre es interesante al analizar, y qué cuidado hay que tener?**

> Suele ser el mecanismo de **instancia única** ("ya estoy corriendo"), así que es una **pista** útil. Pero su nombre **por sí solo no es un IOC**: un nombre genérico puede coincidir con software legítimo; sirve como indicio a **corroborar** con más contexto.

**Puerta de salida (optativa)**

Podés: (1) explicar el modelo objeto/handle/access-mask; (2) leer un token (SIDs, privilegios ON/off, integridad); (3) relacionar token + DACL en un chequeo de acceso; (4) sacar evidencia (handles, mutex) de un proceso propio sin modificarlo.

## Fuentes

- **Conocimiento externo** (Microsoft Learn; páginas concretas): Handles and Objects, Process Explorer, Access Tokens, Privileges, Mandatory Integrity Control y Access Control Lists. No se citan versiones ni valores reales: el ejemplo es ilustrativo.
- **Fundamentos previos:** la lectura del **PEB** y el contexto de proceso aparecen en 2.15 Anti-análisis; el robo de token en kernel se menciona (de forma ofensiva, fuera de alcance) en los tutes 49–69 del Curso IDA, que acá **no** se usan como guía.

**Etiquetas**

**Núcleo conceptual:** solo el PEB/contexto de 2.15 (referencia). **Conocimiento externo:** todo el modelo de seguridad. **Ejemplo ilustrativo:** la vista de token/handles. **Laboratorio verificado:** ninguno en esta edición (no hay binario compilado con datos reales); la práctica se hace sobre procesos propios en tu VM.

**Ampliación editorial basada en fuentes externas — Inspección de _EPROCESS, _EX_FAST_REF y máscaras de privilegios en _TOKEN con WinDbg**

Al analizar privilegios y niveles de integridad desde el depurador de kernel, las herramientas administrativas de user-mode (como Process Explorer) no bastan; el analista debe inspeccionar directamente las estructuras del ejecutivo en memoria (Microsoft Learn: *!process*, *!token* y símbolos públicos de `ntoskrnl.exe`) *(Hecho confirmado)*:

```
kd> !process 0 0 BlocLab.exe                ; Obtiene la dirección de _EPROCESS
kd> dt nt!_EPROCESS <dir_eprocess> UniqueProcessId ActiveProcessLinks Token Protection
```

- **Puntero `Token` (`_EX_FAST_REF`):** En x64, los 4 bits menos significativos del campo `Token` almacenan un contador de referencias rápidas. Para obtener la dirección virtual real de la estructura `_TOKEN` se debe aplicar la máscara `Token & ~0xF` (poniendo en `0` el último dígito hexadecimal).
- **Máscaras de 64 bits en `_SEP_TOKEN_PRIVILEGES` (`dt nt!_TOKEN <dir_token> Privileges`):** En lugar de recorrer listas de privilegios, el kernel ubica en el offset `+0x40` de `_TOKEN` tres campos `QWORD` contiguos: `Present`, `Enabled` y `EnabledByDefault`. Cada privilegio corresponde a un bit fijo (p. ej., `SeDebugPrivilege` es el bit 20 = `0x100000`), permitiendo verificar privilegios activos mediante una única instrucción bit a bit (`bt` / `test`).
- **Nivel de protección (`PS_PROTECTION`):** Un byte que codifica `Type` (bits 0..2: `0` = ninguno, `1` = `ProtectedLight` / PPL, `2` = `Protected`) y `Signer` (bits 4..7: `WinTcb`, `Antimalware`, `Lsa`), determinando si el proceso puede ser accedido desde user-mode.

# Memoria y loader: PEB/TEB, VAD e image mapping

> **Rama optativa 2D**
>
> Lección de la rama optativa 2D. Profundiza en cómo se **describe** la memoria del proceso; no repite el formato PE (1.4) ni el PE fino (2.14), se apoya en ellos.

> **Propósito**
>
> Saber de dónde sale la información de memoria de un proceso: el **PEB/TEB** (en user-mode), la **lista del loader** (módulos cargados) y las **VAD** (cómo el kernel describe cada región), y cómo se **mapea** una imagen. Para orientarte en un dump o en vivo sin perderte, y reconocer el contexto WOW64.

**Prerrequisitos**

- *Obligatorios:* memoria y stack (1.2), formato PE (1.4).
- *Recomendados:* PE fino (2.14), TLS (2.11), WinDbg (2.19).

## PEB y TEB

El **PEB** (*Process Environment Block*) y el **TEB** (*Thread Environment Block*) son estructuras en **user-mode** que describen el proceso y cada hilo. Ya tocaste el PEB en anti-análisis (el campo `BeingDebugged`). Para memoria/loader, lo valioso del PEB:

- `Ldr` → tres listas doblemente enlazadas de **módulos cargados** (por orden de carga, de memoria y de inicialización): base, tamaño y nombre de cada DLL. Es de donde sale la lista de módulos que ves en el debugger.
- `ProcessParameters` → línea de comandos, directorio actual, variables de entorno: contexto de ejecución, útil en análisis.

El TEB guarda, entre otras cosas, el puntero a la cadena **SEH** en 32 bits (`FS:[0]`) y el TLS por hilo (lo viste en 2.11).

## WOW64: proceso x86 en Windows de 64 bits

**WOW64** permite ejecutar aplicaciones x86 en Windows x64; también hay variantes para ejecutar aplicaciones x86 y ARM de 32 bits en Windows ARM64. Para reversing importa porque el proceso conserva una vista de 32 bits, mientras el sistema operativo y algunas herramientas pueden mostrar el contexto nativo de 64 bits. Un proceso x86 no puede cargar una DLL x64 para ejecutarla, ni a la inversa; la comunicación entre ambos mundos requiere una frontera explícita, por ejemplo IPC o ciertos mecanismos de interoperabilidad.

Al comparar un proceso WOW64, anotá siempre la arquitectura del proceso y la del sistema. La redirección de archivos y Registro puede hacer que una ruta aparente no sea la que finalmente se consulta; no confundas esa redirección con una diferencia en el binario. En depuración, confirmá qué contexto de

registros y qué vista de módulos estás examinando antes de interpretar direcciones o stacks. La práctica de esta lección sigue siendo de lectura: identificar arquitectura, módulos y regiones sin cambiar redirecciones del sistema.

### Cruce de llamadas entre x86 y el sistema nativo

En Windows x64, WOW64 no convierte cada instrucción x86 a x64. El proceso usa su ntdll x86; cuando llega a una llamada de servicio, una secuencia de transición en user mode permite que WOW64 la intercepte. La transición entra en modo nativo, donde las thunks de Wow64.dll adaptan argumentos de 32 a 64 bits y encaminan la llamada al servicio nativo. Por eso una pila puede alternar contexto x86 y nativo, y una vista x86 del depurador no siempre muestra toda la transición.

Con WinDbg nativo y la extensión wow64exts, !wow64exts.sw cambia entre los contextos x86 y nativo, !wow64exts.k muestra una pila combinada y !wow64exts.info resume datos de PEB/TEB de WOW64. La implementación interna puede variar por arquitectura y build; estos comandos sirven para observarla, no son un contrato de aplicación.

## La lista del loader

El **loader** de ntdll mantiene esas listas (`PEB_LDR_DATA` → `LDR_DATA_TABLE_ENTRY`). Que estén en listas enlazadas tiene una consecuencia para el análisis: un módulo se puede **desenlazar** de ellas para "esconderlo" de herramientas que solo recorren la lista. Por eso, al buscar módulos ocultos, se compara la lista del loader con lo que dicen las **VAD** del kernel. (Reconocer esto es defensivo; no se enseña a ocultar nada.)

## VAD: cómo el kernel describe la memoria

Las **VAD** (*Virtual Address Descriptors*) son un árbol que el kernel mantiene por proceso: cada nodo describe un **rango** de direcciones virtuales (privado o mapeado, permisos, a qué archivo/sección corresponde). En WinDbg, `!vadump` lista las regiones de un proceso en user mode. La extensión `!vad` ofrece detalles de nodos VAD en depuración de kernel y requiere los argumentos/contexto adecuados; no es un sustituto directo de `!vadump`. Sirven para:

- Ver **qué es** cada región: imagen mapeada (`Image`), archivo mapeado (`Mapped`), o memoria privada (`Private`, típico del heap/stack).
- **Cruzar** con la lista del loader: si una VAD de tipo `Image` no aparece en la lista del loader, es **algo a investigar** —puede tener explicaciones legítimas—, no una prueba de que haya un módulo oculto.

## Image mapping y secciones

Un `.exe` / `.dll` no se "copia" a memoria: se **mapea** vía un objeto **sección** (*section/file mapping*). Las páginas de código **suelen** ser de solo-lectura/ejecución y **compartidas** entre procesos (varias instancias comparten la misma imagen física); las de datos usan **copy-on-write** (se duplican al primer escribir). Ojo: los permisos exactos **dependen de las características de cada sección** del PE (una sección puede ser escribible) y pueden variar, así que no asumas "todo el código es RO". El loader aplica las **relocalizaciones** solo si la imagen no cargó en su base preferida (ASLR), y resuelve los imports (lo viste en PE/IAT, 1.4).

## Ejemplo trabajado

*(Ejemplo **ilustrativo**: salida resumida de WinDbg; valores construidos.)*

```
0:000> lm                      (módulos cargados — fuente confiable para la lista)
    start    end      module
    00400000 0040c000 prog
    77000000 77180000 ntdll
    75d00000 75e00000 KERNEL32

0:000> !peb                    (extracto; la salida varía según versión/sesión)
    ProcessParameters.CommandLine: "prog.exe" --modo test

0:000> !vadump                 (extracto de regiones)
    BaseAddress  RegionSize  Protect         Type
    00400000     0000c000    EXECUTE_READ    Image    (prog.exe)
    00030000     00002000    READWRITE       Private  (heap/stack)
    00140000     00002000    READONLY        Mapped   (archivo de datos)
```

Lectura: `lm` da la lista de módulos; `prog.exe` aparece además como región `Image` en `!vadump`, el heap/stack es `Private` READWRITE y hay un archivo `Mapped` READONLY. La `CommandLine` del `!peb` da el contexto (ese comando puede variar según la versión de Windows y el tipo de sesión). Todo esto orienta un dump sin suponer.

## Práctica segura

En tu VM, con WinDbg sobre un **proceso propio**:

1. Con `lm` listá los **módulos cargados**; con `!peb` mirá la **CommandLine** (su salida varía según versión/sesión, por eso los módulos salen de `lm`).
2. `!vadump`: identificá una región `Image`, una `Private` y, si hay, una `Mapped`. Decí qué es cada una.
3. Elegí una DLL de `lm` y confirmá que tiene una región `Image` en su base en `!vadump` (la coherencia módulos↔VAD).
4. Anotá base y tamaño de tu `.exe` y compará con lo que dice el PE en disco (2.14).
5. En un proceso x86 bajo WOW64, alterná el contexto con !wow64exts.sw y observá la pila combinada con !wow64exts.k; registra qué frames son x86 y cuáles nativos.

## Entregable

Un mapa breve del proceso: lista de 3–5 módulos (base), 3 regiones de VAD clasificadas (Image/Private/Mapped) y la línea de comandos. Con una frase sobre la coherencia loader↔VAD.

## Preguntas de repaso

▼ **¿Qué guarda el campo `Ldr` del PEB y por qué importa?**

> Las **listas de módulos cargados** (base, tamaño, nombre). Importa porque es la fuente de la lista de DLLs del proceso; y porque un módulo puede desenlazarse de ahí para esconderse, lo que se detecta cruzando con las VAD.

▼ **¿Qué describe una VAD?**

> Un **rango** de direcciones virtuales del proceso: su tipo ( `Image` / `Mapped` / `Private` ), permisos y a qué archivo/sección corresponde. El kernel las mantiene en un árbol por proceso; `!vadump` sirve para listar regiones en user mode y `!vad` para inspección detallada en el contexto de depuración de kernel.

▼ **¿Qué precaución tomás al analizar un proceso WOW64?**

> Anoto por separado la arquitectura del proceso y la del sistema, confirmo el contexto de registros y módulos, y tengo en cuenta la redirección de archivos/Registro. Un proceso de 32 bits no puede cargar una DLL de 64 bits para ejecutarla.

▼ **¿Cómo se investiga un posible módulo que no está en la lista del loader?**

> Comparando los módulos ( `lm` / lista del loader) con las **regiones** `Image` ( `!vadump` / VAD del kernel): una imagen mapeada que no figure en la lista es **algo a investigar** (puede tener causas legítimas), no una prueba de ocultamiento. Es reconocimiento defensivo, no ocultar nada.

▼ **¿Por qué el código de una DLL se comparte entre procesos y los datos no?**

> Porque el ejecutable se **mapea** como una imagen respaldada por una sección. Las páginas pueden compartirse mientras coinciden con el archivo; los permisos y el comportamiento ante escrituras dependen de cada sección. En una vista *copy-on-write*, la página modificada se vuelve privada para ese proceso. No todas las imágenes tienen permisos idénticos; verificá la región concreta con `!vadump`.

▼ **¿Cuándo aplica el loader las relocalizaciones?**

> Solo si la imagen **no** cargó en su base preferida (por ASLR u ocupación): entonces ajusta las direcciones absolutas con la tabla de relocalización.

**Puerta de salida (optativa)**

Podés: (1) listar módulos con `lm` y leer la CommandLine con `!peb` ; (2) clasificar regiones con `!vadump` (Image/Private/Mapped); (3) explicar la coherencia módulos↔VAD y qué amerita investigar; (4) explicar image mapping, código compartido y copy-on-write, y por qué los permisos de sección pueden variar; (5) describir qué cambia al analizar un proceso WOW64 y no confundir la vista x86 con la nativa.

## Fuentes

- Microsoft Learn: Debugging WOW64, File System Redirector.
- Microsoft Learn: Running 32-bit Applications (WOW64), WOW64 Implementation Details.
- **Conocimiento externo** (páginas concretas): PEB (winternl), `lm` (list modules), `!vadump` y el formato PE (características de sección). *Windows Internals* como referencia general. No se citan versiones ni valores reales.
- **Fundamentos previos:** el PEB (`BeingDebugged`) en 2.15; PE, IAT y relocalizaciones en 1.4 y 2.14; TLS/SEH en 2.11.

> **Etiquetas**
>
> **Núcleo conceptual:** PEB y PE/loader de 1.4, 2.11, 2.14, 2.15 (referencia). **Conocimiento externo:** VAD, listas del loader, image mapping/COW, redirección y transición WOW64. **Ejemplo ilustrativo:** las salidas de `lm`, `!peb` y `!vadump`. **Laboratorio verificado:** ninguno en esta edición; la práctica se hace sobre procesos propios en tu VM.

# Registro de Windows: hives, permisos, WOW64 y análisis defensivo

**Rama optativa 2D**

Lección de la rama optativa 2D. Defensiva: **observar y detectar** cambios en el registro; no crear persistencia encubierta.

**Propósito**

Entender cómo está organizado el registro (hives, claves, valores), quién puede escribir dónde (permisos), la redirección **WOW64** para apps de 32 bits, y cómo **observar** qué toca un programa propio (configuración y persistencia) con evidencia.

**Prerrequisitos**

- *Obligatorios:* objetos y ACL (2D.1), procesos (1.3).
- *Recomendados:* malware estático (5.1).

## Hives y organización

El registro es una base jerárquica de **claves** (carpetas) y **valores** (datos tipados). Las cinco raíces predefinidas (`HKLM`, `HKCU`, `HKCR`, `HKU`, `HKCC`) no corresponden todas a archivos físicos uno a uno: los **hives** son unidades cargadas desde archivos como `SYSTEM`, `SOFTWARE` y el `NTUSER.DAT` de cada usuario; algunas raíces son alias o vistas. `HKCU` apunta al hive del usuario actual; `HKCR` combina las clases de máquina y usuario (`HKLM\Software\Classes` y `HKCU\Software\Classes`); `HKCC` representa la configuración de hardware actual. **Conocimiento externo** (Microsoft Learn).

Zonas que importan en el análisis defensivo:

- **Persistencia:** `...\CurrentVersion\Run` / `RunOnce` (en `HKLM` y `HKCU`), servicios (`HKLM\SYSTEM\CurrentControlSet\Services`), y otras claves de autoarranque.
- **Configuración de apps:** cada programa suele guardar lo suyo bajo `HKCU\Software\<Fabricante>\<App>`.

## Permisos

Cada clave es un **objeto asegurable** con su DACL (como viste en 2D.1). Por eso `HKLM` (de máquina) normalmente requiere administrador y `HKCU` (del usuario) lo puede escribir el propio usuario. Una clave de autoarranque con permisos **demasiado abiertos** (escribible por usuarios sin privilegio) es una debilidad a **reportar**.

## Redirección WOW64

Un proceso de **32 bits** en Windows de 64 bits usa la vista de 32 bits para determinadas claves. Por ejemplo, `HKLM\Software` está redirigida en las versiones actuales de Windows: una app x86 que acceda a `HKLM\Software\BlocLab` puede aparecer en la vista de 32 bits que Regedit muestra bajo `HKLM\Software\WOW6432Node\BlocLab`. **No todas las claves se redirigen**; algunas son compartidas, y el resultado depende de la clave y de la versión de Windows. Para un caso real, consultá la tabla oficial de claves afectadas y no agregues `WOW6432Node` a mano en código nuevo.

## Observar cambios (defensivo)

- **Diferencial: Regshot** saca un snapshot antes y después de ejecutar; te da la lista exacta de claves/valores creados o cambiados.
- **En vivo: Process Monitor** con filtro de operaciones de registro (`RegSetValue`, `RegCreateKey`) muestra quién tocó qué y cuándo, con el stack.

## Ejemplo trabajado

*(Ejemplo **ilustrativo**: salida resumida de Regshot sobre una app de laboratorio; valores construidos.)*

```
Regshot — diff antes/después de correr bloc_lab.exe (x86) en la VM:
  Valores agregados:
    HKCU\Software\BlocLab\Settings\Theme = "dark"        ← su config propia (vista compartida)
    HKLM\Software\WOW6432Node\BlocLab\Build = "lab-1"    ← vista x86 de HKLM\Software (app 32-bit)
  (sin cambios en HKLM ni en claves Run)
```

Lectura: la app guardó su configuración de usuario en `HKCU` y, en este ejemplo, escribió también en la vista x86 de su clave de máquina `HKLM\Software`. El diff aparece resumido con la ruta física `WOW6432Node`; el acceso de la app fue a la vista lógica de 32 bits. **No** tocó `Run`: el ejemplo no muestra cambios de autoarranque. Es una ilustración de las vistas, no una regla aplicable a cualquier clave.

## Práctica segura

En tu VM, con un **programa propio** que guarde configuración en el registro:

1. **Regshot:** snapshot → corré el programa → segundo snapshot → *compare*. Anotá qué claves/valores agregó.
2. Si es de 32 bits, confirmá la **redirección WOW64** (aparece bajo `WOW6432Node`).
3. En Regedit, abrí **Permisos** de la clave propia y observá su **DACL**. No cambies permisos. `icacls` trabaja con archivos y no es la herramienta para inspeccionar claves del registro.
4. Confirmá que la práctica no cambió claves de autoarranque. Si necesitás practicar la lectura de una clave `Run`, usá una captura o exportación de ejemplo; no la crees ni la modifiques en el equipo.

## Entregable

Lista de claves/valores de configuración que tu programa propio creó o modificó (con su tipo), si hubo redirección WOW64, y una observación de permisos de una clave propia. Incluí evidencia de que no cambiaste claves de autoarranque.

## Preguntas de repaso

▼ **¿Qué es un hive y cómo se relaciona con `HKCU` / `HKLM`?**

> Una unidad lógica de datos del registro que Windows carga y respalda, por ejemplo, con `NTUSER.DAT` o `SOFTWARE`. Las raíces predefinidas no son todas archivos ni hives uno a uno: `HKCU` apunta al usuario actual y `HKCR` es una vista combinada.

▼ **¿Por qué `HKLM` suele requerir administrador y `HKCU` no?**

> Por la **DACL** de cada clave: las de máquina (`HKLM`) conceden escritura a administradores; el hive del usuario (`HKCU`) lo puede escribir el propio usuario. Son objetos asegurables.

▼ **Una app de 32 bits dice escribir en `HKLM\Software\Foo` pero no la ves ahí. ¿Dónde está?**

> Si esa clave está entre las afectadas, la app x86 accede a la vista de 32 bits y Regedit de 64 bits suele mostrarla bajo `HKLM\Software\WOW6432Node\Foo`. Hay que confirmar el comportamiento para la clave concreta: WOW64 también tiene claves compartidas.

▼ **¿Cómo obtenés la lista exacta de lo que tocó un programa en el registro?**

> Con un **diferencial** (Regshot: snapshot antes/después) o en vivo con **Process Monitor** filtrando operaciones de registro. El diff te da claves/valores agregados o cambiados.

▼ **¿Qué hace "peligrosa" a una clave de autoarranque?**

> Que su **DACL** permita escribir a usuarios sin privilegio: cualquiera podría poner algo que se ejecute al inicio. Es una debilidad a **reportar**, no a aprovechar.

> **Puerta de salida (optativa)**
>
> Podés: (1) explicar hives y las vistas `HKCU` / `HKLM` / `HKCR`; (2) relacionar permisos de clave con su DACL; (3) reconocer la redirección WOW64; (4) sacar con Regshot/Procmon la lista de cambios de un programa propio y dejar el sistema limpio.

## Fuentes

- **Conocimiento externo** (Microsoft Learn): Registry Hives, Structure of the Registry, Registry Key Security and Access Rights, Registry Redirector (WOW64) y Registry Keys Affected by WOW64.
- **Fundamentos previos:** objetos asegurables y DACL en 2D.1; la persistencia por `Run` también aparece como IOC en la rama de malware.

**Etiquetas**

**Núcleo conceptual:** solo el marco de ACL (2D.1) y la noción de persistencia. **Conocimiento externo:** estructura del registro, permisos y WOW64. **Ejemplo ilustrativo:** el diff de Regshot. **Laboratorio verificado:** ninguno en esta edición; la práctica se hace sobre un programa propio en tu VM, con limpieza.

# Servicios: SCM, ciclo de vida, cuentas y auditoría

> **Rama optativa 2D**
>
> Lección optativa y defensiva. La práctica usa únicamente un servicio propio en una VM descartable; no modifica servicios de Windows ni intenta abusar de permisos.

> **Propósito**
>
> Entender qué registra y controla el **Service Control Manager (SCM)**, seguir los estados de un servicio y leer su cuenta, ruta y permisos. Distinguir un servicio con ejecutable propio de uno hospedado como DLL, y terminar la práctica dejando la VM en el estado inicial.

**Prerrequisitos**

- *Obligatorios:* objetos, tokens y ACL (2D.1); registro de Windows (2D.3).
- *Recomendados:* procesos (1.3) y conceptos de depuración (2.19).

## Qué controla el SCM

El **SCM** es el componente que mantiene el registro de servicios instalados, los inicia bajo demanda o al arrancar Windows, conserva sus estados y entrega solicitudes de control. Los programas administrativos consultan o cambian el servicio mediante las API del SCM; el registro contiene también datos asociados en `HKLM\SYSTEM\CurrentControlSet\Services\<nombre>`. Para este curso, consultá la configuración por las herramientas del SCM: **no edites a mano** las claves de un servicio.

Un servicio Win32 no es “una DLL que corre sola”. El programa de servicio contiene el punto de entrada y una función `ServiceMain`; el SCM se comunica con ese programa mediante el dispatcher y el handler de controles. Un ejecutable de consola cualquiera no cumple esa interfaz y no se convierte en servicio por registrarlo.

## Tipo de servicio, tipo de inicio y estado

Son conceptos distintos:

- **Tipo:** `own` (proceso propio) o `share` (programa de servicio compartido). Los tipos `kernel` y `filesys` corresponden a drivers y quedan fuera de esta lección.
- **Tipo de inicio:** `demand` es inicio manual; `auto` inicia con Windows; `delayed-auto` lo inicia más tarde; `disabled` impide iniciarlo. `boot` y `system` son opciones de inicio para drivers, no para el servicio didáctico de esta práctica.
- **Estado actual:** `STOPPED`, `START_PENDING`, `RUNNING`, `STOP_PENDING` o `PAUSED`. El tipo de inicio describe cuándo puede arrancar; el estado describe qué está pasando ahora.

Al entrar en `ServiceMain`, el programa registra su handler de controles y comunica estados al SCM. Durante una inicialización larga informa que el inicio sigue pendiente; al detenerse, procesa la solicitud y

notifica el estado final.

## Ejecutables y servicios hospedados

Un servicio puede ejecutarse en un proceso propio o compartir un programa anfitrión. Windows usa `svchost.exe` para hospedar algunos de sus servicios; la organización de los grupos y procesos varía según la versión y la configuración. `svchost.exe` es un componente del sistema, no una plantilla para registrar servicios propios.

Algunos servicios hospedados cargan una DLL indicada por su configuración, que suele aparecer como `ServiceDll` bajo `Parameters`. Esto se analiza **en lectura**: el valor permite relacionar servicio, proceso anfitrión y módulo. No se cambia el valor ni se reemplaza la DLL. Para comprender el mecanismo, consultá la documentación de programas de servicio y el artículo de agrupación de `svchost`; no supongas que todos los servicios usan este modelo.

## Cuenta y permisos

Cada servicio se ejecuta con un token asociado a una cuenta. `LocalSystem` tiene privilegios amplios; `LocalService` y `NetworkService` tienen perfiles distintos y más limitados. Un servicio bien configurado usa la cuenta de menor privilegio que necesite.

La DACL del **objeto servicio** controla quién puede consultarlo, iniciarlo, detenerlo o cambiar su configuración. Es distinta de la ACL del ejecutable y de sus carpetas. Para una auditoría defensiva, registrá si la ruta existe, quién puede modificar sus archivos y qué permisos tienen las cuentas sobre el objeto servicio. Un permiso de cambio de configuración tiene impacto alto porque permite alterar los datos que el SCM usa; documentá una asignación excesiva, pero no la pruebes ni la aproveches.

## Ejemplo trabajado

*(Ejemplo **ilustrativo**, no observado en un Windows real. Los nombres y valores son de un servicio ficticio de laboratorio.)*

```
Nombre: ReversingLabSvc
Tipo: own-process (servicio Win32)
Tipo de inicio: demand (manual)
Estado: STOPPED
Cuenta: NT AUTHORITY\LocalService
ImagePath: C:\ReversingLab\SvcLab.exe
Objeto servicio: Administrators — control; Users — lectura
Carpeta del binario: solo administradores pueden modificarla
```

Lectura: es un servicio didáctico de proceso propio, detenido y de inicio manual. La cuenta elegida tiene menos privilegios que `LocalSystem`; la ruta y los permisos son coherentes con esa práctica. Esta ficha no demuestra que un servicio real sea seguro: cada hallazgo debe corroborarse con la configuración efectiva y el contexto del equipo.

## Práctica segura: servicio propio y limpieza

Realizá el ejercicio solo en una VM descartable con snapshot. Realizá el ejercicio en una VM descartable con snapshot. Compilá el servicio didáctico desde el archivo `plantillas_codigo/svclab_min.c` (**Plantilla 7 del Kit de Código**), que implementa `StartServiceCtrlDispatcherW`, `ServiceMain` y `RegisterServiceCtrlHandlerExW` para Windows x86/x64:

```
cl /Zi /O1 /DUNICODE /D_UNICODE svclab_min.c advapi32.lib /Fe:C:\ReversingLab\SvcLab.exe
```

(O con MinGW: `gcc -O1 -g -municode svclab_min.c -ladvapi32 -o C:\ReversingLab\SvcLab.exe`).

**Materiales y resultado esperado:** VM/build registrados, snapshot recuperable, `sc.exe`, AccessChk de Sysinternals y el binario propio identificado por hash. El resultado esperado es registrar un servicio manual, verlo pasar a `RUNNING` y `STOPPED`, y confirmar que desaparece después de solicitar su eliminación. Guardá el build de Windows, hash, salidas de consulta y evidencia de limpieza; no se fija una versión de herramienta que no se haya probado.

**Paso 1 — Preparar.** Prepará `C:\ReversingLab` y colocá allí el binario propio. No uses una ruta de red ni un servicio de Windows.

**Paso 2 — Registrar.** En una consola elevada de la VM, registrá el servicio con inicio manual y una cuenta de menor privilegio:

```
   sc.exe create ReversingLabSvc binPath= "C:\ReversingLab\SvcLab.exe" start= demand obj= "NT
AUTHORITY\LocalService"
```

**Paso 3 — Inspeccionar.** Consultá su configuración y estado; auditá la DACL del objeto servicio sin modificarla:

```
   sc.exe qc ReversingLabSvc
   sc.exe query ReversingLabSvc
   accesschk.exe -v -c ReversingLabSvc
```

**Paso 4 — Probar el ciclo de vida.** Iniciá y detené solo `ReversingLabSvc`. Observá los cambios de estado y anotá la cuenta y la ruta reportadas.

**Paso 5 — Limpiar.** Detené el servicio si sigue activo y solicitá eliminar únicamente el servicio de laboratorio:

```
   sc.exe stop ReversingLabSvc
   sc.exe delete ReversingLabSvc
   sc.exe query ReversingLabSvc
```

`sc.exe delete` puede dejarlo marcado para borrar si todavía está activo o si hay una consola con un handle abierto. Cerrá `services.msc` y las herramientas que lo estén consultando; esperá a que desaparezca

o revertí el snapshot. Confirmá que `sc.exe query ReversingLabSvc` ya no encuentra el servicio y recién entonces borrá `C:\ReversingLab`.

No cambies permisos, configuración ni cuenta de otros servicios. Si no tenés un binario propio que implemente el contrato de servicio, hacé el análisis como ejercicio de lectura con la ficha ilustrativa y dejá constancia de esa limitación.

## Entregable

Una ficha con tipo, inicio, estado, cuenta, ruta, resultado de la inspección de permisos y evidencia de limpieza. Indicá si trabajaste con un servicio compilado o solo con el ejemplo ilustrativo. No incluyas datos personales de la VM.

## Preguntas de repaso

<details>
<summary>¿Qué responsabilidad tiene el SCM?</summary>

Mantiene el registro de servicios, los inicia, conserva su estado y envía solicitudes de control.
</details>

<details>
<summary>¿En qué se diferencian el tipo de inicio y el estado?</summary>

El tipo de inicio determina cuándo puede comenzar; el estado indica si está detenido, iniciándose, activo, deteniéndose o pausado.
</details>

<details>
<summary>¿Un ejecutable de consola se vuelve servicio al registrarlo?</summary>

No. El programa debe implementar el dispatcher de servicios, `ServiceMain` y el handler de controles.
</details>

<details>
<summary>¿Qué diferencia hay entre el objeto servicio y los permisos del archivo ejecutable?</summary>

La DACL del objeto controla operaciones sobre el servicio; la ACL del archivo y sus carpetas controla quién puede leer, ejecutar o modificar esos archivos. Se auditan por separado.
</details>

<details>
<summary>¿Qué significa que `sc.exe delete` no lo haya quitado inmediatamente?</summary>

Puede estar marcado para eliminación porque sigue activo o porque otro programa conserva un handle. Cerrá las consolas que lo consultan, esperá y verificá su ausencia antes de borrar los archivos.
</details>

> **Puerta de salida (optativa)**
>
> Podés explicar SCM, `ServiceMain`, tipo de inicio y estado; leer cuenta, ruta y permisos; distinguir un proceso propio de un servicio hospedado; y demostrar que el servicio de prueba desapareció o declarar que solo completaste el ejercicio ilustrativo.

## Fuentes

- **Conocimiento externo:** Service Control Manager, Service Programs, ServiceMain, Service User Accounts y Service Security and Access Rights.

- **Herramientas:** `sc.exe create`, `sc.exe delete` y AccessChk.
- **Hospedaje:** Service host grouping in Windows. Los detalles de agrupación dependen de la versión de Windows.
- **Fundamentos previos:** ACL y token en 2D.1; representación del registro en 2D.3.

**Etiquetas**

**Núcleo conceptual:** marco de token/ACL (2D.1) y referencia al registro (2D.3). **Conocimiento externo:** SCM, estados, cuentas y servicios hospedados. **Ejemplo ilustrativo:** ficha de `ReversingLabSvc`. **Laboratorio verificado:** no; requiere un binario propio compilado como servicio.

# Task Scheduler: leer tareas y detectar cambios

> **Rama optativa 2D**
>
> Lección optativa de análisis defensivo. La práctica inspecciona tareas existentes y exporta su definición; no crea, modifica, ejecuta ni oculta tareas.

> **Propósito**
>
> Entender de qué partes se compone una tarea programada y reconstruir, a partir de sus metadatos y XML, **qué se ejecuta, cuándo y bajo qué identidad**. Aprender a separar una configuración poco habitual de una conclusión de compromiso.

**Prerrequisitos**

- *Obligatorios:* registro y contexto de seguridad (2D.1, 2D.3).
- *Recomendados:* servicios y SCM (2D.4); procesos (1.3).

## Partes de una tarea

Una tarea registrada combina una **acción** con uno o más **triggers** y ajustes. La definición también describe el **principal** (la identidad y el nivel con que se ejecuta) y datos de registro como nombre, autor, descripción y ruta lógica (URI). El XML permite revisar estos elementos juntos.

- **Trigger:** condición temporal o de evento que solicita la ejecución, por ejemplo, un horario o el inicio de sesión.
- **Action:** lo que Task Scheduler ejecuta y sus argumentos. Revisá ruta, firma y relación con el software instalado.
- **Principal / contexto:** cuenta, tipo de inicio de sesión y nivel de ejecución. `RunLevel` no concede privilegios por sí mismo; importa junto con la identidad, sus derechos y la configuración de la tarea.
- **Settings:** habilitación, restricciones, límites y propiedad `Hidden`.
- **RegistrationInfo:** autor, descripción, fecha, URI y otros datos administrativos.

## Visibilidad y auditoría

`Hidden=true` indica que la tarea no se muestra normalmente en la interfaz; no la vuelve invisible para un administrador ni demuestra que sea maliciosa. Una tarea puede ser legítima y poco conocida. Evaluá el conjunto: acción y argumentos, firma y ubicación del ejecutable, trigger, principal, nivel, autor, permisos y coherencia con el software instalado.

La revisión es **de solo lectura**. Podés usar el Programador de tareas para abrir la pestaña de propiedades y exportar el XML, o consultar una tarea específica con herramientas de Windows. No deshabilites ni borres una tarea desconocida durante el análisis; preservá los datos y pedí revisión al administrador responsable.

## Ejemplo trabajado

*(Fragmento **ficticio e incompleto**, solo para aprender a leer campos; no es un XML para registrar.)*

```
<RegistrationInfo>
  <Author>Reversing Lab</Author>
  <Description>Comprobación local de estado</Description>
</RegistrationInfo>
<Triggers>
  <TimeTrigger><Enabled>false</Enabled></TimeTrigger>
</Triggers>
<Principals>
  <Principal id="Author">
    <UserId>PC-LAB\alumno</UserId>
    <RunLevel>LeastPrivilege</RunLevel>
  </Principal>
</Principals>
<Settings><Hidden>false</Hidden></Settings>
<Actions Context="Author">
  <Exec>
    <Command>C:\ReversingLab\status.exe</Command>
    <Arguments>--once</Arguments>
  </Exec>
</Actions>
```

Lectura: la acción apunta a un ejecutable local y lleva el argumento `--once`; el trigger está deshabilitado en este fragmento; el principal es un usuario de laboratorio con nivel `LeastPrivilege`; y `Hidden` es falso. Como el ejemplo está incompleto y ficticio, no permite registrar ni evaluar una tarea real.

## Práctica segura: inspección de solo lectura

En una VM de laboratorio o en un equipo donde tengas autorización, elegí una tarea conocida y no crítica del sistema o de una aplicación instalada. No la ejecutes ni cambies su configuración.

1. Abrí sus propiedades en Task Scheduler y anotá nombre/URI, autor, descripción y estado habilitado/deshabilitado.
2. Revisá trigger, acción y argumentos. Confirmá si el archivo existe y consultá su firma sin abrirlo ni ejecutarlo.
3. Anotá principal, tipo de inicio de sesión, nivel de ejecución y si `Hidden` figura en las propiedades o en el XML.
4. Exportá el XML a una carpeta temporal del laboratorio y revisá los mismos campos. Si vas a compartir el informe, quitá nombres de usuario, rutas personales y otros datos privados.
5. Compará la tarea con la documentación del producto o con otra referencia confiable. Si algo no coincide, describilo como **anomalía para investigar**, no como prueba de malware.
6. Eliminá solo la copia exportada si ya no la necesitás. No borres ni deshabilites la tarea analizada.

## Entregable

Una ficha con URI/nombre, autor, trigger, acción y argumentos, principal, nivel, valor `Hidden`, procedencia conocida y fuente usada para la comparación. Cerrá con una conclusión calibrada: normal, no explicado o requiere revisión; indicá qué evidencia falta.

## Preguntas de repaso

<details>
<summary>¿Qué diferencia hay entre trigger y acción?</summary>

El trigger define **cuándo** se solicita ejecutar la tarea; la acción define **qué** programa o comando ejecuta Task Scheduler.
</details>

<details>
<summary>¿Qué datos del principal conviene leer?</summary>

La identidad, el tipo de inicio de sesión y el nivel de ejecución; deben interpretarse junto con los derechos de esa cuenta.
</details>

<details>
<summary>¿<code>Hidden=true</code> significa que la tarea es invisible o maliciosa?</summary>

No. Cambia su visibilidad normal en la interfaz, pero no la oculta a un administrador ni demuestra intención maliciosa.
</details>

<details>
<summary>¿Qué hacés si encontrás una acción o ruta que no reconocés?</summary>

Registrás los datos, conservás la evidencia y contrastás con una fuente confiable o con el administrador; no ejecutás, deshabilitás ni borrás la tarea durante el análisis.
</details>

**Puerta de salida (optativa)**

Podés explicar trigger, acción, principal y ajustes; leer esos campos en XML; describir el efecto limitado de `Hidden`; y fundamentar una anomalía sin convertirla en una acusación no corroborada.

## Fuentes

- **Conocimiento externo:** About the Task Scheduler, Tasks, Security Contexts for Running Tasks, Task Registration Information y Task Scheduler schema.
- **Propiedad de visibilidad:** TaskSettings.Hidden.
- **Consulta:** `schtasks.exe`.
- **Fundamentos previos:** permisos del registro en 2D.3, contexto de tokens en 2D.1 y servicios en 2D.4.

**Etiquetas**

**Núcleo conceptual:** marco de lectura de configuración y persistencia defensiva. **Conocimiento externo:** Task Scheduler, XML, contextos, triggers y acciones. **Ejemplo ilustrativo:** fragmento ficticio no registrable. **Laboratorio verificado:** no; la práctica propuesta es de inspección de solo lectura.

# COM: interfaces, IUnknown y vida de los objetos

> **Rama optativa 2D**
>
> Lección conceptual y de análisis. El ejemplo es un componente propio; no se registra ni modifica software ajeno.

> **Propósito**
>
> Reconocer cómo un cliente pide una interfaz COM, cómo interpretar el resultado y cómo seguir la llamada hasta la implementación sin confundir una interfaz con una clase C++ concreta. Al terminar deberías poder decir, frente a una llamada indirecta, **qué contrato** se está usando, **en qué apartamento** vive el objeto y si el puntero que tenés delante es el objeto o un **proxy**.

**Prerrequisitos**

- *Obligatorios:* punteros, estructuras y convención de llamada (1.5, 2.5); objetos y handles (2D.1).
- *Recomendados:* C++ profundo (2.18); memoria y loader (2D.2); procesos e hilos (1.3).

## Conceptos

- **CLSID** identifica una clase COM; **IID** identifica un contrato de interfaz. Ambos son GUID, pero responden preguntas distintas.
- `IUnknown` es la base de las interfaces COM: `QueryInterface`, `AddRef` y `Release`. La consulta devuelve `S_OK` si el objeto ofrece el IID o `E_NOINTERFACE` si no.
- **HRESULT** comunica éxito o fallo. No lo interpretes como un booleano: se usa `SUCCEEDED(hr)` / `FAILED(hr)`; algunos resultados no negativos (como `S_FALSE`) indican éxito informativo.
- Una **vtable** contiene punteros a métodos en orden contractual. En una interfaz derivada, los métodos de `IUnknown` preceden a los propios.
- El **reference counting** administra la vida del objeto. Una referencia obtenida debe equilibrarse con `Release`; después de la última liberación, ese puntero no se reutiliza.
- Una llamada puede atravesar una **proxy/stub** si el objeto vive en otro apartamento o proceso. El puntero visible al cliente no tiene por qué apuntar directamente al código servidor.

## Inicialización por hilo: `CoInitializeEx` y `CoUninitialize`

COM no se "enciende" una vez por proceso: **cada hilo** que usa interfaces COM llama a `CoInitializeEx` y, con eso, declara su modelo de concurrencia y queda asociado a un **apartamento**. El primer parámetro es reservado (`NULL`); el segundo lleva exactamente uno de `COINIT_APARTMENTTHREADED` o `COINIT_MULTITHREADED`, más opciones como `COINIT_DISABLE_OLE1DDE`.

Lo que conviene registrar al analizar un binario:

| Resultado | Significado documentado | Qué implica para el análisis |
|---|---|---|
| `S_OK` | COM se inicializó en ese hilo. | Debe haber un `CoUninitialize` equilibrado antes de que el hilo termine. |
| `S_FALSE` | COM ya estaba inicializado en ese hilo con el mismo modelo. | Es éxito; **también** debe equilibrarse con `CoUninitialize`. |
| `RPC_E_CHANGED_MODE` | Un llamado previo fijó un modelo incompatible para ese hilo. | Es fallo: el hilo **sigue** en el modelo anterior y no corresponde un `CoUninitialize` por este llamado. |

Microsoft indica además que no se llame a `CoInitialize(Ex)` ni a `CoUninitialize` desde `DllMain`. Cuando veas una DLL que lo hace, anotalo como hallazgo de calidad, no como intención maliciosa.

## Apartamentos: STA, MTA y por qué existe el marshaling

Un **apartamento** agrupa objetos COM y los hilos que pueden llamarlos **directamente**. Cada objeto vive en exactamente un apartamento; un hilo de otro apartamento que quiera llamarlo debe pasar por un **proxy**.

- **STA (single-threaded apartment)**: un único hilo. Las llamadas que llegan desde otros apartamentos se entregan a través de la **cola de mensajes** de ese hilo, así que se serializan y solo avanzan cuando el hilo bombea mensajes. Si un hilo STA se bloquea en una espera sin bombear (por ejemplo, `WaitForSingleObject`), las llamadas entrantes no se entregan y aparece un interbloqueo. La documentación recomienda `CoWaitForMultipleHandles` o `MsgWaitForMultipleObjects` en esos hilos.
- **MTA (multithreaded apartment)**: uno o más hilos; a lo sumo **una** MTA por proceso. Cualquier hilo de la MTA puede llamar directamente a los objetos de la MTA, y **el objeto** debe sincronizarse por su cuenta (secciones críticas, mutex, etc.).
- Un proceso puede tener **cero o más STA** y **cero o una MTA**. También existe el apartamento **neutral** (NA), que aparece en la próxima lección a través de `ThreadingModel=Neutral`.

**Marshaling** es empaquetar la llamada (parámetros, punteros de interfaz) para que cruce un límite de apartamento, de proceso o de equipo. Existe porque las reglas anteriores solo se cumplen si nadie copia un puntero de interfaz "crudo" a un hilo de otro apartamento. Para pasar una interfaz entre apartamentos del mismo proceso se usan mecanismos explícitos —la Global Interface Table o, en código moderno (Windows 8.1+), `RoGetAgileReference`— que devuelven un puntero directo si se resuelve en el mismo apartamento o un proxy si no.

> **Lectura defensiva del modelo de hilos**
>
> En un análisis, el modelo de hilos sale de la evidencia: el flag pasado a `CoInitializeEx` (si lo ves en un argumento constante), el `ThreadingModel` del servidor (2D.7) y la presencia de un bucle de mensajes. Si solo tenés una de las tres, escribí "probable STA/MTA" y por qué.

## Proxies y stubs: cuando el puntero no es el objeto

Un **proxy** vive en el espacio del llamador y, para el cliente, *es* el objeto: implementa la misma interfaz, empaqueta los parámetros en un búfer y los entrega al canal (RPC). Del otro lado, un **stub** desempaqueta y

llama a la implementación real. El proxy es un objeto compuesto: un *proxy manager* (que implementa el `IUnknown` controlador) y un *interface proxy* por cada interfaz expuesta a ese cliente. El código de esos interface proxies puede estar en una DLL distinta, que el registro asocia al IID mediante `HKCR\Interface\{IID}\ProxyStubClsid32`.

Cómo reconocerlo en el depurador, sin suponer nombres:

1. Tomá el puntero de interfaz `p` y leé su primer campo: es la dirección de la vtable.
2. Resolvé a qué **módulo** pertenecen la vtable y sus primeras entradas (`lm` / `ln` en WinDbg, o el mapa de memoria de tu depurador).
3. Si apuntan al **módulo servidor**, probablemente es un puntero directo. Si apuntan a módulos del runtime COM/RPC o a una DLL de proxy/stub, es un proxy. Los nombres concretos de esos módulos y funciones dependen de la versión de Windows y de los símbolos disponibles: registrá lo que veas, no lo que esperabas ver.
4. Confirmalo con el contexto: ¿el objeto se creó en otro proceso (`LocalServer32`) o en otro apartamento? ¿El hilo cliente es STA y el servidor `Free`?

Consecuencia práctica: poner un breakpoint en la entrada de la vtable de un proxy **no** te lleva a la implementación; te lleva al código de marshaling. La implementación se sigue en el **proceso o apartamento del servidor**.

## Marshaling a medida y el *free-threaded marshaler*

El marshaling estándar no es la única opción. Un objeto puede implementar `IMarshal` y decidir por su cuenta cómo se empaqueta una referencia a sí mismo (*custom marshaling*). Para el analista, esto significa que el proxy que aparece del otro lado puede no ser el estándar: puede ser un objeto escrito por el autor del componente, con su propio protocolo.

El caso más común es el **free-threaded marshaler** (FTM), que se obtiene con `CoCreateFreeThreadedMarshaler` y se **agrega** al objeto (ver "Agregación y *tear-offs*", más abajo). Cuando alguien marshalea una interfaz de ese objeto, el FTM mira el contexto de destino:

- si el destino es **otro apartamento del mismo proceso** (`MSHCTX_INPROC`), copia el puntero real: el otro apartamento recibe un **puntero directo**, sin proxy;
- si el destino es **otro proceso u otro equipo**, delega en el marshaling estándar: ahí **sí** hay proxy y stub.

Tres límites que conviene escribir en el informe:

1. El FTM **no elimina** el marshaling entre procesos; solo evita el proxy dentro del proceso.
2. Al eliminar el proxy, también elimina la sincronización que el apartamento le daba al objeto: **el objeto tiene que manejar su propia concurrencia**. Microsoft lo describe como una violación calculada de las reglas de COM, con riesgo de comportamiento indefinido si el objeto guarda punteros directos a objetos que no usan el FTM o referencias a proxies de otros apartamentos.
3. En código nuevo (Windows 8.1+), Microsoft recomienda `RoGetAgileReference` en lugar del FTM.

Señales en un binario: una llamada a `CoCreateFreeThreadedMarshaler` en la construcción del objeto y un `QueryInterface` que responde a `IID_IMarshal` delegando en otro objeto. Si las ves, "no hay proxy entre

apartamentos" deja de ser una anomalía y pasa a ser el comportamiento esperado; lo que hay que revisar es si el objeto se sincroniza bien.

## Reglas de `QueryInterface` que podés usar como evidencia

Microsoft fija tres reglas para implementar `QueryInterface`:

- **Identidad**: para un mismo objeto, `QueryInterface(IID_IUnknown)` devuelve **siempre el mismo valor de puntero**. Por eso, para saber si dos interfaces pertenecen al mismo objeto, se comparan los resultados de pedir `IID_IUnknown` a cada una, no los punteros de interfaz originales (que suelen diferir).
- **Conjunto estático**: si un IID devolvió `S_OK` una vez, no puede devolver `E_NOINTERFACE` después en el mismo objeto, y viceversa.
- **Reflexiva, simétrica y transitiva**: desde cualquier interfaz se puede pedir la misma interfaz, volver a la anterior y llegar a cualquier otra que el objeto ofrezca.

Uso en reversing: si observás un objeto que ofrece un IID "a veces", o dos `IUnknown` distintos para lo que creías un solo objeto, no es una curiosidad. Puede ser un bug del componente, que en realidad son objetos distintos o que estás mirando un proxy. Registralo y explicá cuál hipótesis sostenés y con qué evidencia.

## Agregación y *tear-offs*: un objeto, varias implementaciones

La regla de identidad habla del **objeto COM**, no de una clase C++. Dos técnicas hacen que un objeto COM esté formado por varias piezas de código, y las dos se ven raras si no las conocés.

**Agregación.** Un objeto **externo** expone interfaces de un objeto **interno** como si fueran propias. Para que la identidad se mantenga:

- al crear el interno, el externo pasa su propio `IUnknown` como `pUnkOuter` en `CoCreateInstance` y **debe pedir** `IID_IUnknown`; si pide otra interfaz, la creación falla (un objeto que no admite agregación devuelve `CLASS_E_NOAGGREGATION`);
- el interno tiene **dos** `IUnknown`: uno propio (*no delegante*), que controla su vida y que solo conoce el externo, y el de sus demás interfaces, que **delega** `QueryInterface`, `AddRef` y `Release` en el `IUnknown` **controlador** del externo;
- el cliente siempre ve un solo objeto: pedir `IID_IUnknown` desde cualquier interfaz devuelve el `IUnknown` del externo.

Cómo se ve en un binario: un `CoCreateInstance` (o un constructor) que recibe un `pUnkOuter` no nulo junto con `IID_IUnknown`, y métodos `QueryInterface` / `AddRef` / `Release` que solo hacen un salto indirecto a través de un puntero guardado (el controlador). Si seguís la vtable de una interfaz agregada, sus primeros tres slots apuntan a código del **interno** que solo reenvía al controlador del **externo**, y el resto, a la implementación del interno, que puede estar en otra DLL.

**Tear-offs.** Algunas bibliotecas (ATL, por ejemplo, con `COM_INTERFACE_ENTRY_TEAR_OFF`) crean la implementación de una interfaz poco usada **recién cuando alguien la pide**, como un objeto auxiliar que delega `IUnknown` en el principal. Consecuencias: dos `QueryInterface` del mismo IID pueden devolver **punteros de interfaz distintos** (dos tear-offs), sin violar la identidad, porque ambos devuelven el mismo `IUnknown`; y la memoria de esa interfaz puede no existir antes del primer pedido.

Para el informe: si los punteros de interfaz difieren pero `IID_IUnknown` coincide, anotá "compatible con agregación o tear-off" y buscá el patrón de delegación antes de afirmar cuál es.

## Monikers y la tabla de objetos en ejecución (ROT)

Un **moniker** es un objeto (interfaz `IMoniker`) que **nombra** a otro objeto y sabe cómo obtenerlo: a eso se le llama *binding*. Hay monikers de archivo, de ítem, de clase, compuestos y otros; OLE los usa para conectar y activar objetos en el mismo equipo o en la red, por ejemplo en los vínculos de documentos compuestos.

La **ROT** (*Running Object Table*, interfaz `IRunningObjectTable`, obtenida con `GetRunningObjectTable`) es una tabla por estación de trabajo con pares (moniker, objeto en ejecución). Cuando un cliente resuelve un moniker, se consulta la ROT para conectarse a la instancia que ya corre en vez de crear otra. Un objeto se **registra** en la ROT al cargarse y debe **revocar** su registro al terminar.

Qué aporta al análisis:

- Un cliente que obtiene un objeto con `CoGetObject`, `BindMoniker` / `IMoniker::BindToObject` o consultando la ROT **no** pasa necesariamente por `CoCreateInstance`: si buscás solo activaciones, te lo perdés.
- Un servidor que llama a `IRunningObjectTable::Register` está publicando un objeto para que otros procesos lo encuentren por nombre. Anotá qué moniker usa y con qué flags; es parte de su superficie.
- Enumerar la ROT (`EnumRunning`) es una operación de lectura; conectarse a un objeto encontrado ahí **no** lo es, porque ejecuta código del servidor. En la práctica de esta lección solo se anota lo que el **binario propio** registra o consulta.

> **Recuadro conceptual: COM+**
>
> COM+ (Component Services) agrupa componentes COM en **aplicaciones COM+** que se administran como una unidad: alcance de despliegue, configuración y seguridad común, atributos que el autor del componente no escribió (transacciones, sincronización), y procesos anfitriones administrados (`DllHost.exe`) que cargan las DLL bajo demanda. Su configuración vive en un **catálogo** propio, no solo en las claves de 2D.7. Si en un análisis ves un `DllHost.exe` con una DLL de componente o referencias a contextos COM+, sabé que existe esta capa; esta lección **no** la desarrolla y no conviene sacar conclusiones de seguridad sin consultar la configuración del catálogo.

## IID, orden de métodos, slot y convención de llamada

El **slot** de vtable se deduce así: `slot = offset / tamaño_de_puntero`. El nombre del método **no** sale del offset; sale de combinar cuatro datos:

1. **IID** usado para obtener el puntero (lo ves como argumento de `QueryInterface` o `CoCreateInstance`).
2. **Definición de la interfaz** (IDL, header, type library o PDB) con el **orden** de los métodos, incluida la herencia (`IUnknown` aporta los slots 0–2).
3. **Arquitectura**: 4 bytes por slot en x86, 8 bytes en x64.

4. **Convención de llamada**: en x86, los métodos COM usan `__stdcall` y `this` va en la pila como primer argumento; en x64 hay una sola convención y `this` viaja en `RCX`, seguido de `RDX`, `R8` y `R9`.

| Slot | Método ( `IStatus : IUnknown` ) | Offset x86 | Offset x64 |
|---|---|---|---|
| 0 | `QueryInterface` | `+0x00` | `+0x00` |
| 1 | `AddRef` | `+0x04` | `+0x08` |
| 2 | `Release` | `+0x08` | `+0x10` |
| 3 | `GetState` | `+0x0C` | `+0x18` |

Un `call [rax+18h]` en x64 es "slot 3"; solo es `IStatus::GetState` si el puntero vino de un `QueryInterface` / `CoCreateInstance` con `IID_IStatus` (o de una interfaz que deriva de ella) **y** la definición confirma el orden.

## Ejemplo trabajado (x64, MSVC)

*(Ejemplo ilustrativo de un componente propio `BlocStatus` compilado para **x64**. Las instrucciones muestran el patrón que genera MSVC para llamadas COM; las posiciones de pila y los resultados no son una captura de un binario real.)*

Contrato, tal como lo declararía el IDL propio:

```
interface IStatus : IUnknown        // IID_IStatus
{
    HRESULT GetState([out] ULONG* state);   // slot 3
};
```

Llamadas del cliente, en el orden que se ve en el desensamblado. Primero, inicialización y creación:

```
; hilo cliente
xor   ecx, ecx                  ; pvReserved = NULL
mov   edx, 2                    ; COINIT_APARTMENTTHREADED  -> hilo STA
call  CoInitializeEx            ; anotar HRESULT en eax

lea   rcx, CLSID_BlocStatus     ; rclsid
xor   edx, edx                  ; pUnkOuter = NULL
mov   r8d, 1                    ; CLSCTX_INPROC_SERVER
lea   r9,  IID_IStatus          ; riid
lea   rax, [rsp+40h]
mov   [rsp+20h], rax            ; ppv (5.° argumento, en la pila tras el shadow space)
call  CoCreateInstance
```

Después, las llamadas a través de la vtable y el cierre:

```
mov   rcx, [rsp+40h]              ; this = p (IStatus*)
mov   rax, [rcx]                  ; rax = vptr
lea   rdx, [rsp+48h]              ; &state
call  qword ptr [rax+18h]         ; slot 3 = 0x18 / 8 -> IStatus::GetState

mov   rcx, [rsp+40h]
mov   rax, [rcx]
lea   rdx, IID_IResettable
lea   r8,  [rsp+50h]
call  qword ptr [rax]             ; slot 0 -> QueryInterface

mov   rcx, [rsp+40h]
mov   rax, [rcx]
call  qword ptr [rax+10h]         ; slot 2 -> Release

call  CoUninitialize              ; equilibra el CoInitializeEx anterior
```

Ficha de lectura, separando qué sale del código y qué se infiere:

| Dato | Fuente | Tipo |
|---|---|---|
| El hilo pide STA (`2` = `COINIT_APARTMENTTHREADED`). | Constante en `EDX` + definición del enum. | Observable en el binario. |
| `[rax+18h]` es el slot 3. | Aritmética x64: `0x18 / 8`. | Observable. |
| El slot 3 es `GetState`. | IID pasado en `R9` + IDL propio. | Inferencia respaldada por el contrato. |
| `E_NOINTERFACE` para `IID_IResettable`. | Valor de `EAX` tras la llamada al slot 0. | Se obtiene **solo** ejecutando en el laboratorio; acá es ilustrativo. |
| `p` apunta directo a la implementación. | Vtable dentro de `BlocCom.dll`, servidor in-proc compatible con STA. | Inferencia; se confirma resolviendo el módulo de la vtable. |

Variante x86, para contraste: el mismo `GetState` se vería como `push` de `&state`, `push` de `p` (el `this`), `mov eax,[p]` y `call [eax+0Ch]`, porque cada slot ocupa 4 bytes y `__stdcall` pasa `this` en la pila. No mezcles las dos tablas al leer un binario.

## Práctica

Con un componente COM **propio** o un binario didáctico ya incluido en una VM:

1. Anotá la arquitectura del cliente (x86/x64), CLSID e IIDs documentados, y cuál interfaz obtiene el cliente.
2. Ubicá `CoInitializeEx` en cada hilo que use COM: flag pasado, HRESULT y dónde está el `CoUninitialize` correspondiente. Si no lo encontrás, decilo.
3. En el depurador, seguí una llamada a `QueryInterface`; registrá IID solicitado, HRESULT y destino de retorno.
4. Identificá la dirección de la vtable, el **módulo** al que pertenece y si el puntero es directo o un proxy. Relacioná un método con su prototipo usando la tabla slot/offset de tu arquitectura. No invoques métodos desconocidos.

5. Pedí `IID_IUnknown` desde dos interfaces del mismo objeto y compará los punteros (regla de identidad). Si los punteros de interfaz difieren, buscá el patrón de agregación o tear-off.
6. Buscá en el binario `CoCreateFreeThreadedMarshaler`, respuestas a `IID_IMarshal`, `pUnkOuter` no nulos y llamadas a la ROT. Anotá cada hallazgo como observación y su consecuencia como inferencia.
7. Dibujá el ciclo de referencias: creación, consultas, `AddRef` / `Release` y liberación final. Si no hay símbolos, marcá las inferencias.

## Entregable

Diagrama cliente → (proxy/stub si corresponde) → interfaz → implementación; tabla CLSID/IID/HRESULT; tabla slot/offset/método con la arquitectura declarada; apartamento de cada hilo y evidencia de una llamada. Separá lo observado de lo inferido; no afirmes reference count exacto si el binario no lo expone.

## Repaso

▼ **¿CLSID e IID significan lo mismo?**

> No. CLSID identifica la clase; IID, una interfaz/contrato que el objeto puede ofrecer.

▼ **¿Qué comunica `E_NOINTERFACE`?**

> Que el objeto consultado no implementa el IID solicitado; no prueba que la clase COM no exista.

▼ **¿Por qué una vtable no basta para nombrar métodos?**

> Los slots solo son direcciones. Hace falta el IID, el contrato con su orden, la arquitectura (tamaño de slot) y la convención de llamada para asociarlos con nombres y prototipos.

▼ **En x64, ¿qué slot es `call [rax+18h]` y dónde estaría ese mismo slot en x86?**

> Slot 3 (`0x18 / 8`). En x86 el slot 3 está en `+0x0C` (`3 × 4`).

▼ **¿Qué riesgo hay después de `Release`?**

> Si se liberó la última referencia, el objeto pudo destruirse; reutilizar el puntero sería usar una referencia inválida.

▼ **`CoInitializeEx` devuelve `S_FALSE`. ¿Hace falta `CoUninitialize`?**

> Sí. `S_FALSE` es éxito (COM ya estaba inicializado en ese hilo) y debe equilibrarse igual. `RPC_E_CHANGED_MODE`, en cambio, es fallo y no se equilibra.

▼ **¿Por qué un hilo STA que espera con `WaitForSingleObject` puede colgar una llamada COM?**

> Porque las llamadas entrantes a objetos de una STA se entregan por la cola de mensajes de ese hilo; si no bombea mensajes, nunca llegan.

▼ **¿Cómo comprobás que dos punteros de interfaz pertenecen al mismo objeto?**

> Pidiendo `IID_IUnknown` a cada uno y comparando los resultados: la regla de identidad exige el mismo valor.

▼ **Un breakpoint en la entrada de vtable cae en código del runtime COM/RPC y no en tu DLL. ¿Qué estás viendo?**

> Probablemente un proxy: la llamada se empaqueta y la implementación corre en otro apartamento o proceso.

▼ **Un objeto agrega el free-threaded marshaler. ¿Hay proxy cuando se pasa a otro apartamento del mismo proceso? ¿Y a otro proceso?**

> Dentro del proceso, no: el otro apartamento recibe el puntero directo y el objeto debe sincronizarse solo. Hacia otro proceso, sí: el FTM delega en el marshaling estándar.

▼ **Dos `QueryInterface` del mismo IID devuelven punteros distintos, pero `IID_IUnknown` coincide. ¿Se rompió la identidad?**

> No necesariamente. Es compatible con tear-offs o agregación; la identidad se juzga por el `IUnknown`, no por cada puntero de interfaz.

▼ **¿Por qué al crear un objeto agregado hay que pedir `IID_IUnknown`?**

> Porque el externo necesita el `IUnknown` no delegante del interno para controlar su vida; las demás interfaces del interno delegan en el externo.

▼ **¿Por qué buscar solo `CoCreateInstance` puede no alcanzar para encontrar cómo un cliente obtiene un objeto?**

> Porque puede obtenerlo resolviendo un moniker o consultando la ROT, que conecta con una instancia ya en ejecución.

**Puerta optativa**

Podés distinguir CLSID/IID, interpretar HRESULT (incluidos los de `CoInitializeEx`), explicar qué cambia entre STA y MTA, reconocer un proxy por el módulo de su vtable, explicar cuándo el free-threaded marshaler evita un proxy y cuándo no, reconocer agregación y tear-offs sin confundirlos con una violación de identidad, aplicar la regla de identidad y nombrar un slot de vtable con el contrato y la arquitectura correctos.

**Lo que queda fuera**

La implementación de `IMarshal` propio, el formato de una referencia marshaleada (OBJREF), el detalle interno de los proxies estándar, los contextos COM+ y el catálogo COM+ (solo como recuadro), la escritura de monikers propios y WinRT no se desarrollan. El apartamento neutral solo se menciona. La lección prepara para leer evidencia COM; no es una cobertura completa de COM.

## Fuentes

- Microsoft Learn: IUnknown, QueryInterface, reglas de QueryInterface, vida y reference counting, HRESULT.
- Microsoft Learn, hilos y apartamentos: Initializing the COM Library, CoInitializeEx, Processes, Threads, and Apartments, Accessing Interfaces Across Apartments.
- Microsoft Learn, proxies y convención: Proxy, ProxyStubClsid32, x64 calling convention.
- Microsoft Learn, marshaling a medida y composición: In-Process Server Threading Issues, CoCreateFreeThreadedMarshaler, IMarshal, Aggregation, ATL COM_INTERFACE_ENTRY macros (tear-offs).
- Microsoft Learn, monikers y COM+: Monikers, IRunningObjectTable, COM+ Application Overview.
- **Fundamentos previos:** complemento externo a la ruta de C++ y vtables de 2.18.

**Etiquetas**

**Núcleo conceptual:** conceptos generales de C++ y vtables. **Conocimiento externo:** COM, apartamentos, marshaling estándar y a medida, free-threaded marshaler, agregación, tear-offs, monikers/ROT, COM+ (recuadro), reglas de `QueryInterface` y convención x64. **Ejemplo ilustrativo:** desensamblado y resultados de `BlocStatus` (patrón MSVC x64, no capturado de un binario). **Laboratorio verificado:** no; usar solo un componente propio/didáctico.

# COM: registro, activación y configuración

> **Rama optativa 2D**
>
> El ejercicio inspecciona una clase propia o una instalación conocida. No cambia el registro de componentes ajenos, no ejecuta `DllRegisterServer` / `regsvr32` sobre binarios que no son tuyos y no configura activación automática.

> **Propósito**
>
> Reconstruir cómo COM pasa de un CLSID a un servidor local o dentro del proceso y cómo usar metadatos para confirmar el contrato. El objetivo es poder responder, con evidencia, **qué archivo** atiende una clase, **en qué proceso y apartamento** corre y **por qué** fue ese y no otro.

**Prerrequisitos**

- *Obligatorios:* 2D.3 Registro, 2D.6 COM.
- *Recomendados:* PE e imports (1.4); ACL y token (2D.1).

## El recorrido de una activación

La activación parte de una solicitud de clase y contexto. Con `CoCreateInstance(rclsid, pUnkOuter, dwClsContext, riid, ppv)` el cliente dice **qué clase** quiere, **qué tipos de servidor acepta** (`CLSCTX_INPROC_SERVER`, `CLSCTX_LOCAL_SERVER`, `CLSCTX_REMOTE_SERVER`, combinables) y **qué interfaz** espera recibir. Conceptualmente, la cadena es:

1. **CLSID + contexto de activación.** Si el hilo tiene un *activation context* activo (manifiesto), COM busca primero ahí qué DLL aloja el CLSID. Si no lo encuentra, usa el registro.
2. **Registro efectivo.** `HKEY_CLASSES_ROOT` es una vista combinada de `HKLM\Software\Classes` (máquina) y `HKCU\Software\Classes` (usuario); para una misma subclave, la entrada del usuario tiene prioridad. Además, la vista de 32 o 64 bits del proceso cambia qué subárbol se lee (ver más abajo).
3. **Servidor.** Según `dwClsContext` y lo registrado, COM elige un servidor en proceso (`InprocServer32`), uno local (`LocalServer32`, o un servicio vía `LocalService` del AppID) o uno remoto (2D.8).
4. **Class factory.** COM obtiene el *class object* de la clase: en una DLL, llamando a su export `DllGetClassObject`; en un EXE, esperando a que el servidor registre su class object al arrancar. Ese objeto implementa normalmente `IClassFactory`.
5. **Instancia e interfaz.** `IClassFactory::CreateInstance` crea el objeto y devuelve la interfaz pedida por `riid`. Si el servidor está en otro apartamento o proceso, el cliente recibe un **proxy** (2D.6).

`CoCreateInstance` equivale a `CoGetClassObject` + `IClassFactory::CreateInstance` + liberar la factory. En un binario podés ver cualquiera de las dos formas.

## `InprocServer32` y `LocalServer32`

| | `InprocServer32` | `LocalServer32` |
|---|---|---|
| Qué señala | Ruta de una **DLL** que se carga **en el proceso cliente**. | Línea de comando de un **EXE** que corre en **otro proceso**. |
| Cómo entrega la factory | Export `DllGetClassObject`. | El EXE registra su class object al arrancar; si no lo hace a tiempo (por defecto, 60 s), la activación expira. |
| Arquitectura | La DLL debe coincidir con la del cliente (un proceso x64 no carga una DLL x86). | Puede tener otra arquitectura; las llamadas viajan por proxy/stub. |
| Detalles útiles | Declara `ThreadingModel`. | COM agrega `-Embedding` a la línea de comando. El valor `ServerExecutable` evita ambigüedad de ruta. Si el AppID define `LocalService`, se usa el servicio y `LocalServer32` se ignora. |
| Riesgo de lectura | Una ruta sin comillas o relativa es ambigua; verificá qué archivo se resolvería. | Igual; la documentación advierte sobre rutas sin comillas en `CreateProcess`. |

Una DLL también puede correr fuera de proceso dentro de un **surrogate** si su AppID define `DllSurrogate`. Por eso "es una DLL" no implica automáticamente "corre dentro del cliente".

La ubicación por sí sola no determina si algo es confiable: verificá ruta, firma, propietario, permisos de la carpeta y compatibilidad de arquitectura.

## `ThreadingModel`: valores y límites

Solo aplica a servidores **en proceso**. Declara en qué apartamento (2D.6) puede vivir el objeto; COM lo usa para decidir dónde crearlo.

| Valor | Apartamento declarado | Si el cliente está en un apartamento incompatible |
|---|---|---|
| *(ausente)* | Solo el **STA principal** (el primero inicializado). | Se crea en el STA principal y el cliente recibe un proxy. |
| `Apartment` | STA. | Si el cliente está en la MTA, COM crea o usa un **host STA**; el cliente recibe un proxy. |
| `Both` | STA o MTA. | Se crea en el mismo apartamento del cliente. |
| `Free` | MTA. | Si el cliente es STA, se crea en la MTA (o en una *host MTA* creada por COM); proxy. |
| `Neutral` | Apartamento neutral. | Se crea en el apartamento neutral. |

Límites que conviene escribir en el informe:

- Es una **declaración del autor**, no una prueba: `Both` o `Free` no demuestran que el código sea seguro entre hilos.

- Debe ser el mismo valor para todos los objetos de ese servidor.
- Explica **por qué aparece un proxy** aun en una activación in-proc: no siempre hay un salto de proceso detrás.

## Registro por usuario, por máquina y vistas de 32/64 bits

- **Usuario vs. máquina.** Un CLSID puede estar en `HKCU\Software\Classes\CLSID`, en `HKLM\Software\Classes\CLSID` o en ambos. La vista `HKCR` da prioridad al usuario. La documentación aclara que, si una aplicación corre con derechos de administrador y UAC deshabilitado, el runtime COM ignora la configuración por usuario. Un proceso que atiende a clientes distintos del usuario interactivo (un servicio, por ejemplo) necesita abrir explícitamente la vista de ese usuario con `RegOpenUserClassesRoot`.
- **WOW64.** En Windows 7 y posteriores de 64 bits, `HKLM\Software\Classes\CLSID`, `HKCU\Software\Classes\CLSID` e `...\Interface` están **redirigidas**: un proceso de 32 bits ve otra copia (bajo `Wow6432Node`). En cambio `...\Classes\AppID` está **compartida**, y `Wow6432Node\Typelib` es un enlace a la clave compartida. Consecuencia: el mismo CLSID puede resolver a archivos distintos según la arquitectura del cliente.

Antes de afirmar "el CLSID no está registrado", anotá **qué vista** consultaste (usuario/máquina, 32/64) y con qué herramienta. Regedit de 64 bits muestra `Wow6432Node` como una rama más; una API con `KEY_WOW64_32KEY` o `KEY_WOW64_64KEY` elige la vista explícitamente.

## AppID, TypeLib e IDL: qué prueba cada uno

| Metadato | Qué aporta | Qué **no** demuestra |
|---|---|---|
| **AppID** (`HKLM\Software\Classes\AppID\{GUID}`, enlazado desde el valor `AppID` del CLSID) | Configuración común de los objetos DCOM de un mismo ejecutable: `LaunchPermission`, `AccessPermission`, `RunAs`, `LocalService`, `DllSurrogate`, `AuthenticationLevel`, `RemoteServerName`, entre otros. | Que esos valores sean los efectivos: si el proceso llama a `CoInitializeSecurity`, sus parámetros reemplazan a los del registro (2D.8). Tampoco prueba que la clase se active remotamente. |
| **TypeLib** (`.tlb` o recurso dentro de la DLL; referenciada por `TypeLib` o por `tlbid`) | Descripción binaria de interfaces, métodos, parámetros y tipos; base del marshaling de automatización. | Que la implementación cumpla el contrato, que todos los métodos estén implementados o que no haya métodos no documentados. |
| **IDL** (fuente que MIDL compila a headers, typelib y código proxy/stub) | El contrato tal como lo escribió el autor: herencia, orden de métodos, atributos `[in]` / `[out]`. | Que el binario distribuido se haya compilado de **ese** IDL o de esa versión. |
| `Interface\{IID}` con `ProxyStubClsid32` | Qué proxy/stub se usa para marshalear ese IID. | Qué objeto implementa la interfaz. |

Regla práctica: los metadatos te dan **hipótesis de nombres y contratos**; la implementación y la ejecución en laboratorio las confirman o las refutan.

## Activación sin registro (registration-free COM)

Una aplicación puede declarar sus clases COM en un **manifiesto** en lugar del registro. En un manifiesto de ensamblado, el elemento `file` (la DLL) contiene uno o más `comClass` con atributos como `clsid`, `threadingModel`, `progid` y `tlbid`, y puede incluir `typelib` y `comInterfaceProxyStub`. Cuando el hilo tiene ese **contexto de activación** activo, `CoCreateInstance` y `CLSIDFromProgID` lo consultan **antes** que el registro; si el contexto no contiene la información, COM recurre al registro como siempre. Los contextos de activación son por hilo, y COM los propaga al hilo anfitrión al cargar la DLL.

Para el análisis, esto significa que **una búsqueda en el registro puede dar vacío y la activación igual funcionar**. Dónde mirar, en modo lectura:

- manifiesto de aplicación embebido como recurso del EXE o archivo `.manifest` junto al ejecutable;
- manifiestos de ensamblados privados (archivo junto a la DLL o recurso de la DLL);
- llamadas a las APIs de contextos de activación en el cliente.

## Ejemplo trabajado: observación frente a inferencia

*(Ejemplo **ilustrativo**: rutas ficticias de un componente propio; las cadenas entre llaves son marcadores didácticos, no GUID utilizables. No es salida de una VM.)*

```
Cliente: BlocCliente.exe (PE32+, x64)
Llamada vista en el desensamblado:
  CoCreateInstance(CLSID {A...1}, NULL, CLSCTX_INPROC_SERVER|CLSCTX_LOCAL_SERVER, IID {D...4}, &p)

Vista 64 bits:
  HKCU\Software\Classes\CLSID\{A...1}   (no existe)
  HKLM\Software\Classes\CLSID\{A...1}
    AppID           {B...2}
    InprocServer32  (Default)       C:\ReversingLab\x64\BlocCom.dll
                    ThreadingModel  Both
    TypeLib         {C...3}
HKLM\Software\Classes\AppID\{B...2}
    (sin LaunchPermission / AccessPermission / RunAs)
Vista 32 bits (Wow6432Node):
  HKLM\Software\Classes\Wow6432Node\CLSID\{A...1}
    LocalServer32   "C:\ReversingLab\x86\BlocSrv.exe"
Manifiesto de BlocCliente.exe: sin comClass
```

| Afirmación | Tipo | Por qué |
|---|---|---|
| El cliente acepta servidor in-proc **o** local. | Observación | Flags de `dwClsContext` en el código. |
| En la vista de 64 bits, el CLSID resuelve a `BlocCom.dll` (x64). | Observación | Clave leída en esa vista. |
| No hay registro por usuario ni registro sin manifiesto que lo pise. | Observación | `HKCU` vacío y manifiesto sin `comClass`. |
| Un cliente **x86** del mismo CLSID terminaría en `BlocSrv.exe`, fuera de proceso. | Inferencia | Depende de la vista de 32 bits; habría que confirmarlo con un cliente x86. |
| Como el servidor x64 es `Both`, el objeto se crea en el apartamento del cliente y no hay proxy. | Inferencia | Se confirma resolviendo el módulo de la vtable (2D.6). |
| El AppID no define permisos propios, así que regirían los valores por defecto del equipo. | Inferencia con límite | Solo si el servidor no llama a `CoInitializeSecurity`; además, para una activación in-proc los permisos de lanzamiento no intervienen. |
| La typelib `{C...3}` describe `IID {D...4}`. | Hipótesis | Falta abrir la typelib y comparar; tampoco probaría la implementación. |

## Práctica: trazado de solo lectura

1. Elegí un componente propio ya registrado o una aplicación de laboratorio conocida.
2. Anotá la arquitectura del cliente y los flags `CLSCTX_*` que usa. Si no los ves, decilo.
3. Revisá si el cliente tiene manifiesto con `comClass` (recurso o archivo). Registrá el resultado aunque sea "no tiene".
4. Seguí `CLSID → servidor → AppID → TypeLib` con Regedit en modo lectura, en la vista de **usuario y de máquina** y en la de **32 y 64 bits** que correspondan.
5. Anotá ruta, firma, arquitectura y `ThreadingModel` del servidor. No ejecutes un `DllRegisterServer` desconocido.
6. Clasificá cada dato como observación, inferencia o hipótesis, como en la tabla del ejemplo.
7. Si el componente de práctica no existe, analizá el ejemplo ilustrativo y declará que no verificaste activación en vivo.

## Entregable

Tabla de CLSID, contexto pedido, tipo de servidor, ruta, arquitectura, `ThreadingModel`, AppID y valores relevantes, typelib, vista de registro consultada, existencia de manifiesto y evidencias. Redactá anomalías como preguntas a investigar, no como diagnóstico automático.

## Repaso

▼ **¿Qué diferencia hay entre `InprocServer32` y `LocalServer32`?**

> El primero apunta a un servidor DLL cargado en el proceso cliente (debe coincidir en arquitectura); el segundo, a un servidor ejecutable fuera del proceso, que puede tener otra arquitectura y se comunica por proxy/stub.

▼ **¿Qué agrega `ThreadingModel`?**

> Declara el modelo de apartamento compatible para el servidor en proceso y determina dónde lo crea COM; no describe por sí solo toda la sincronización del código.

▼ **Un servidor in-proc tiene `ThreadingModel=Apartment` y el cliente está en la MTA. ¿Qué recibe el cliente?**

> Un proxy: COM crea el objeto en un host STA y marshalea las llamadas.

▼ **¿Qué aporta AppID?**

> Agrupa opciones/configuración de uno o varios objetos distribuidos (permisos, identidad, surrogate, servicio) y permite relacionar la clase con ajustes DCOM. No garantiza que sean los valores efectivos si el proceso llama a `CoInitializeSecurity`.

▼ **¿Un TLB demuestra el comportamiento interno?**

> No. Describe contratos y tipos; el comportamiento se confirma siguiendo la implementación.

▼ **Buscaste el CLSID en el registro y no aparece, pero la aplicación lo crea. ¿Qué dos explicaciones revisás primero?**

> Que estés mirando la vista equivocada (usuario/máquina o 32/64 bits) o que la clase se declare en un manifiesto y se resuelva por contexto de activación sin registro.

**Puerta optativa**

Podés seguir una activación desde CLSID hasta servidor y metadatos, distinguir servidor in-process/local, explicar el efecto de `ThreadingModel`, declarar la vista de registro consultada y reconocer cuándo el registro no alcanza por la existencia de un manifiesto.

**Lo que queda fuera**

Monikers, ROT, servidores de servicio en detalle, catálogo COM+ y la creación de manifiestos o de registros propios no se desarrollan. La lección enseña a **leer** una configuración, no a registrar componentes.

## Fuentes

- Microsoft Learn, activación: CoCreateInstance, CoGetClassObject, IClassFactory, DllGetClassObject, COM Clients and Servers.
- Microsoft Learn, registro: COM Registry Keys, InprocServer32, LocalServer32, AppID Key, Interface Key, Merged View of HKEY_CLASSES_ROOT, Registry Keys Affected by WOW64.
- Microsoft Learn, metadatos y sin registro: Generating a type library with MIDL, Creating Registration-Free COM Objects, Assembly Manifests, Activation Contexts.
- **Fundamentos previos:** Registro/WOW64 en 2D.3; COM base en 2D.6.

> **Etiquetas**
>
> **Núcleo conceptual:** registro y permisos tratados en 2D.3. **Conocimiento externo:** activación, `ThreadingModel`, vistas de registro, metadatos y COM sin registro. **Ejemplo ilustrativo:** claves, rutas y conclusiones del componente ficticio. **Laboratorio verificado:** no.

# DCOM y RPC: activación remota y límites de confianza

> **Laboratorio aislado**
>
> No habilites acceso remoto ni abras puertos para esta lección. No cambies DCOMCNFG, permisos, identidades, restricciones de equipo ni políticas. Usá dos VMs ya configuradas para un ejercicio autorizado; si la práctica requeriría debilitar una protección, limitate al análisis del diagrama y de la configuración existente.

> **Propósito**
>
> Entender DCOM como activación/llamada de objetos COM a través de RPC y separar identidad autenticada, autorización, permisos de lanzamiento/activación y permisos de acceso. Al terminar deberías poder leer un error de DCOM como **un dato con varias explicaciones posibles** y documentarlo sin proponer que se baje la seguridad.

**Prerrequisitos**

- *Obligatorios:* 2D.6 COM, 2D.7 activación, red básica (1.3).
- *Recomendados:* tokens e impersonación (2D.1); Windows Firewall y seguridad de cuenta; no exige completar toda 2D.

## Modelo

RPC permite invocar operaciones entre procesos locales o remotos. DCOM añade al modelo COM activación distribuida, proxies/stubs y negociación de seguridad. Una interfaz remota no se convierte en acceso libre por conocer su CLSID: intervienen autenticación, nivel de protección, identidad del servidor, permisos de lanzamiento/activación, permisos de acceso, firewall y políticas locales/dominio.

La autenticación de paquetes puede aportar integridad; privacidad agrega cifrado. Las actualizaciones de hardening DCOM elevaron requisitos de autenticación para activación. El detalle efectivo depende de la versión, actualizaciones y políticas administradas: documentá el estado, no copies recetas antiguas que bajan el nivel.

## Dos momentos distintos: activar y llamar

Conviene separar siempre dos operaciones, porque las controlan **permisos distintos** y fallan por **motivos distintos**.

**1. Activación remota.** El cliente pide un objeto en otro equipo (por ejemplo, `CoCreateInstanceEx` con un `COSERVERINFO`, o un `RemoteServerName` configurado en el AppID). El pedido llega al servicio de activación del equipo servidor, que:

- identifica al cliente (con el token de proceso o, si el cliente usa *cloaking*, el de hilo);

- comprueba los **permisos de lanzamiento y activación**: si el servidor no está corriendo, hace falta permiso para **lanzarlo**; si ya corre, permiso para **activar** un objeto en él;
- si corresponde, lanza el servidor con la **identidad** configurada (usuario que lanza, usuario interactivo, una cuenta concreta o un servicio);
- devuelve al cliente una referencia marshaleada, que en el cliente se convierte en un **proxy**.

**2. Llamada a un método.** Con el proxy ya en mano, cada llamada viaja por RPC al proceso servidor. Ahí se evalúan los **permisos de acceso** (quién puede llamar a un servidor que ya está corriendo), con el nivel de autenticación negociado, y el servidor puede **impersonar** al cliente dentro del nivel que el cliente permitió.

Consecuencia: un cliente puede **activar** con éxito y luego fallar en la **primera llamada**, o al revés. El informe tiene que decir en qué momento ocurrió el fallo.

## Cómo encuentra la llamada su destino: endpoints y puertos dinámicos

Muchos servidores RPC de Windows, entre ellos los servidores DCOM, no escuchan en un puerto fijo. Usan **endpoints dinámicos**: al arrancar, el servidor obtiene un puerto del rango dinámico y registra sus interfaces en el **mapeador de endpoints** (*Endpoint Mapper*, servicio RPCSS). El cliente primero pregunta al mapeador del equipo remoto —que en TCP escucha en el puerto **135**— dónde está la interfaz, y después se conecta al puerto que le devuelven. Desde Windows Vista y Server 2008, el rango dinámico predeterminado de TCP/IP es **49152–65535**, salvo que una política o configuración lo cambie.

En DCOM hay un detalle más: la referencia de interfaz que el servidor devuelve al activar contiene **direcciones IP del servidor** tal como él las ve. Microsoft advierte que por eso DCOM no funciona a través de firewalls que traducen direcciones (NAT).

Qué cambia para la evidencia:

- En el escenario típico, la activación usa el mapeador en el 135 y las llamadas posteriores van al **puerto dinámico** del proceso servidor. Un firewall que deja pasar el 135 pero no ese puerto produce exactamente el patrón "activa bien, falla la primera llamada", sin que haya un problema de **permisos**.
- Un `0x800706BA` (servidor RPC no disponible) puede venir del mapeador inaccesible, del puerto dinámico bloqueado, de una dirección no alcanzable dentro de la referencia o de un servidor que terminó.
- En el laboratorio, de solo lectura: el puerto y el PID que escuchan en la VM servidor (`netstat -ano`), las reglas de firewall existentes y la dirección que la VM cliente usó. No se abren puertos ni se fija un rango para que "funcione".

## Autenticación, autorización y permisos

- **Autenticación**: establece *quién* es el interlocutor (con NTLM, Kerberos u otro proveedor). No otorga nada por sí misma.
- **Autorización**: decide *qué puede hacer* esa identidad. En DCOM se expresa con listas de control de acceso.

Desde Windows XP SP2 / Server 2003 SP1, los derechos se separan por **distancia** (local o remoto):

| ACL | Derechos | Qué controla | Dónde vive |
|---|---|---|---|
| **Lanzamiento y activación** | Local Launch, Remote Launch, Local Activation, Remote Activation | Quién puede **arrancar** el servidor y quién puede **obtener** un objeto (un puntero de interfaz). | `LaunchPermission` del AppID; si no existe, `DefaultLaunchPermission`. |
| **Acceso** | Local Access, Remote Access | Quién puede **llamar** a un servidor que ya está en ejecución. | `AccessPermission` del AppID (solo si el proceso **no** llama a `CoInitializeSecurity`), el descriptor que pase `CoInitializeSecurity` o el valor por defecto del equipo. |
| **Restricciones de equipo** | Las mismas, como mínimo obligatorio | Un control adicional que se aplica a **todo** servidor COM del equipo, además del propio de cada aplicación. | `MachineLaunchRestriction` / `MachineAccessRestriction` o la política de grupo equivalente. |

Leé estas ACL como capas: una solicitud tiene que pasar **la restricción del equipo y** la de la aplicación. Que una ACL de aplicación sea permisiva no alcanza si la restricción del equipo lo impide, y viceversa.

## Nivel de autenticación frente a nivel de impersonación

Son dos perillas distintas que se negocian en el mismo "blanket" de seguridad:

| | Nivel de **autenticación** ( `RPC_C_AUTHN_LEVEL_*` ) | Nivel de **impersonación** ( `RPC_C_IMP_LEVEL_*` ) |
|---|---|---|
| Pregunta que responde | ¿Cuánta protección tiene la comunicación? | ¿Cuánto puede hacer el servidor **en nombre** del cliente? |
| Valores | None, Default, Connect, Call, Packet, Packet Integrity, Packet Privacy | Anonymous, Identify (el predeterminado del sistema), Impersonate, Delegate |
| Quién decide | Cliente y servidor proponen; en el handshake se usa **el más alto** de los dos. | Lo fija el **cliente** en su proxy. |
| Matices documentados | La mayoría de los proveedores promueve Call a Packet; Default nunca elige None. | Anonymous solo funciona en transporte local (en otros se promueve a Identify); Delegate requiere configuración de dominio específica. |

Un nivel de autenticación alto no autoriza más operaciones, y un nivel de impersonación bajo no debilita el cifrado: son ejes independientes.

## Servicio de autenticación: Kerberos, NTLM, Negotiate y el SPN

El *security blanket* —el conjunto de valores de seguridad que COM negocia para cada proxy— incluye, además de los niveles de la sección anterior, el **servicio de autenticación**: el paquete que de verdad autentica. Los más comunes en DCOM son **NTLM** ( `RPC_C_AUTHN_WINNT` ), **Kerberos** ( `RPC_C_AUTHN_GSS_KERBEROS` ) y **Negotiate/Snego** ( `RPC_C_AUTHN_GSS_NEGOTIATE` ), que no autentica por sí mismo sino que elige, entre los paquetes que admiten cliente y servidor, uno que funcione para ambos.

Qué paquete termina usándose **depende del contexto y de la configuración**: las listas que cada lado declaró (explícitamente con `CoInitializeSecurity` / `CoSetProxyBlanket` o por defecto), si los equipos y cuentas están en un dominio y se confían, el nombre con el que el cliente llegó al servidor, la existencia del SPN correcto y las políticas que restringen paquetes. No hay una regla universal del tipo "primero Kerberos y si no, NTLM" que puedas aplicar sin mirar esa configuración.

El **SPN** (*Service Principal Name*) es el identificador único de una instancia de servicio que Kerberos usa para asociarla con la cuenta con la que esa instancia inicia sesión. El SPN se registra en el objeto de esa cuenta en Active Directory, un mismo SPN puede estar en **una sola** cuenta, y si la cuenta del servicio cambia, los SPN deben registrarse de nuevo. El cliente **compone** el SPN a partir del nombre con el que localizó el servicio y lo presenta al autenticar; por eso, con Kerberos, el nombre de principal del servidor tiene que ser el correcto o la llamada falla.

Para la evidencia:

- Anotá **con qué nombre** se llegó al servidor (nombre corto, FQDN, alias o IP), **con qué cuenta** corre el servidor y si el binario fija un servicio de autenticación o un nombre de principal en `CoInitializeSecurity` / `CoSetProxyBlanket`.
- Si el código usa Negotiate, `CoQueryProxyBlanket` informa **Negotiate** y no el paquete que eligió: no deduzcas "Kerberos" o "NTLM" de esa consulta.
- Si había auditoría de inicio de sesión habilitada en el servidor, el registro de seguridad suele indicar el paquete usado; si no la había, decí que no se pudo determinar.

> **Recuadro conceptual: delegación de Kerberos**
>
> El nivel de impersonación **Delegate** permite que el servidor use la identidad del cliente hacia **otros** equipos, y solo funciona con Kerberos y configuración de dominio específica. Microsoft distingue, a grandes rasgos, tres modalidades: **sin restricciones** (la cuenta del servidor puede delegar hacia cualquier servicio), **restringida** (la cuenta del servidor solo puede delegar hacia una lista de servicios; se configura sobre la cuenta del servicio de entrada) y **restringida basada en recursos** (la decide el dueño del servicio de destino, sobre la cuenta de ese recurso). Señales que vale la pena **revisar**, sin cambiarlas: código que pide `RPC_C_IMP_LEVEL_DELEGATE`, cuentas de servicio marcadas como confiables para delegación, servicios con listas de delegación o con delegación basada en recursos, y cuentas sensibles que deberían estar marcadas como "no delegables". Esta lección no enseña a configurar ni a probar delegación: el inventario lo hace o lo autoriza quien administra el directorio.

## `CoInitializeSecurity` y `CoSetProxyBlanket`

- `CoInitializeSecurity` fija la seguridad **por proceso**: nivel de autenticación, nivel de impersonación, servicios de autenticación y, del lado servidor, quién puede acceder. Si el proceso la llama, **se ignoran** los valores de seguridad del registro para ese proceso (salvo que se le pase un AppID, en cuyo caso usa solo el registro). Algunas opciones, como cambiar el nivel de impersonación por defecto del proceso, solo se pueden fijar así.
- `CoSetProxyBlanket` ajusta la seguridad de **un proxy concreto** (una interfaz remota), sobrescribiendo los valores del proceso para las llamadas por ese proxy. Internamente equivale a pedir `IClientSecurity` al proxy y llamar a `SetBlanket`.

Para el análisis: si ves `CoInitializeSecurity` en el binario, lo que diga DCOMCNFG sobre **acceso** de esa aplicación puede no ser lo efectivo. Si ves `CoSetProxyBlanket`, el nivel usado en esa interfaz puede diferir del resto. Registrá los argumentos constantes que veas y marcá como inferencia los que dependen de valores en tiempo de ejecución.

## Ejemplo trabajado

*(Diagrama hipotético, sin tráfico capturado ni HRESULT observado.)*

```
VM-Cliente: CoCreateInstanceEx(CLSID propio, servidor VM-Servicio)
  -> [ACTIVACIÓN] RPC hacia el servicio de activación de VM-Servicio
VM-Servicio: autentica al cliente
  -> restricción de equipo (launch/activation)  ¿pasa?
  -> LaunchPermission del AppID (o el valor por defecto)  ¿pasa?
  -> lanza BlocSrv.exe con la identidad configurada (si no estaba en ejecución)
  -> devuelve referencia marshaleada -> proxy para IID_IStatus en VM-Cliente
```

```
VM-Cliente: p->GetState(&state)
  -> [LLAMADA] RPC al proceso BlocSrv.exe, con el nivel de autenticación negociado
VM-Servicio: restricción de equipo (access) + permisos de acceso del proceso  ¿pasa?
  -> stub -> BlocStatus::GetState; respuesta HRESULT + estructura de estado
```

Si la activación falla, las causas pueden estar en identidad, permisos, endpoint, DNS/red o hardening. Un error aislado no identifica cuál. El análisis correcto conserva HRESULT, evento y contexto y compara con la documentación de la versión.

### Cómo documentar un error sin atribuirle una causa única

| Dato | Ejemplo de registro | Por qué importa |
|---|---|---|
| Versión y build de **ambos** equipos | Edición, número de build, actualizaciones instaladas | El hardening DCOM cambió con actualizaciones; el mismo código puede comportarse distinto. |
| Momento del fallo | ¿Activación o llamada? ¿Primera llamada o posterior? | Separa permisos de lanzamiento/activación de permisos de acceso. |
| HRESULT exacto | Valor hexadecimal, no solo "acceso denegado" | `0x80070005` (`E_ACCESSDENIED`) puede venir de lanzamiento, activación o acceso; `0x800706BA` (servidor RPC no disponible) puede ser red, nombre, endpoint o firewall; `0x80080005` (`CO_E_SERVER_EXEC_FAILURE`) puede ser identidad, ruta o un fallo propio del servidor. |
| Identidades | Cuenta del cliente, identidad configurada del servidor | Distingue quién pidió de quién ejecuta. |
| Red y nombre | Nombre usado para llegar al servidor, puerto y PID que escuchan, reglas de firewall existentes | Separa fallos de transporte (mapeador, puerto dinámico, NAT) de fallos de autorización. |
| Autenticación | Servicio pedido en código (si es constante), paquete observado en auditoría (si existía), SPN esperado | Evita suponer Kerberos o NTLM sin evidencia. |
| Configuración leída (sin cambiarla) | AppID, `LaunchPermission` / `AccessPermission` presentes o ausentes, si el binario llama a `CoInitializeSecurity` | Indica qué capa podría estar decidiendo. |
| Eventos | Entradas de origen DCOM en el registro *System* de **ambos** equipos, con fecha y hora | Suelen nombrar CLSID/AppID y la identidad, pero no siempre la capa exacta. |
| Hipótesis y descartes | "Compatible con X; no descartado Y porque…" | Evita que el informe convierta una correlación en causa. |

## Práctica

Solo con dos VMs en una red virtual host-only, ya provistas y aprobadas por quien administra el laboratorio:

1. Revisá sin modificar DCOM Config (identidad del servidor, permisos de lanzamiento/acceso, autenticación), las restricciones de equipo y el firewall. Anotá versión/build de ambas VMs.
2. En el binario cliente y servidor, buscá llamadas a `CoInitializeSecurity` y `CoSetProxyBlanket` y registrá los niveles constantes que veas.
3. Si hay un componente propio de prueba ya preparado, registrá una llamada inocua de consulta, separando el resultado de la **activación** y el de la **llamada**, y la identidad visible en ambos lados.

4. Si no está preparado o la activación requiere cambiar la seguridad, no la habilites: reconstruí el flujo a partir de documentación y del diagrama del ejemplo, completando la tabla de documentación de errores como ejercicio.
5. Apagá las VMs o revertí ambos snapshots; no reutilices credenciales de producción ni expongas la red virtual al host/LAN.

## Entregable

Diagrama cliente–RPC–servidor con los dos momentos (activación y llamada) y las capas de control; versión/actualizaciones observadas; identidad; permisos; niveles de autenticación e impersonación; HRESULT/eventos y limitaciones. No incluyas credenciales, direcciones públicas ni cambios de seguridad.

## Repaso

▼ **¿Qué añade DCOM a una llamada COM local?**

> Activación y comunicación distribuidas a través de RPC, con proxies/stubs y controles de seguridad remotos.

▼ **¿Autenticación equivale a autorización?**

> No. La autenticación establece quién es el interlocutor; la autorización decide qué puede hacer.

▼ **¿Qué permiso falta si la activación funciona pero la primera llamada al método devuelve acceso denegado?**

> Un candidato fuerte es un permiso de **acceso** (de la aplicación o la restricción de equipo), porque el de lanzamiento/activación ya se cumplió. Pero si el error es de transporte (por ejemplo, `0x800706BA`), también encaja un firewall que bloquea el puerto dinámico del servidor. Se distingue con el HRESULT exacto, eventos y configuración antes de afirmarlo.

▼ **¿Por qué un firewall que permite el puerto 135 puede no alcanzar para DCOM?**

> Porque el 135 es el del mapeador de endpoints; las llamadas al objeto van al puerto dinámico que registró el proceso servidor.

▼ **El código usa Negotiate y `CoQueryProxyBlanket` devuelve Negotiate. ¿Se autenticó con Kerberos?**

> No se puede saber por esa consulta: informa Negotiate, no el paquete elegido. Hace falta otra evidencia, como la auditoría de inicio de sesión del servidor.

▼ **¿Qué es un SPN y por qué importa el nombre con el que se llega al servidor?**

> Es el identificador de una instancia de servicio que Kerberos asocia a la cuenta del servicio. El cliente lo compone a partir del nombre que usó; si no corresponde a un SPN registrado en la cuenta correcta, Kerberos no puede autenticar ese servicio.

▼ **¿En qué se diferencian el nivel de autenticación y el de impersonación?**

> El de autenticación fija la protección de la comunicación (y se usa el más alto propuesto); el de impersonación, que fija el cliente, limita qué puede hacer el servidor en su nombre.

▼ **El registro de una aplicación dice una cosa y la aplicación se comporta como si dijera otra. ¿Qué buscás en el binario?**

> Una llamada a `CoInitializeSecurity` (que hace ignorar los valores del registro para ese proceso) o a `CoSetProxyBlanket` (que cambia la seguridad de un proxy).

▼ **¿Qué hacés si la práctica requiere desactivar hardening?**

> No la ejecutás. Analizás la configuración existente o usás un laboratorio actualizado que funcione con las protecciones vigentes.

**Puerta optativa**

Podés explicar las capas COM/DCOM/RPC, separar activación de llamada, autenticación de autorización y permisos de lanzamiento de permisos de acceso, distinguir nivel de autenticación de nivel de impersonación y documentar un error sin atribuirle una causa única ni recomendar bajar protecciones.

**Lo que queda fuera**

El formato del protocolo DCOM en la red (OBJREF, resolución OXID), la configuración de puertos o rangos, el funcionamiento interno de Kerberos y NTLM, la configuración de delegación (solo como recuadro), *cloaking* y COM+ no se desarrollan. Tampoco se enseña a configurar DCOM ni el firewall: la lección es de lectura y diagnóstico.

## Fuentes

- Microsoft Learn: COM Clients and Servers, Locating a Remote Object, Activation Security, Authentication Level, Impersonation Levels.
- Microsoft Learn, configuración: Process-wide security / DCOMCNFG, Process-wide security with CoInitializeSecurity, CoSetProxyBlanket, LaunchPermission, AccessPermission, DCOM Security Enhancements (XP SP2 / 2003 SP1).
- Microsoft Learn, red y autenticación: Security Blanket Negotiation, COM authentication service constants, Snego, Service Principal Names, How clients compose a service's SPN, Kerberos constrained delegation overview, RPC dynamic ports and firewalls, Default dynamic port range, Service overview and network port requirements.
- Microsoft Support: DCOM hardening KB5004442.
- **Fundamentos previos:** contratos COM en 2D.6; activación en 2D.7.

**Etiquetas**

**Núcleo conceptual:** ninguno específico de DCOM. **Conocimiento externo:** COM/RPC, mapeador de endpoints y puertos dinámicos, permisos, niveles de seguridad, servicios de autenticación, SPN, delegación (recuadro) y hardening. **Ejemplo ilustrativo:** flujo hipotético y tabla de registro de errores. **Laboratorio verificado:** no; la práctica depende de dos VMs preconfiguradas.

# WMI: proveedores, filtros y consumidores

**Alcance de la práctica**

La práctica principal inspecciona WMI y usa consultas temporales. No crea suscripciones permanentes, no ejecuta las acciones que encuentre y no borra ni "repara" objetos durante el triage. Si un docente prepara una demostración permanente, debe usar solo una VM aislada y un consumidor benigno, con inventario previo y limpieza verificada.

**Propósito**

Reconocer el modelo WMI/CIM y entender por qué un filtro unido a un consumidor permanente merece revisión, sin concluir malware solo por encontrar una suscripción. Al terminar deberías poder reconstruir una suscripción completa —qué evento la dispara, qué hace, quién la creó y con qué permisos— y dejar constancia de lo que **no** pudiste determinar.

**Prerrequisitos**

- *Obligatorios:* Registro (2D.3) y contexto de seguridad (2D.1).
- *Recomendados:* COM (2D.6), Task Scheduler (2D.5), servicios (2D.4).

## Modelo

WMI expone clases/instancias a través de namespaces y proveedores. Un cliente consulta o se suscribe a eventos. La suscripción **temporal** vive mientras el cliente está conectado; una permanente permanece en el repositorio hasta cancelarse y relaciona `__EventFilter`, una instancia de `__EventConsumer` y `__FilterToConsumerBinding`. Los proveedores y consumidores tienen configuración y seguridad propias.

Para revisar una suscripción, lee namespace, filtro, consumidor, binding, propietario/CreatorSID, permisos y destino. Los consumidores estándar pueden tener efectos diferentes; no ejecutes scripts ni comandos encontrados. Una suscripción inesperada es un hallazgo que requiere contexto, no una prueba automática.

## Temporal frente a permanente

| | Consumidor **temporal** | Consumidor **permanente** |
|---|---|---|
| Cómo nace | Un programa o script llama a `ExecNotificationQuery` (o su variante asíncrona) y recibe eventos mientras corre. | Se guardan en el repositorio un filtro, un consumidor lógico y un binding. |
| Cuánto dura | Hasta que el cliente termina, WMI se detiene o el sistema se reinicia. | Hasta que alguien cancela la registración; sobrevive a reinicios. |
| Quién lo ejecuta | El propio cliente. | WMI carga el consumidor físico cuando hace falta. |
| Para el analista | Es lo que usás en la práctica para observar. | Es lo que inventariás y documentás, sin tocar. |

La documentación recomienda llamadas **semisíncronas** antes que asíncronas para consumidores temporales, porque en el modo asíncrono un llamador no autenticado puede entregar datos al *sink*.

## Namespaces: dónde vive la suscripción y de dónde vienen los eventos

WMI organiza clases en **namespaces** (`root\cimv2`, `root\subscription`, `root\default` y muchos otros que agregan productos y roles). Para este tema importan dos ideas:

- `root\cimv2` aloja las clases del proveedor Win32 y eventos intrínsecos como `__InstanceCreationEvent` sobre esas clases.
- Microsoft **recomienda** compilar las suscripciones permanentes en `root\subscription`, para tener un solo lugar donde buscarlas. Es una recomendación, no una garantía: los tres objetos pueden existir en **cualquier** namespace que tenga las clases necesarias. Un inventario que solo mira `root\subscription` puede quedar incompleto.

Hay que distinguir **dos namespaces** por suscripción:

1. El namespace donde **están guardados** el filtro, el consumidor y el binding (por ejemplo, `root\subscription`).
2. El valor de la propiedad `EventNamespace` del filtro: el namespace de los **eventos** que el filtro consulta (por ejemplo, `root\cimv2`). Con eso se arman suscripciones *cross-namespace*: el objeto vive en un lugar y escucha eventos de otro.

Si en la ficha anotás solo uno de los dos, la reconstrucción queda ambigua.

## Las piezas de una suscripción permanente

```
__EventFilter                (Name, Query WQL, QueryLanguage, EventNamespace,
   ^                          EventAccess, CreatorSID)
   | Filter
__FilterToConsumerBinding    (Filter, Consumer, MaintainSecurityContext, CreatorSID)
   | Consumer
   v
<consumidor lógico>          instancia de una clase derivada de __EventConsumer
                             (p. ej. NTEventLogEventConsumer, LogFileEventConsumer,
                              CommandLineEventConsumer, ActiveScriptEventConsumer…)
   | clase del consumidor
   v
__EventConsumerProviderRegistration  -> __Win32Provider (proveedor de consumidor, COM)
   v
consumidor físico (objeto COM que realmente ejecuta la acción)
```

- **Filtro**: *qué* evento interesa (consulta WQL de eventos).
- **Consumidor lógico**: *qué hacer* (escribir en el registro de eventos, en un archivo, lanzar un proceso, ejecutar un script, enviar correo…). Sus propiedades describen la acción, no el evento.
- **Binding**: la asociación que dice qué filtro alimenta a qué consumidor. Un filtro puede tener varios consumidores y un consumidor varios filtros.
- **Proveedor de consumidor**: el objeto COM que WMI localiza, mediante `__EventConsumerProviderRegistration`, para ejecutar al consumidor físico de esa clase. Por eso un consumidor de una clase no estándar te lleva a revisar también su registro COM (2D.7).

Entre los consumidores estándar, `CommandLineEventConsumer` lanza un proceso **en el contexto de sistema local**, y `ActiveScriptEventConsumer` ejecuta un script. Microsoft los señala como sensibles. Su presencia aumenta la prioridad de revisión; no define la intención.

## Leer la consulta del filtro: WQL de eventos

La propiedad `Query` del filtro está escrita en **WQL**. Microsoft la describe como un subconjunto de SQL con cambios semánticos: las consultas de datos van contra **una clase por vez**, su lista de palabras clave no incluye `JOIN` ni sentencias de modificación, y las consultas de **eventos** agregan cláusulas propias. No la leas como SQL general.

**Qué clase de evento se pide.**

- **Intrínsecos:** reflejan un cambio en el modelo de datos de WMI: creación, modificación o borrado de instancias, clases o namespaces (`__InstanceCreationEvent`, `__InstanceModificationEvent`, `__InstanceDeletionEvent`, `__InstanceOperationEvent`…). La instancia afectada viaja en `TargetInstance`, y el operador `ISA` restringe a una clase y sus subclases: `WHERE TargetInstance ISA 'Win32_Service'`.
- **Extrínsecos:** sucesos que un proveedor define como clase propia derivada de `__ExtrinsicEvent`, sin relación directa con instancias. Por ejemplo, el proveedor del registro define `RegistryKeyChangeEvent`.
- **De temporizador:** clases de reloj (`__TimerEvent` y relacionadas) que disparan en momentos o intervalos.

**Dos usos distintos de `WITHIN`.** La misma palabra cumple dos funciones que no son intercambiables:

| Forma | Dónde va | Qué hace | Qué te dice como analista |
|---|---|---|---|
| `WITHIN n` (sondeo) | Inmediatamente **antes** de `WHERE` | Fija el **intervalo de sondeo** que WMI usa para detectar eventos intrínsecos cuando no hay un proveedor de eventos para esa clase. Admite fracciones de segundo, pero valores demasiado chicos pueden rechazarse; Microsoft recomienda intervalos mayores a 5 minutos para la mayoría de los consumidores. | El costo y la latencia de detección. Un sondeo muy frecuente sobre una clase grande es una carga constante; la notificación puede llegar hasta `n` segundos tarde. |
| `GROUP WITHIN n` (agrupación) | **Después** de `WHERE`, tras `GROUP` | Junta los eventos similares que llegan durante `n` segundos desde el primero y entrega **un** evento agregado (`__AggregateEvent`). Admite `BY propiedades` y `HAVING NumberOfEvents …`. | Que el consumidor reacciona a **ráfagas o umbrales**, no a cada evento. |

Ejemplos de lectura (ilustrativos):

```
SELECT * FROM __InstanceCreationEvent WITHIN 30
  WHERE TargetInstance ISA 'Win32_Process'
  -> sondea cada 30 s la aparición de procesos; reacciona a cada uno

SELECT * FROM __InstanceCreationEvent
  WHERE TargetInstance ISA 'Win32_NTLogEvent'
  GROUP WITHIN 600 BY TargetInstance.SourceName
  HAVING NumberOfEvents > 25
  -> agrupa 10 minutos por origen; solo entrega si hubo más de 25
```

Microsoft indica además que crear consumidores **permanentes** con consultas de sondeo requiere privilegios de administrador, y que cuando la consulta de un consumidor permanente falla se registra un evento de origen *WinMgmt* con id 10. Ese evento es evidencia útil de un filtro roto.

## Seguridad: CreatorSID, EventAccess y ACL del namespace

**`CreatorSID`.** WMI guarda en cada instancia el SID de quien la creó. Para que una suscripción permanente funcione, el filtro, el consumidor y el binding deben tener **el mismo** `CreatorSID`, y el creador debe ser una cuenta de dominio con privilegios de administrador local o el grupo Administradores local. Para los consumidores sensibles, WMI verifica que ese SID pertenezca a Administradores. Qué revisar:

- ¿Coinciden los tres `CreatorSID`? Si no, la suscripción probablemente no funciona; queda como hallazgo a explicar, no a reparar.
- ¿A qué cuenta o grupo corresponde el SID? Convertí el arreglo de bytes a SID de texto y resolvelo; si no resuelve (cuenta borrada, otro dominio), anotalo.

**`EventAccess`.** Es un descriptor de seguridad SDDL en el filtro que limita **qué identidades pueden publicar** eventos hacia él (derecho `WBEM_RIGHT_PUBLISH`). El valor por defecto es `NULL`, que permite a todos. Que esté vacío no es anómalo en sí; que esté restringido indica una configuración deliberada.

**ACL del namespace.** Cada namespace tiene un descriptor de seguridad que WMI compara con el token de quien se conecta: derechos como *Enable Account*, *Execute Methods*, *Full Write*, *Partial Write*, *Provider Write*, *Remote Enable*, *Read Security* y *Edit Security*. Revisá quién tiene escritura en el namespace donde vive la suscripción, comparalo con los permisos por defecto que documenta Microsoft y anotá las diferencias. La auditoría de namespaces existe (SACL), pero no viene habilitada; si no estaba activa **antes** del incidente, no esperes encontrar eventos de quién creó la suscripción.

## Leer un archivo MOF sin compilarlo

**MOF** (*Managed Object Format*) es el lenguaje con el que se describen clases e instancias CIM. Un proveedor suele distribuirse como un MOF (que define sus clases) más una DLL (que entrega los datos), y el MOF se **compila** al repositorio con `mofcomp`. Para el triage importa porque una suscripción permanente también puede escribirse como MOF.

Qué mirar en un `.mof` encontrado durante una revisión, **solo leyéndolo como texto**:

- `#pragma namespace("\\\\.\\root\\subscription")`: en qué namespace se crearían los objetos.
- Bloques `instance of __EventFilter as $FLT { … }`, `instance of <ClaseConsumidor> as $CONS { … }` e `instance of __FilterToConsumerBinding { Filter = $FLT; Consumer = $CONS; }`: es exactamente la terna filtro–consumidor–binding de esta lección.
- `#pragma autorecover`: agrega el archivo a la lista que WMI **recompila automáticamente** si reconstruye un repositorio dañado (la lista vive en `HKLM\SOFTWARE\Microsoft\WBEM\CIMOM\autorecover mofs`).

Dos límites de interpretación:

- Un MOF en disco **no prueba** que esos objetos existan en el repositorio: pudo no haberse compilado nunca. Y al revés, una suscripción puede existir en el repositorio sin ningún MOF en disco.
- **Nunca** ejecutes `mofcomp` sobre un archivo encontrado durante una revisión: compilarlo **crearía** los objetos que describe.

> **Recuadro conceptual: proveedores WMI**
>
> Un **proveedor** es un componente COM que entrega instancias, métodos o eventos de ciertas clases. Se registra con una instancia de `__Win32Provider`, cuyo `CLSID` apunta a su servidor COM (el recorrido de 2D.7 se aplica igual). La propiedad `HostingModel` define dónde y con qué cuenta corre: dentro de un proceso anfitrión compartido `WmiPrvSE.exe` como *NetworkService* (el predeterminado desde Vista cuando no se especifica), *LocalService* o *LocalSystem*; como servidor propio (*SelfHost*), o como proveedor desacoplado dentro de otra aplicación. Microsoft desaconseja *LocalSystem* por su privilegio y documenta eventos de registro cuando un proveedor usa ese modelo. Para la revisión basta con saber leer `__Win32Provider`, su CLSID y su `HostingModel`; **escribir** proveedores queda fuera del curso.

## WMI remoto: el modelo, sin habilitar nada

Un cliente puede conectarse a WMI de **otro** equipo indicando el nombre del equipo en la ruta del namespace (`\\EQUIPO\root\cimv2` en `IWbemLocator::ConnectServer`, o `-ComputerName` en PowerShell).

Esa conexión clásica viaja por **DCOM**, así que todo lo de 2D.8 aplica: firewall, permisos y autenticación DCOM, más el derecho **Remote Enable** sobre el namespace y las restricciones de UAC para cuentas remotas. La alternativa es **WinRM**, la implementación de Microsoft del protocolo WS-Management (SOAP sobre HTTP/HTTPS), que expone datos de WMI a través de su propio servicio y con su propia configuración; las sesiones CIM de PowerShell pueden usarlo.

Para la evidencia: una suscripción o una consulta pudo haberse creado **desde otro equipo**. Por eso un `CreatorSID` de cuenta de dominio, sin actividad local que lo explique, es una pista para preguntar al administrador por herramientas de gestión remota, no una conclusión. Esta lección **no** habilita WMI remoto, WinRM ni reglas de firewall.

## Criterios para documentar sin concluir de más

Una suscripción **existe**: eso es una observación. Que sea **maliciosa** es una conclusión que necesita más evidencia. Antes de clasificar, respondé:

- **Origen plausible:** ¿la instaló un producto conocido (agente de gestión, monitoreo, antivirus)? Nombres, rutas y proveedores de consumidor suelen delatar al producto; confirmalo con el inventario de software o con el administrador.
- **Coherencia:** ¿coinciden los `CreatorSID`? ¿El consumidor apunta a un archivo que existe, firmado, en una ruta protegida? Una ruta escribible por usuarios en un `CommandLineEventConsumer` es un riesgo aunque el producto sea legítimo.
- **Disparador:** ¿qué hace la consulta? Un temporizador, el arranque, el inicio de sesión o la creación de un proceso tienen implicancias distintas.
- **Temporalidad:** ¿hay registros de cambio, tickets o eventos que fechen la creación? Si no, decí que no se pudo fechar.
- **Alcance:** ¿la misma suscripción aparece en otros equipos de la flota? Si es así, sugiere despliegue centralizado (legítimo o no).

Conclusiones calibradas posibles: “esperada y documentada”, “legítima con riesgo de configuración”, “sin origen identificado: escalar”, “inconsistente/no funcional”. Ninguna de estas habilita a borrarla durante el triage.

## Ejemplo trabajado

*(Vista conceptual ficticia de un laboratorio, sin consulta activa. Nombres, rutas y SID son marcadores.)*

```
Namespace de la suscripción: ROOT\subscription
  __EventFilter.Name           = "BlocLab-Filtro"
  __EventFilter.Query          = SELECT * FROM __InstanceCreationEvent WITHIN 30
                                 WHERE TargetInstance ISA 'Win32_Process'
                                 AND TargetInstance.Name = 'BlocLab.exe'
  __EventFilter.EventNamespace = root\cimv2
  __EventFilter.EventAccess    = (vacío)
  Consumidor: NTEventLogEventConsumer "BlocLab-Log"
  Binding: Filtro "BlocLab-Filtro" -> Consumidor "BlocLab-Log"
  CreatorSID (filtro, consumidor, binding): S-1-5-32-544 (los tres iguales)
```

Lectura: la suscripción vive en `root\subscription`, pero escucha eventos de `root\cimv2` (cross-namespace). El filtro sondea cada 30 segundos (`WITHIN 30`) la creación de un proceso llamado `BlocLab.exe` y el consumidor escribe una entrada en el registro de eventos: una acción de bajo impacto. Los tres `CreatorSID` coinciden con el SID del grupo Administradores, que es una forma documentada de crear suscripciones. `EventAccess` vacío significa que cualquier proveedor puede publicar al filtro.

La relación filtro–binding–consumidor permite reconstruir el flujo. Si falta un elemento o los SIDs no coinciden, la suscripción puede estar incompleta o requerir explicación; no la repares ni la borres durante triage.

### Ficha de evidencia

| Campo | Valor (ejemplo) | Fuente / tipo |
|---|---|---|
| Equipo, versión/build, fecha y hora de la revisión | VM-Lab-01, *(completar)* | Observación |
| Herramienta y cuenta usadas para inspeccionar | *(completar)*; sesión elevada sí/no | Observación |
| Namespace de la suscripción | `ROOT\subscription` | Observación |
| `EventNamespace` del filtro | `root\cimv2` | Observación |
| Filtro: nombre, consulta, lenguaje | `BlocLab-Filtro`, WQL arriba | Observación |
| Lectura de la consulta | Evento intrínseco de creación; sondeo `WITHIN 30`; sin `GROUP` | Interpretación de la WQL |
| Consumidor: clase, nombre y propiedades de acción | `NTEventLogEventConsumer`, `BlocLab-Log` | Observación (no ejecutado) |
| Proveedor de consumidor | Estándar de WMI | Inferencia por clase; confirmar registración |
| Binding y `MaintainSecurityContext` | Filtro → consumidor; *(completar)* | Observación |
| `CreatorSID` de los tres objetos y resolución | Iguales; Administradores | Observación + resolución |
| `EventAccess` | Vacío (`NULL`, todos pueden publicar) | Observación |
| ACL del namespace (escritura) | *(completar)*; diferencias con los valores documentados | Observación |
| Archivos referenciados (ruta, firma, hash, ACL) | No aplica para este consumidor | Observación |
| Origen plausible y evidencia | Laboratorio del curso, ticket *(completar)* | Contexto |
| Conclusión calibrada | Esperada y documentada | Juicio del analista |
| Lo que no se pudo determinar | Fecha de creación (sin auditoría previa) | Límite declarado |

## Práctica: inspección y evidencia

1. En una VM de laboratorio, inspeccioná primero una clase/proveedor WMI y una consulta temporal de lectura sobre datos conocidos (por ejemplo, instancias de `Win32_Service`).
2. Listá los namespaces existentes y decidí cuáles revisar; no te limites a `root\subscription`. Con PowerShell, de solo lectura: `Get-CimInstance -Namespace root -ClassName __NAMESPACE` para los namespaces y `Get-CimInstance -Namespace root/subscription -ClassName __EventFilter` (y luego `__EventConsumer` y `__FilterToConsumerBinding`) para cada namespace elegido.
3. Para cada suscripción, completá la ficha: namespace, `EventNamespace`, filtro, consumidor, binding, `CreatorSID` convertido a SID de texto, `EventAccess` y ACL del namespace. Sin ejecutar sus acciones.
4. Contrastá cuenta creadora, ACL del namespace, query y destino. Para cada consulta, anotá tipo de evento, si usa sondeo (`WITHIN`) o agrupación (`GROUP WITHIN`) y con qué intervalos. Redactá rutas personales antes de compartir evidencia.
5. Si en la VM hay archivos `.mof` de laboratorio, leelos como texto y compará lo que describen con lo que está en el repositorio. No los compiles.
6. No cambies ni elimines suscripciones encontradas. Si el laboratorio incluye una permanente creada previamente por el docente, identificá su ticket/ID y seguí la hoja de limpieza del laboratorio; verificá que los tres objetos vinculados ya no aparecen.

## Entregable

Ficha de evidencia de una consulta temporal o de una suscripción auditada, con todos los campos de la tabla, la conclusión calibrada y la sección de límites. Si no había una suscripción autorizada de prueba, indicá que no realizaste el paso de eliminación.

## Repaso

▼ **¿Qué mantiene viva una suscripción permanente?**

> La inscripción persistente de filtro, consumidor y binding en el repositorio WMI; permanece hasta que se cancela.

▼ **¿Por qué hay que revisar el binding?**

> Une qué evento se busca con qué consumidor recibirá el evento.

▼ **¿Qué diferencia hay entre el namespace de la suscripción y `EventNamespace`?**

> El primero es donde están guardados filtro, consumidor y binding; `EventNamespace` indica de qué namespace vienen los eventos que el filtro consulta.

▼ **¿Alcanza con revisar `root\subscription`?**

> No. Es la ubicación recomendada, pero una suscripción puede crearse en otros namespaces.

▼ **Los `CreatorSID` del filtro y del binding no coinciden. ¿Qué concluís?**

> Que la suscripción probablemente no funciona tal como está y que hay algo que explicar; no la reparás ni la borrás durante el triage.

▼ **¿Qué controla `EventAccess`?**

> Qué identidades pueden publicar eventos hacia ese filtro; vacío (`NULL`) permite a todos.

▼ **¿Qué diferencia hay entre `WITHIN 30` antes del `WHERE` y `GROUP WITHIN 30` después?**

> El primero fija un intervalo de **sondeo** para detectar eventos intrínsecos; el segundo **agrupa** eventos durante 30 s y entrega uno agregado (`__AggregateEvent`). No son intercambiables.

▼ **¿Qué distingue un evento intrínseco de uno extrínseco?**

> El intrínseco refleja un cambio en el modelo de datos de WMI (instancias, clases, namespaces); el extrínseco es una clase de evento definida por un proveedor para un suceso que no es un cambio de instancia.

▼ **Encontrás un `.mof` con un filtro, un consumidor y un binding. ¿Prueba que la suscripción existe?**

> No. Hay que comprobarlo en el repositorio; el archivo pudo no compilarse nunca. Y no se compila durante la revisión, porque crearía los objetos.

▼ **¿Qué aporta `#pragma autorecover` en un MOF?**

> Que WMI lo recompile automáticamente si reconstruye el repositorio; por eso conviene anotarlo junto con la entrada de registro correspondiente.

▼ **¿Por qué un `CreatorSID` de dominio sin actividad local no prueba nada por sí solo?**

> Porque WMI admite conexiones remotas (por DCOM o WinRM): la suscripción pudo crearse con una herramienta de gestión remota. Es una pregunta para el administrador.

▼ **¿Encontrar `__EventFilter` prueba una infección?**

> No. Hace falta relacionarlo con consumidor, binding, identidad, autorización y producto que lo instaló.

▼ **¿Qué no se debe hacer con un consumidor desconocido?**

> No ejecutarlo, borrarlo ni repararlo durante la revisión; preservá datos y escalá al administrador.

**Puerta optativa**

Podés distinguir consulta temporal y suscripción permanente, ubicar ambos namespaces de una suscripción, leer la WQL del filtro (tipo de evento, sondeo y agrupación), reconstruir filtro–binding–consumidor–proveedor, leer un MOF sin compilarlo, revisar `CreatorSID`, `EventAccess` y ACL del namespace, y describir evidencia con una conclusión calibrada sin ejecutar la acción configurada.

**Lo que queda fuera**

La escritura de proveedores (solo como recuadro), la sintaxis completa de MOF y de WQL (consultas de esquema, `ASSOCIATORS OF`, `REFERENCES OF`), el formato interno del repositorio, la configuración de WMI remoto o WinRM, y la habilitación de trazas o auditoría (que son cambios de configuración y no corresponden al triage) no se desarrollan.

## Fuentes

- Microsoft Learn: WMI architecture, Monitoring Events, Receiving Events at All Times, Receiving Events Securely, Maintaining WMI Security.
- Microsoft Learn, clases y namespaces: __EventFilter, __EventConsumer, __FilterToConsumerBinding, __EventConsumerProviderRegistration, Standard Consumer Classes, Cross-Namespace Permanent Event Subscriptions, Access to WMI Namespaces.
- Microsoft Learn, WQL y MOF: WQL (SQL for WMI), Determining the Type of Event to Receive, WITHIN Clause, GROUP Clause, HAVING Clause, ISA Operator for Event Queries, Managed Object Format (MOF), pragma autorecover.
- Microsoft Learn, proveedores y remoto: __Win32Provider, Provider Hosting and Security, Connecting to WMI on a Remote Computer, About Windows Remote Management.
- **Fundamentos previos:** servicios y tareas en 2D.4 y 2D.5; DCOM en 2D.8.

**Etiquetas**

**Núcleo conceptual:** análisis defensivo y persistencia como concepto. **Conocimiento externo:** arquitectura, namespaces, suscripciones, WQL de eventos, MOF, proveedores (recuadro), WMI remoto y seguridad de eventos WMI. **Ejemplo ilustrativo:** suscripción y ficha del laboratorio ficticio. **Laboratorio verificado:** no; inspección de solo lectura.

# IPC en Windows: named pipes, RPC y ALPC

> **Rama optativa 2D**
>
> Se analizan mecanismos en programas propios o didácticos. No se buscan endpoints de terceros para enviarles datos ni se enseña a abusarlos.

> **Propósito**
>
> Reconocer IPC por evidencia estática/dinámica y explicar qué controles separan al cliente del servidor. Al terminar deberías poder decir, para un canal propio, **quién puede abrirlo**, **quién puede hacerse pasar por servidor**, **con qué identidad actúa** el servidor al atender y **qué valida** antes de procesar un mensaje.

**Prerrequisitos**

- *Obligatorios:* procesos e hilos (1.3); objetos, handles, tokens y ACL (2D.1).
- *Recomendados:* COM/RPC (2D.6, 2D.8).

## Diferencias

- **Named pipe:** canal nombrado, local o de red según configuración; el nombre no es secreto. El servidor decide acceso con ACL y puede autenticar/impersonar clientes; revisá también framing, longitud y validación de mensajes.

Para reconstruir la estructura de los mensajes más allá del mecanismo IPC, seguí 4.5 · Reconstruir formatos y protocolos propios.

- **RPC:** contrato de operaciones que puede comunicarse local o remotamente; el runtime gestiona transporte/marshalling según binding. Analizá interfaz, endpoint, identidad y autorización.
- **ALPC:** mecanismo local de bajo nivel usado por componentes de Windows. En reversing suele reconocerse por módulos, estructuras y trazas; la documentación pública del contrato es limitada y varía por versión. Se cubre conceptualmente, sin construir clientes de endpoints del sistema.

| | Named pipe | RPC | ALPC |
|---|---|---|---|
| Qué transporta | Bytes o mensajes | Llamadas a operaciones de una interfaz (IDL) | Mensajes locales del sistema |
| Dónde se ve | Nombre `\\.\pipe\…`, handles de tipo archivo | UUID y versión de interfaz, secuencia de protocolo, endpoint | Módulos y trazas; poca documentación pública |
| Control de acceso principal | Descriptor de seguridad del pipe | Autenticación + callback de seguridad + chequeos en cada operación | Interno del sistema |
| Lo que lees en un análisis | Creación, apertura, ACL, modo, impersonación | Registro de interfaz, flags, protocolos, autenticación | Que existe, quién lo usa y qué evento registra |

## Named pipes en detalle

**Nombres y alcance.** Un servidor crea `\\.\pipe\nombre` con `CreateNamedPipe`; el nombre no distingue mayúsculas y cualquiera que lo conozca puede **intentar** abrirlo. Un cliente de otro equipo puede llegar por la red con `\\servidor\pipe\nombre`, salvo que el servidor cree la instancia con `PIPE_REJECT_REMOTE_CLIENTS`, que rechaza automáticamente las conexiones remotas.

**Descriptor de seguridad.** Si el servidor pasa `NULL`, el pipe recibe un descriptor por defecto que, según la documentación, da control total a LocalSystem, a los administradores y al creador, y **lectura** a Everyone y a la cuenta anónima. Un servidor que atiende solo a su sesión puede restringir el acceso con el *logon SID*; Microsoft lo recomienda para impedir accesos desde otras sesiones o equipos.

**Quién puede ser servidor.** Para crear una instancia hace falta el derecho `FILE_CREATE_PIPE_INSTANCE` sobre el pipe. La documentación advierte que `FILE_GENERIC_WRITE` incluye ese derecho (comparte valor con `FILE_APPEND_DATA`), así que una ACL que da "escritura genérica" también deja **crear instancias**. Si el servidor real crea la primera con `FILE_FLAG_FIRST_PIPE_INSTANCE`, la llamada falla con `ERROR_ACCESS_DENIED` cuando el nombre ya existe: es la forma documentada de detectar que otro proceso ocupó el nombre antes.

**Modo.** Un pipe de tipo **mensaje** conserva los límites de cada escritura; uno de tipo **byte** no. El lado cliente arranca en modo byte aunque el servidor sea de mensajes. Para el análisis, esto define cómo hay que leer el protocolo: con mensajes, cada `WriteFile` es una unidad; con bytes, el protocolo necesita su propio *framing* (longitud, delimitador) y es ahí donde se validan tamaños.

**Impersonación.** El servidor puede llamar a `ImpersonateNamedPipeClient` para actuar con el token del cliente y volver a su propia identidad con `RevertToSelf`. Por defecto la impersonación es al nivel `SecurityImpersonation`, pero el **cliente** puede limitarla al abrir el pipe con `CreateFile` y la bandera `SECURITY_SQOS_PRESENT` (por ejemplo, a nivel identificación). Para el análisis importan tres preguntas: ¿el servidor impersona? ¿revierte en todas las rutas, incluidos los errores? ¿qué nivel pidió el cliente?

| Qué revisar en un pipe propio | Evidencia | Señal a explicar |
|---|---|---|
| Nombre y proceso creador | Handle en el proceso servidor, argumentos de `CreateNamedPipe` | Nombre predecible usado por un servicio privilegiado |
| Descriptor de seguridad | DACL pasada al crear (o `NULL`) | Descriptor por defecto o ACL con `FILE_GENERIC_WRITE` amplio |
| Primera instancia | `FILE_FLAG_FIRST_PIPE_INSTANCE` en la primera creación | Sin la bandera, otro proceso pudo ocupar el nombre antes |
| Clientes remotos | `PIPE_REJECT_REMOTE_CLIENTS` | Aceptación remota sin necesidad |
| Modo y framing | Tipo byte/mensaje, prefijo de longitud | Longitud leída del mensaje sin tope |
| Impersonación | `ImpersonateNamedPipeClient` / `RevertToSelf` | Rutas de error sin `RevertToSelf` |

## RPC en detalle

Una interfaz RPC se define en **IDL** con un UUID y una versión; MIDL genera los stubs de cliente y servidor. El servidor registra la interfaz y elige **secuencias de protocolo**: `ncalrpc` (local), `ncacn_np` (sobre named pipes) o `ncacn_ip_tcp` (TCP, normalmente con endpoint dinámico resuelto por el mapeador de 2D.8).

Tres lecturas de seguridad que Microsoft documenta y que cambian conclusiones:

- **Los endpoints no aíslan interfaces.** En un proceso con varios servidores RPC, *todas* las interfaces son invocables por *todos* los endpoints del proceso. Que tu componente registre solo `ncalrpc` no impide que lo llamen por un pipe o un socket que abrió otro componente del mismo proceso. Por eso un descriptor de seguridad sobre un endpoint no es un control efectivo; la recomendación es un **callback de seguridad** que verifique protocolo e identidad en cada llamada.
- **Registrar autenticación no la exige.** `RpcServerRegisterAuthInfo` agrega una **opción** de autenticación, no un requisito: un cliente no autenticado que podía conectarse sigue pudiendo, aunque luego fallen funciones como `RpcImpersonateClient`.
- **Flags de registro.** Con `RpcServerRegisterIf2` / `Ex` / `3`, `RPC_IF_ALLOW_LOCAL_ONLY` rechaza clientes remotos (con las excepciones que detalla la documentación para `ncacn_np`), y `RPC_IF_ALLOW_SECURE_ONLY` exige un nivel de autenticación mayor que *none*, **sin** garantizar que el usuario sea privilegiado: puede ser una cuenta de invitado.

Microsoft remarca que `ncalrpc` no es "seguro por ser local": en un servidor de terminales, cientos de usuarios pueden llegar a un servicio local.

### Anatomía Interna de Stubs RPC y Decodificación de NDR (Format Strings)

Para el analista de ingeniería inversa que audita un binario sin símbolos ni archivos `.idl`, reconstruir la firma exacta de las funciones expuestas por un servidor RPC requiere inspeccionar las estructuras internas que MIDL compila en la sección `.data` o `.rdata`:

```
RPC_SERVER_INTERFACE (puntero exportado o registrado con RpcServerRegisterIf2):
   +0x00: Length: 0x60 (96 bytes en x64)
   +0x04: InterfaceId.SyntaxGUID (UUID de 16 bytes de la interfaz)
   +0x14: InterfaceId.SyntaxVersion (Major/Minor version)
   +0x50: InterpreterInfo (Ptr64 a MIDL_SERVER_INFO)

MIDL_SERVER_INFO:
   +0x00: pStubDesc (Ptr64 a MIDL_STUB_DESC)
   +0x08: DispatchTable (Ptr64 a arreglo de punteros a funciones C del servidor)
   +0x10: ProcFormatString (Ptr64 a tabla de formatos de procedimiento NDR)
   +0x18: FmtStringOffset (Ptr64 a tabla de índices a ProcFormatString)
```

### Decodificación de `ProcFormatString` y `TypeFormatString`

El compilador MIDL genera secuencias de bytes compactas que codifican los parámetros de cada método mediante la máquina de tipos de **NDR (Network Data Representation)**:

1. **Cabecera de Procedimiento:** En `ProcFormatString`, cada rutina arranca con una cabecera de 6 bytes en modo `-Oicf` que define el tamaño del marco en la pila (`stack_size`) y el número de parámetros.

2. **Descriptores de Parámetros (6 bytes por parámetro):**

- **Flags de Dirección:** Los primeros 2 bytes indican si el parámetro es entrante o saliente (`0x0048` = `[in]`, `0x0158` = `[out]`, `0x0050` = `[in, out]`).
- **Offset en el Stack:** Los siguientes 2 bytes indican la posición relativa en el marco de la llamada.
- **Descriptor de Tipo:** Los 2 bytes finales contienen el tipo básico (`FC_LONG = 0x08`, `FC_HYPER = 0x0b`, `FC_CHAR = 0x02`) o un offset relativo hacia `TypeFormatString` (almacenado en `MIDL_STUB_DESC+0x28`).

1. **Tipos Complejos en `TypeFormatString`:**

- `0x11` (`FC_RP`): Puntero de referencia (no puede ser nulo).
- `0x12` (`FC_UP`): Puntero único (puede ser nulo).
- `0x21` (`FC_C_CSTRING`): Cadena ASCII conformante terminada en nulo (`char*`).
- `0x22` (`FC_C_WSTRING`): Cadena UTF-16 conformante terminada en nulo (`wchar_t*`).
- `0x1A` (`FC_BOGUS_STRUCT`): Estructura compleja con alineación manual y punteros anidados.

El laboratorio `plantillas_codigo/rpc_com_server_lab.c` y su definición `rpc_com_server_lab.idl` permiten compilar un servidor local sobre `ncalrpc` y verificar la disposición exacta de estas tablas en memoria.

## ALPC

ALPC es el mecanismo de mensajes locales que usan muchos componentes de Windows. Su contrato no está documentado para uso general y cambia entre versiones, así que el curso solo pide **reconocerlo**: qué proceso lo usa, que existe una clase de eventos ETW para ALPC (ver 2D.12) y que, si un análisis llega a ALPC, la conclusión debe apoyarse en la documentación del componente, no en suposiciones sobre el formato de los mensajes.

## Ejemplo trabajado

*(Ejemplo ilustrativo de una app propia; los valores no son una captura.)*

```
BlocClient -> \\.\pipe\BlocLab.Status -> BlocService
Mensaje: {version=1, request=GET_STATUS}
Respuesta: {status=READY}
Seguridad: ACL permite al usuario de la sesión; no acepta datos arbitrarios
```

El pipe sugiere el transporte, pero hay que confirmar el proceso propietario, ACL, modo de lectura y formato del protocolo. Un nombre predecible no implica vulnerabilidad por sí solo.

Ficha del análisis, separando observación de inferencia:

| Dato | Valor (ilustrativo) | Tipo |
|---|---|---|
| Creador del pipe | `BlocService.exe`, cuenta de servicio de laboratorio | Observación (handle y proceso) |
| Flags de creación | `PIPE_ACCESS_DUPLEX`, `FILE_FLAG_FIRST_PIPE_INSTANCE`, `PIPE_TYPE_MESSAGE`, `PIPE_REJECT_REMOTE_CLIENTS` | Observación (argumentos en el código o el depurador) |
| DACL | Lectura/escritura al *logon SID* de la sesión; control total a SYSTEM | Observación (`GetSecurityInfo` en el lab) |
| Impersonación | `ImpersonateNamedPipeClient` antes de leer la configuración del usuario; `RevertToSelf` en salida normal y en error | Observación en código propio |
| Validación | Mensaje de tamaño fijo; versión distinta de 1 se rechaza | Observación en código propio |
| "Ningún otro proceso puede hacerse pasar por servidor" | — | Inferencia: la sostiene la primera instancia con bandera, no el nombre |

**Ampliación editorial basada en fuentes externas — Inspección práctica de puertos y conexiones ALPC en user-mode y WinDbg ( `!alpc` )**

Aunque ALPC (*Advanced Local Procedure Call*) es una interfaz interna de `ntdll.dll`, el analista necesita saber reconocer sus llamadas en un binario y auditar qué procesos están conectados a un puerto local durante una sesión de depuración (*Windows Internals 7th Ed., Cap. 3 / extensión `!alpc` de WinDbg*) (**Hecho confirmado**):

1. **Las tres primitivas de `ntdll.dll` y el espacio de nombres `\RPC Control\` :**

- **Servidor:** Llama a `ntdll!NtAlpcCreatePort(&PortHandle, &ObjectAttributes, &PortInformation)` publicando un objeto de tipo `ALPC Port` en el directorio del Object Manager (casi siempre bajo `\RPC Control\<NombreDelPuerto>` o `\Sessions\<N>\BaseNamedObjects\...` ).
- **Cliente:** Se conecta con `ntdll!NtAlpcConnectPort` (o `NtAlpcConnectPortEx` ) especificando el `UNICODE_STRING` del puerto destino.
- **Intercambio de mensajes:** Ambos lados usan `ntdll!NtAlpcSendWaitReceivePort(PortHandle, Flags, SendMessage, SendMessageAttributes, ReceiveMessage, &BufferLength, ReceiveMessageAttributes, Timeout)` .

1. **Cabecera `PORT_MESSAGE` en memoria ( `+0x00..+0x27` , 40 bytes en x64 / 24 bytes en x86):**

Todo mensaje enviado o recibido por ALPC comienza con una cabecera fija `PORT_MESSAGE` seguida inmediatamente por los datos de la aplicación:

```
typedef struct _PORT_MESSAGE_X64 {
USHORT DataLength;     // +0x00 (2B): Bytes útiles del payload después de esta cabecera
USHORT TotalLength;    // +0x02 (2B): sizeof(PORT_MESSAGE) (0x28 en x64) + DataLength
USHORT Type;           // +0x04 (2B): LPC_REQUEST (1), LPC_REPLY (2), LPC_CONNECTION_REQUEST
(10)
USHORT DataInfoOffset; // +0x06 (2B)
PVOID  ClientIdUniqueProcess; // +0x08 (8B): PID del emisor (CLIENT_ID.UniqueProcess)
PVOID  ClientIdUniqueThread;  // +0x10 (8B): TID del emisor (CLIENT_ID.UniqueThread)
ULONG  MessageId;      // +0x18 (4B): ID correlativo del mensaje
ULONG  Reserved;       // +0x1C (4B)
ULONG_PTR ClientViewSize; // +0x20 (8B): Total cabecera = 0x28 (40 bytes en x64)
} PORT_MESSAGE_X64;
```

1. **Comandos de inspección en solo lectura (Sysinternals y WinDbg de kernel):**

```
# En user-mode (consola elevada en la VM): listar todos los puertos ALPC abiertos y su
proceso dueño
handle.exe -a -p <PID_o_nombre> "ALPC Port"

# En WinDbg conectado al kernel de la VM (extensión !alpc):
kd> !alpc /lpp <dir_EPROCESS>    ; Lista todos los puertos ALPC creados y conectados por ese
proceso
kd> !alpc /p <dir_PortObject>    ; Muestra el proceso servidor, la cola de mensajes y todos
los clientes conectados
kd> !alpc /m <dir_Message>       ; Decodifica un mensaje ALPC en vuelo y quién lo envió
```

## Práctica

Con un cliente/servidor propios ya preparados:

1. Listá los pipes visibles en la VM solo para ubicar el tuyo (en PowerShell, `Get-ChildItem \\.\pipe\` muestra nombres) y no abras pipes ajenos.
2. Inspeccioná en Process Explorer/Procmon la apertura del endpoint y seguí una sola solicitud inocua. Capturá nombre, PID, operación, respuesta y ACL observada.
3. Completá la tabla “Qué revisar en un pipe propio” con evidencia del código o del depurador.
4. Para RPC, usá el propio contrato local: anotá UUID/versión, secuencias de protocolo registradas, flags de registro y si hay callback de seguridad.
5. Para ALPC, describí una traza/documentación existente, sin enviar mensajes.

## Entregable

Diagrama de dos procesos, mecanismo IPC, endpoint, identidad, controles, esquema del mensaje y evidencia. Incluí la tabla de revisión del pipe (o del registro RPC) con observación/inferencia. Ocultá datos personales; no registres payloads sensibles.

## Repaso

▼ **¿Un named pipe siempre es local?**

> No. Puede ser local o accesible por red según cómo se publique y la configuración del sistema/servidor; `PIPE_REJECT_REMOTE_CLIENTS` rechaza clientes remotos.

▼ **¿Qué diferencia RPC de un pipe?**

> RPC expresa una llamada mediante una interfaz; un pipe es un canal de bytes/mensajes. RPC puede usar distintos transportes.

▼ **¿Qué derecho permite crear instancias de un pipe y por qué importa una ACL con escritura genérica?**

> `FILE_CREATE_PIPE_INSTANCE`. `FILE_GENERIC_WRITE` lo incluye, así que esa ACL también permite crear instancias, es decir, actuar como servidor.

▼ **¿Para qué sirve `FILE_FLAG_FIRST_PIPE_INSTANCE`?**

> Hace que la creación falle si el nombre ya existe, así el servidor detecta que otro proceso ocupó el pipe antes.

▼ **¿Quién controla hasta dónde puede impersonar un servidor de pipe?**

> El cliente, con `SECURITY_SQOS_PRESENT` y el nivel elegido al abrir el pipe; por defecto es `SecurityImpersonation`.

▼ **Un servidor RPC registra solo `ncalrpc`. ¿Queda accesible solo localmente?**

> No necesariamente: en un proceso con otros servidores RPC, la interfaz es invocable por cualquier endpoint del proceso. Se controla con un callback de seguridad.

▼ **¿`RpcServerRegisterAuthInfo` impide que se conecten clientes no autenticados?**

> No. Agrega una opción de autenticación, no un requisito; hacen falta chequeos propios.

▼ **¿Por qué ALPC se trata como concepto?**

> Es una interfaz interna de bajo nivel con contratos menos estables; el curso enseña reconocimiento, no clientes de endpoints del sistema.

**Puerta optativa**

Podés distinguir pipe, RPC y ALPC, seguir un intercambio propio, revisar ACL, primera instancia, clientes remotos, modo e impersonación de un pipe, y explicar por qué en RPC el control debe estar en el callback de seguridad y no en el endpoint.

**Lo que queda fuera**

El protocolo de red de los pipes remotos, el formato interno de RPC (NDR), los mensajes ALPC, mailslots, memoria compartida y otros mecanismos IPC no se desarrollan. No se enseña a enviar datos a pipes ni a endpoints RPC ajenos.

## Fuentes

- Microsoft Learn: Interprocess Communications, Named Pipes, RPC, ALPC ETW class.
- Microsoft Learn, pipes: CreateNamedPipe, Named Pipe Security and Access Rights, Impersonating a Named Pipe Client, Named Pipe Type, Read, and Wait Modes.
- Microsoft Learn, RPC seguro: Writing a Secure RPC Client or Server, Be Wary of Other RPC Endpoints Running in the Same Process, RpcServerRegisterAuthInfo doesn't deny unauthorized users, Interface Registration Flags, Protocol Sequence Constants.
- **Fundamentos previos:** call stack y procesos en 1.3; DCOM/RPC en 2D.8.

**Etiquetas**

**Núcleo conceptual:** procesos e IPC general. **Conocimiento externo:** IPC Windows, seguridad de named pipes y RPC. **Ejemplo ilustrativo:** protocolo y ficha BlocLab. **Laboratorio verificado:** no; ejemplo propio propuesto.

**Ampliación editorial basada en fuentes externas — Reconstrucción estática de interfaces RPC (RPC_SERVER_INTERFACE y MIDL_SERVER_INFO)**

Cuando un binario registra un servidor RPC mediante `RpcServerRegisterIf` / `RpcServerRegisterIf2` / `RpcServerRegisterIfEx`, IDA Pro o Ghidra no resuelven por defecto la relación entre números de procedimiento (opcodes RPC) y funciones C. El primer argumento ( `IfSpec`, registro `RCX` en x64) apunta a la estructura `RPC_SERVER_INTERFACE` en `.rdata` o `.data` generada por el compilador MIDL ( `rpcndr.h` del Windows SDK) *(Hecho confirmado)*:

| Offset (x64) | Campo en `RPC_SERVER_INTERFACE` | Tipo y Significado en IDA / Ghidra |
|---|---|---|
| `+0x04` | `InterfaceId` | `RPC_SYNTAX_IDENTIFIER` (20 bytes: `GUID` de 16 bytes de la interfaz RPC + `MajorVersion` de 2B + `MinorVersion` de 2B). |
| `+0x30` | `DispatchTable` | `PRPC_DISPATCH_TABLE`: cantidad de funciones ( `DispatchTableCount` ) y puntero al despachador NDR ( `NdrServerCall2` / `NdrServerCallAll` ). |
| `+0x50` | `InterpreterInfo` | `const void*` que apunta a `MIDL_SERVER_INFO`: metadatos de decompilación del servidor. |

Siguiendo el puntero `InterpreterInfo` hacia la estructura `MIDL_SERVER_INFO`:

- En `+0x00` ( `pStubDesc` ) reside el descriptor de tipos y sintaxis NDR.
- En `+0x08` ( `DispatchTable` ) reside el **arreglo directo de punteros a las funciones C reales del servidor** ( `ServerRoutineTable[0..N-1]` ). Navegar a esta dirección revela inmediatamente la lista completa de procedimientos remotos expuestos por el binario.

**Automatización práctica:** En análisis defensivo o auditoría de servicios de Windows, herramientas de código abierto como `RpcView` o un script de **IDAPython** que automatice la navegación `InterfaceId → InterpreterInfo → DispatchTable` permiten extraer y tipar todas las rutinas del servidor RPC en cuestión de segundos.

# Excepciones de Windows y debugging

> **Rama optativa 2D**
>
> La práctica usa una excepción esperada en un programa propio. No busca provocar corrupción ni explotar un fallo.

> **Propósito**
>
> Entender cómo el depurador reconstruye el stack y cómo Windows transfiere el control cuando una función falla, distinguiendo el modelo histórico x86 del unwind x64. Al terminar deberías poder explicar **quién** vio una excepción, **en qué orden** y **por qué** una excepción de primera oportunidad no significa que el programa haya fallado.

**Prerrequisitos**

- *Obligatorios:* stack y llamadas (1.2, 2.5); 2D.2 memoria/loader.
- *Recomendados:* WinDbg/TTD (2.19); C++ profundo (2.18); taxonomía anti-análisis (2.15).

## Modelos

En x86, SEH usa registros/estructuras de excepción y el runtime del compilador puede agregar handlers de lenguaje; los detalles dependen del compilador y de mitigaciones como SafeSEH/SEHOP. En x64, el unwinder consulta metadatos de funciones: `.pdata` indexa entradas `RUNTIME_FUNCTION` y `.xdata` describe cómo deshacer prólogos y recuperar registros; algunas funciones hoja no requieren entrada.

WinDbg puede mostrar el evento de excepción, contexto y stack. En TTD, una traza de user mode permite avanzar o retroceder por esa ejecución, pero no reemplaza símbolos, documentación ni comprensión del estado. La salida cambia con arquitectura, build y símbolos disponibles.

## Qué guarda el sistema cuando ocurre una excepción

Cuando el procesador o el software genera una excepción, Windows guarda dos estructuras:

- el **registro de contexto** (`CONTEXT`): el estado de la máquina del hilo en ese momento, dependiente de la arquitectura;
- el **registro de excepción** (`EXCEPTION_RECORD`): el **código** de excepción, si es **continuable**, un puntero a otro registro (excepciones anidadas), la **dirección** donde ocurrió y un arreglo de **parámetros** adicionales.

Para el análisis, el par contexto + registro es la evidencia primaria: la dirección y el código dicen qué pasó; el contexto dice con qué registros. En WinDbg, `.exr` muestra un registro de excepción y `.ecxr` cambia el contexto al de la excepción guardada, para que `k` muestre el stack **de ese momento** y no el del depurador.

## Orden de despacho en user mode

Microsoft documenta este orden para buscar quién maneja una excepción de user mode:

1. **Depurador, primera oportunidad.** Si el proceso está siendo depurado, el sistema notifica al depurador.
2. **Vectored exception handlers (VEH).** Se registran con `AddVectoredExceptionHandler`, no dependen del marco de llamada, se aplican a todo el proceso y se llaman en el orden en que se agregaron, **después** de la primera oportunidad del depurador y **antes** de que comience el desenrollado.
3. **Handlers basados en marcos.** El sistema recorre los marcos del hilo desde el actual hacia atrás: en x86, la cadena SEH; en x64, la información de `.pdata` / `.xdata`. Aquí entran `__try/__except` y los handlers de lenguaje como el de C++.
4. **Depurador, segunda oportunidad.** Si nadie la manejó y hay depurador, se lo notifica de nuevo.
5. **Manejo por defecto.** Sin depurador o si este no la maneja, el sistema aplica la acción por defecto, que para la mayoría de las excepciones es terminar el proceso.

En kernel mode el sistema busca handlers en la pila del kernel; si no hay ninguno, el sistema se detiene (bugcheck, ver 6.3).

Un filtro de `__try/__except` decide con su valor de retorno si el bloque maneja la excepción, si se sigue buscando o si se continúa la ejecución. Cuando un handler acepta la excepción, el sistema **desenrolla** los marcos intermedios y ejecuta los bloques `__finally`/destructores que correspondan antes de llegar al handler.

## Primera y segunda oportunidad en el depurador

Para WinDbg, cada tipo de excepción tiene un **estado de corte**: cortar en la primera oportunidad (`sxe`), cortar solo en la segunda (`sxd`), solo informar (`sxn`) o ignorar (`sxi`). Por defecto, por ejemplo, una violación de acceso corta en la primera oportunidad, mientras que la excepción de C++ (`eh`) corta solo en la segunda. `.lastevent` muestra el último evento.

Consecuencias para leer evidencia:

- Una **excepción de primera oportunidad** es normal en muchos programas: excepciones C++ lanzadas y atrapadas, sondeos de memoria protegidos por `__try`, mecanismos de runtime. **No** significa un fallo.
- Una **segunda oportunidad** sí significa que nadie la manejó.
- Un **VEH** registrado por el programa ve todas las excepciones del proceso. Si al analizar un binario encontrás `AddVectoredExceptionHandler`, anotá qué hace el handler: puede ser diagnóstico legítimo (registro de fallos) o una técnica anti-depuración que usa excepciones a propósito (2.15). La llamada sola no decide cuál.

En binarios MSVC, las excepciones de C++ se lanzan como una excepción de Windows con un código propio del runtime (habitualmente `0xE06D7363`, conocimiento externo de reversing); reconocerlo evita confundir un `throw` controlado con un fallo.

## Ejemplo trabajado

*(Secuencia ilustrativa de un programa C++ propio que lanza y captura una excepción documentada.)*

```
app!RunCase -> app!ParseOwnInput -> throw/catch controlado
WinDbg: evento de excepción -> handler del runtime -> app!RunCase
x64: .pdata señala RuntimeFunction; .xdata describe unwind del prólogo
```

Al recorrer el stack, identificá qué frames son la ruta de llamada y cuál maneja el evento. La mera presencia de `.pdata` no demuestra que una excepción haya ocurrido; es metadata disponible para unwind.

Cronología de lectura (ilustrativa) del mismo caso, en el orden en que aparece cada dato:

| Paso | Qué se ve | Herramienta | Interpretación prudente |
|---|---|---|---|
| 1 | Evento de primera oportunidad, código de excepción C++ | Mensaje de WinDbg / `.lastevent` | Se lanzó una excepción; todavía no se sabe si alguien la maneja |
| 2 | Registro de excepción con dirección dentro del runtime | `.exr -1` | El `throw` pasa por el runtime de C++ |
| 3 | Stack de la excepción hasta `app!ParseOwnInput` | `.ecxr` + `k` | Ruta de llamada al momento del `throw` |
| 4 | El programa continúa y no hay segunda oportunidad | Ejecución | Un `catch` la manejó |
| 5 | Ejecución reanudada en `app!RunCase` | Breakpoint en el `catch` | Coincide con el handler esperado |

**Ampliación editorial basada en fuentes externas — Verificación de marcos de pila y detección de *Call Stack Spoofing* mediante `.pdata` y validación de sitios de `CALL` **

En la lección 2.15 vimos que las técnicas de *Call Stack Spoofing* fabrican marcos de pila sintéticos para ocultar el origen real de una llamada al sistema, y en 2D.11 vimos el layout binario de `RUNTIME_FUNCTION` ( `.pdata` ) y `UNWIND_INFO` ( `.xdata` ) (*Microsoft Learn: x64 stack usage y RtlVirtualUnwind*) (**Hecho confirmado**). Un analista o motor defensivo verifica la autenticidad de una pila de llamadas en x64 aplicando tres comprobaciones encadenadas sobre cada marco:

1. **Respaldo de módulo ( `RtlLookupFunctionEntry` ):**

Para cada `ControlPc` ( `RIP` actual o dirección de retorno en la pila), debe existir una entrada `RUNTIME_FUNCTION` válida dentro de la sección `.pdata` de un módulo PE firmado/respaldado en disco ( `Image` en el VAD, no `MEM_PRIVATE` ). Las únicas funciones x64 sin `.pdata` son las *funciones hoja* (*leaf functions*), que por definición de la ABI **no pueden modificar `RSP` ni llamar a ninguna otra función** (solo pueden estar en el frame `0` del tope de la pila, nunca en un frame intermedio).

1. **Coherencia del tamaño de marco ( `UNWIND_CODE` ):**

La distancia entre el `RSP` de un marco y el `RSP` del marco padre debe coincidir exactamente con la suma de los códigos `UWOP_ALLOC_SMALL` ( `OpInfo * 8 + 8` ), `UWOP_ALLOC_LARGE` y `UWOP_PUSH_NONVOL` ( `8` bytes por registro no volátil salvado) declarados en `UNWIND_INFO` .

1. **Validación de la instrucción previa a `ReturnAddress` (detección de *Gadgets*):**

Cuando `call destino` se ejecuta, empuja en la pila la dirección de la instrucción inmediatamente siguiente ( `ReturnAddress` ). Por lo tanto, los **2 a 7 bytes anteriores a `ReturnAddress`** en memoria ejecutable deben decodificarse como una instrucción `CALL` legítima:

| Bytes previos a `ReturnAddress` | Instrucción x64 | Interpretación en auditoría de pila |
|---|---|---|
| `E8 xx xx xx xx` ( `ReturnAddress - 5` ) | `call rel32` | Llamada directa normal. Se verifica que el destino calculado ( `ReturnAddress + rel32` ) coincida con el inicio de la función hija. |
| `FF 15 xx xx xx xx` ( `ReturnAddress - 6` ) | `call qword ptr [rip+disp32]` | Llamada indirecta vía IAT o puntero global (normal en llamadas a DLLs). |
| `FF D0` .. `FF D7` o `41 FF D0` .. `D7` ( `-2` / `-3` ) | `call rax` .. `r15` | Llamada indirecta por registro (vtable, callback o `GetProcAddress` ). |
| `FF 23` / `FF 26` / `FF 27` ( `jmp [rbx]` / `[rsi]` / `[rdi]` ) | `jmp qword ptr [reg]` | **Anomalía crítica (*Gadget de Call Stack Spoofing*):** la dirección en la pila apunta después de un `JMP` , no de un `CALL` , o el `call rel32` apunta a una función distinta de la que está en el frame hijo. |

**Inspección rápida en WinDbg ante una pila sospechosa:**

```
0:000> kn                                ; Lista los números de frame, Child-SP y Call
Site
0:000> !fnent <Call_Site>                ; Verifica la entrada RUNTIME_FUNCTION y el
tamaño del marco en .xdata
0:000> ub <Call_Site> L1                 ; Desensambla la instrucción inmediatamente
ANTERIOR al retorno (debe ser CALL)
```

## Anatomía Binaria de UNWIND_INFO y Decodificación de UNWIND_CODE en x64

En arquitecturas x64, la estructura `UNWIND_INFO` almacenada en la sección `.xdata` gobierna cómo el kernel y los depuradores desenrollan la pila hacia atrás. Cada registro de desenrollado tiene la siguiente estructura binaria en memoria:

```
Estructura UNWIND_INFO (.xdata):
   +0x00: UBYTE Version : 3;      // Versión de unwind (típicamente 1 o 2)
   +0x00: UBYTE Flags   : 5;      // 0x01=EHANDLER (__except), 0x02=UHANDLER (__finally),
0x04=CHAININFO
   +0x01: UBYTE SizeOfProlog;     // Longitud del prólogo de la función en bytes
   +0x02: UBYTE CountOfCodes;     // Número de entradas en el arreglo UnwindCode[]
   +0x03: UBYTE FrameRegister : 4;// Registro de marco (0=ninguno, 5=RBP, etc.)
   +0x03: UBYTE FrameOffset   : 4;// Offset del registro de marco escalado (*16)
   +0x04: UNWIND_CODE UnwindCode[CountOfCodes]; // Arreglo de operaciones de desenrollado
```

## Decodificación de Slots de `UNWIND_CODE` (2 bytes por slot)

Cada elemento de `UnwindCode` ocupa exactamente 16 bits (2 bytes) y describe una operación que el prólogo ejecutó y que el desenrollador debe revertir:

- `CodeOffset` **(8 bits bajos):** Offset en bytes desde el inicio de la función donde se realizó la operación.
- `UnwindOp` **(4 bits):** Operación de reversión de pila:
- `0` = `UWOP_PUSH_NONVOL`: El prólogo hizo un `push` de un registro no volátil. Operación inversa: pop del registro indicado en `OpInfo`.
- `1` = `UWOP_ALLOC_LARGE`: Asignó un tamaño grande en stack (ocupa 2 o 3 slots sucesivos de `UNWIND_CODE` para especificar el tamaño).
- `2` = `UWOP_ALLOC_SMALL`: Asignó entre 8 y 128 bytes en la pila. Operación inversa: sumar `(OpInfo * 8 + 8)` a `RSP`.
- `3` = `UWOP_SET_FPREG`: Estableció el puntero de marco de pila. Operación inversa: restaurar `RSP` desde `FrameRegister`.
- `4` = `UWOP_SAVE_NONVOL`: Guardó un registro no volátil en la pila usando `mov` en lugar de `push` (ocupa 2 slots para codificar el offset).
- `10` = `UWOP_EPILOG`: Define los epílogos de la función (Windows 10 21H1+ para soporte de Time Travel Debugging).
- `OpInfo` **(4 bits altos):** Índice del registro x64 involucrado (`0`=RAX, `1`=RCX, `2`=RDX, `3`=RBX, `4`=RSP, `5`=RBP, `6`=RSI, `7`=RDI, `8..15`=R8..R15).

### Verificación Forense frente a Call Stack Spoofing

Cuando una herramienta de seguridad (EDR) o un analista en WinDbg valida una pila con `!fnent`, el kernel simula la ejecución inversa de cada `UNWIND_CODE`. Si un atacante utilizó *Call Stack Spoofing* fabricando una dirección de retorno falsa pero no ajustó `RSP` para coincidir exactamente con la sumatoria de los `UWOP_ALLOC_SMALL` / `UWOP_PUSH_NONVOL` de la función invocadora, o si la instrucción previa a la dirección de retorno no es un opcode `CALL` legítimo (`E8 rel32` o `FF /2`), el desenrollado falla con inconsistencia de marco y delata la intrusión.

## Práctica

1. Compilá o usá un programa propio mínimo que lance/capture una excepción prevista, sin leer datos externos.
2. En WinDbg, anotá arquitectura, evento, excepción y `k` / `kv` antes y después del handler. Usá `.exr -1` y `.ecxr` para leer el registro y el contexto de la excepción.
3. Cambiá **solo para tu sesión** el estado de corte de la excepción C++ (`sxe eh`) para verla en primera oportunidad, y comparalo con el comportamiento por defecto.
4. En x64, inspeccioná la entrada de función/unwind con símbolos y comandos documentados para tu build; en x86, describe el frame SEH observado sin modificar la cadena.
5. Opcional: agregá a tu programa un VEH que solo registre el código de excepción y verificá en qué momento se llama respecto del depurador y del `catch`.
6. Opcional: grabá el mismo caso de user mode con TTD y navega a la excepción. Guardá el trace solo mientras lo necesites y borrá la copia al finalizar.

## Entregable

Diagrama de control antes/después de la excepción, arquitectura, stack, handler y límites de símbolos; la cronología con primera/segunda oportunidad y, si lo hiciste, el momento en que actúa el VEH. Separá información observada de interpretación del compilador.

## Repaso

▼ **¿Qué función cumplen `.pdata` y `.xdata` en x64?**

> `.pdata` localiza metadata de funciones; `.xdata` describe información de unwind/handlers necesaria para recuperar estado y recorrer el stack.

▼ **¿x86 SEH y x64 unwind son el mismo mecanismo?**

> No. Tienen representación y reglas distintas; el compilador y las mitigaciones también afectan lo observable.

▼ **¿Un frame de stack prueba que esa función lanzó la excepción?**

> No. Es una pista del camino actual; se confirma con instrucción, contexto y flujo de control.

▼ **¿En qué orden se buscan handlers en user mode?**

> Depurador (primera oportunidad), handlers vectorizados, handlers basados en marcos, depurador (segunda oportunidad) y manejo por defecto.

▼ **¿Una excepción de primera oportunidad indica que el programa falló?**

> No. Muchas se lanzan y se manejan normalmente; solo la segunda oportunidad indica que nadie la manejó.

▼ **¿Para qué sirve `.ecxr`?**

> Pone el contexto del depurador en el registro de contexto de la excepción, para que el stack corresponda al momento del fallo.

▼ **Encontrás `AddVectoredExceptionHandler` en un binario. ¿Qué concluís?**

> Que el programa ve todas las excepciones del proceso antes que los handlers por marco. Hay que leer qué hace el handler: puede ser diagnóstico o anti-depuración.

> **Puerta optativa**
>
> Podés describir una excepción propia en WinDbg, leer registro y contexto, explicar el orden de despacho (incluidos VEH y primera/segunda oportunidad), leer el stack y explicar la diferencia general entre SEH x86 y unwind x64.

**Lo que queda fuera**

El formato completo de `UNWIND_INFO`, los manejadores de lenguaje en detalle, SafeSEH/SEHOP y CFG por dentro, WER y la depuración post mortem configurada en el sistema no se desarrollan. No se cambia ninguna configuración global de depuración.

## Fuentes

- Microsoft Learn: x64 exception handling, Structured Exception Handling, Debugging a user-mode process using WinDbg.
- Microsoft Learn, despacho y depurador: Exception Dispatching, Vectored Exception Handling, try-except statement, Controlling Exceptions and Events, .exr, .ecxr.
- **Fundamentos previos:** stack en 1.2, unwind C++ en 2.18, WinDbg en 2.19, anti-análisis en 2.15.

**Etiquetas**

**Núcleo conceptual:** excepciones y stack como conceptos generales. **Conocimiento externo:** SEH/unwind, despacho de excepciones, VEH y control de excepciones en WinDbg; el código de excepción C++ de MSVC como dato de reversing. **Ejemplo ilustrativo:** flujo y cronología de excepción. **Laboratorio verificado:** no.

**Ampliación editorial basada en fuentes externas — Layout binario de RUNTIME_FUNCTION (.pdata) y UNWIND_INFO (.xdata) en x64**

A diferencia de x86 (donde la lista SEH se enlaza en la pila mediante `FS:[0]`), en Windows x64 el desenrollado de pila y el despacho de excepciones se rigen por tablas estáticas en el PE sin tocar la pila en el prólogo (Microsoft Learn: *x64 exception handling*) *(Hecho confirmado)*:

| Estructura y Sección | Offset / Tamaño | Campos Binarios y Significado |
|---|---|---|
| **`RUNTIME_FUNCTION`** (Sección `.pdata`) | `12 bytes` fijos por función | • `+0x00`: `DWORD BeginAddress` (RVA de inicio de la función).<br>• `+0x04`: `DWORD EndAddress` (RVA de fin de la función).<br>• `+0x08`: `DWORD UnwindInfoAddress` (RVA que apunta a la cabecera en `.xdata`). |
| **`UNWIND_INFO`** (Sección `.xdata`) | `4 bytes` cabecera + array variable | • `+0x00`: `Version : 3` (bits 0..2, vale 1 o 2) y `Flags : 5` (bits 3..7: `0x01 = UNW_FLAG_EHANDLER`, `0x02 = UNW_FLAG_UHANDLER`, `0x04 = UNW_FLAG_CHAININFO`).<br>• `+0x01`: `UBYTE SizeOfProlog` (longitud en bytes del prólogo).<br>• `+0x02`: `UBYTE CountOfCodes` (cantidad de slots de 2 bytes en `UnwindCode[]`).<br>• `+0x03`: `UBYTE FrameRegisterAndOffset` (registro base y desplazamiento de marco).<br>• `+0x04`: Arreglo `UNWIND_CODE[]` (códigos como `UWOP_PUSH_NONVOL=0`, `UWOP_ALLOC_SMALL=2` indicando qué registros se salvaron y cuánto creció `RSP`).<br>• **Tras `UnwindCode[]`** (alineado a 4B): Si `Flags & 0x03`, sigue la **RVA de 32 bits de `ExceptionHandler`** (`__C_specific_handler`, `__CxxFrameHandler3` o `__CxxFrameHandler4`) y los datos de excepción (`SCOPE_TABLE` / `FuncInfo`). |

**Inspección en vivo con WinDbg:** El comando `!fnent <dirección_de_función>` decodifica en vivo tanto la entrada `RUNTIME_FUNCTION` como todos los códigos `UNWIND_CODE` de `.xdata`, siendo fundamental para validar si una dirección de retorno en la pila fue falsificada (Call Stack Spoofing).

# ETW y telemetría defensiva

> **Propósito**
>
> Comprender cómo se genera, habilita y consume telemetría ETW, dominar la sesión del sistema **NT Kernel Logger**, analizar la **anatomía binaria del formato ETL**, y auditar de forma reproducible las técnicas de evasión y **manipulación de ETW (ETW Patching y Blinding)** tanto en modo usuario como en modo kernel.

**Prerrequisitos**

- *Obligatorios:* procesos/hilos (1.3); WinDbg y TTD.
- *Recomendados:* 2D.10 IPC; conceptos de excepciones en 2D.11; registro de Windows (2D.3).

---

## 1. El Modelo de Arquitectura ETW

ETW separa tres roles clave: **provider** (emite eventos), **controller** (inicia sesión, habilita providers y define buffers/archivo) y **consumer** (procesa eventos en vivo o desde un archivo ETL).

ETW permite habilitar o deshabilitar providers **en caliente**, sin reiniciar el programa. Un provider registrado que nadie habilitó no emite eventos: por eso "el programa no generó nada" y "nadie estaba escuchando" se ven idénticos desde afuera.

### Tipos de Providers y qué implican para decodificar

| Tipo | Cómo emite | Dónde está la información para decodificar | Sesiones simultáneas |
|---|---|---|---|
| **MOF (clásico)** | `RegisterTraceGuids` / `TraceEvent` | Clases MOF en WMI | Una sola |
| **WPP** | `RegisterTraceGuids` / `TraceEvent` | Archivos TMF (normalmente en el PDB del binario) | Una sola |
| **Manifest-based** | `EventRegister` / `EventWrite` | Manifiesto XML registrado en el sistema | Hasta ocho |
| **TraceLogging** | `TraceLoggingRegister` / `TraceLoggingWrite` | El propio evento binario (autodescriptivo) | Hasta ocho |

---

## 2. La Sesión de Kernel: `NT Kernel Logger`

A diferencia de los proveedores de modo usuario, el kernel de Windows expone una sesión de rastreo reservada de alto rendimiento denominada `NT Kernel Logger`.

### Identificador Global y Banderas de Activación

- **GUID de Sesión:** `SystemTraceControlGuid = {9e814aad-3204-11d2-9a82-006008a86939}`.
- La sesión no se suscribe a proveedores por GUID individual, sino a través del campo **`EnableFlags`** de la estructura `EVENT_TRACE_PROPERTIES`:

| Bandera de Kernel ( `EnableFlags` ) | Valor Hex (Constante) | Telemetría Capturada |
|---|---|---|
| `EVENT_TRACE_FLAG_PROCESS` | `0x00000001` (bit 0 = 1) | Creación y terminación de procesos (PID, PPID, SID, ImageFileName). |
| `EVENT_TRACE_FLAG_THREAD` | `0x00000002` (bit 1 = 2) | Creación, destrucción y conmutación de contexto de hilos (*Context Switch*). |
| `EVENT_TRACE_FLAG_IMAGE_LOAD` | `0x00000004` (bit 2 = 4) | Carga de módulos ejecutables ( `.exe` , `.dll` , `.sys` ) con dirección base y tamaño. |
| `EVENT_TRACE_FLAG_DISK_IO` | `0x00000100` (bit 8 = 256) | Operaciones de lectura y escritura física en disco. |
| `EVENT_TRACE_FLAG_NETWORK_TCPIP` | `0x00010000` (bit 16) | Conexiones de red TCP/UDP (send, receive, connect, disconnect). |
| `EVENT_TRACE_FLAG_REGISTRY` | `0x00020000` (bit 17) | Creación, modificación y borrado de claves y valores del Registro. |

*(Nota técnica sobre EnableFlags: Valores hexadecimales canónicos definidos en `evntrace.h` del Windows SDK. Nótese que `EVENT_TRACE_FLAG_DISK_IO` corresponde estrictamente al bit 8 = `0x00000100` / 256 decimal; no debe confundirse con cero ni con valores truncados).*

### Control Práctico de la Sesión con `logman`

```
:: Iniciar la captura de kernel a un archivo ETL
logman start "NT Kernel Logger" -p "Windows Kernel Trace" (process,thread,img,net) -ets -o
kernel_trace.etl

:: Consultar estado y estadísticas de buffers y eventos perdidos
logman query "NT Kernel Logger" -ets

:: Detener la sesión
logman stop "NT Kernel Logger" -ets
```

---

## 3. Anatomía y Formato Binario del Archivo ETL ( `.etl` )

Un archivo ETL generado por ETW es una secuencia binaria estructurada de bloques de 64 KB organizados de la siguiente manera:

### A. Cabecera de Buffer (`WMI_BUFFER_HEADER`)

Cada bloque físico de 64 KB dentro del archivo `.etl` comienza con una cabecera de 32 a 48 bytes:

- **`BufferSize`:** Tamaño del bloque (típicamente `0x10000` = 64 KB).
- **`SavedOffset`:** Desplazamiento hasta el último byte de evento escrito en el buffer.
- **`CurrentOffset`:** Posición del cursor de escritura.
- **`ReferenceTime`:** Timestamp de inicio del bloque en unidades de temporizador de alta resolución (`RDTSC` o `KeQueryPerformanceCounter`).

### B. El Primer Registro: `TRACE_LOGFILE_HEADER`

El primer evento del archivo describe los metadatos globales de la captura:

- **`BufferSize` y `VersionDetail`:** Versión del sistema operativo que generó la traza.
- **`StartTime` y `EndTime`:** Tiempos de inicio y cierre en formato `FILETIME` de 64 bits.
- **`TimerResolution`:** Resolución del temporizador del kernel (en unidades de 100 ns).
- **`NumberOfProcessors` y `CpuSpeedInMHz`:** Hardware subyacente.
- **`PointerSize`:** `4` para arquitecturas x86, `8` para x64.
- **`LogFileMode`:** Configuración de almacenamiento (`EVENT_TRACE_FILE_MODE_SEQUENTIAL`, `CIRCULAR`, etc.).

### C. Registros de Eventos (`EVENT_RECORD` / `EVENT_HEADER`)

Cada evento individual dentro de los buffers contiene una cabecera estandarizada de 80 bytes:

1. **`Size` (`USHORT`):** Longitud total del registro del evento en bytes.
2. **`HeaderType` y `Flags`:** Indican si el evento es de 32 o 64 bits y qué temporizador se usó.
3. **`ProviderId` (`GUID`):** Identificador de 16 bytes del proveedor emisor.
4. **`EventDescriptor` (16 bytes):**

- `Id` (Identificador del evento dentro del proveedor).
- `Version` (Revisión del esquema).
- `Channel` (Canal de destino: Admin, Operational, Analytic, Debug).
- `Level` (Severidad: Crítico, Error, Warning, Info).
- `Opcode` (Operación: Start, Stop, Info).
- `Task` y `Keyword` (Máscara de 64 bits para filtrado).

1. **`ProcessId` y `ThreadId`:** PID y TID del hilo que emitió el evento.
2. **`TimeStamp`:** Marca temporal de 64 bits.
3. **`UserData` / `UserDataLength`:** Payload binario con los argumentos específicos del evento.

---

## 4. Técnicas de Manipulación y Cegado de ETW (ETW Tampering / Blinding)

En ciberseguridad defensiva e ingeniería inversa de malware, el análisis de telemetría debe contemplar cómo los atacantes neutralizan la generación de eventos:

### A. Parcheo en Modo Usuario (`ntdll!EtwEventWrite`)

Cuando un proceso en modo usuario desea impedir que componentes de seguridad reciban eventos (como telemetría de inyección de código o AMSI), recurre a **ETW Patching**:

1. El proceso localiza la función exportada `ntdll!EtwEventWrite`.
2. Modifica los permisos de la página de memoria usando `VirtualProtect` a `PAGE_EXECUTE_READWRITE`.
3. Sobrescribe el prólogo de la función con una instrucción de retorno anticipado:

- En x64: `xor eax, eax; ret` (`31 C0 C3`) o simplemente `ret` (`C3`).

1. Al retornar `0` (`STATUS_SUCCESS`), la aplicación cree que el evento se registró con éxito, pero ningún byte de telemetría llega al despachador de ETW.

**Detección Defensiva:** Un monitor de integridad lee la imagen limpia de `ntdll.dll` directamente desde el disco (`\SystemRoot\System32\ntdll.dll`) y compara los primeros 16 bytes de `EtwEventWrite` contra los bytes en memoria. Cualquier discordancia (`0xC3` o `0x31 0xC0` en el primer byte) delata un parcheo activo de ETW.

### B. Cegado en Modo Kernel (ETWti Blinding)

A nivel de kernel, los controladores de seguridad se alimentan del proveedor `Microsoft-Windows-Threat-Intelligence` (Lección 6.7). Para cegar este sensor:

- Un atacante con primitiva de escritura en kernel (vector BYOVD) localiza el handle de registro apuntado por `nt!EtwThreatIntProvRegHandle`.
- En la estructura `_ETW_GUID_ENTRY`, manipula el campo `ProviderEnableInfo`, estableciendo la máscara de habilitación a cero (`EnableMask = 0`).
- Al quedar deshabilitado el proveedor a nivel de hipervisor/kernel, el sensor EDR deja de recibir eventos de inyección de hilos y acceso a memoria sin generar alertas visibles en user mode.

---

## 5. Repaso

▼ **¿Qué rol cumple el controller?**

> Define y controla una sesión ETW, habilita providers y establece cómo registrar eventos.

▼ **¿Qué diferencia provider y consumer?**

> El provider produce eventos; el consumer los lee e interpreta desde una sesión o archivo.

▼ **¿Una traza sin eventos prueba que no ocurrió actividad?**

> No. El provider puede no estar habilitado, no emitir ese evento, perder datos o haber sido parcheado (`EtwEventWrite`).

▼ **¿Qué es la sesión NT Kernel Logger?**

> Es la sesión del sistema reservada para telemetría de bajo nivel del kernel (procesos, hilos, DLLs, disco, red), controlada por `SystemTraceControlGuid`.

▼ **¿Cómo detectás en memoria un parcheo de ETW en user mode?**

> Comparando los primeros bytes de `ntdll!EtwEventWrite` en memoria contra los bytes del archivo original en disco; si empieza con `0xC3` o `0x31 0xC0`, fue alterado.

---

## Fuentes


- Microsoft Learn: About Event Tracing, Configuring NT Kernel Logger, EVENT_TRACE_PROPERTIES structure.
- Microsoft Learn: WMI_BUFFER_HEADER, EVENT_RECORD structure.
- Repositorio y Laboratorio: Plantilla de auditoría en WinDbg en `plantillas_codigo/auditar_callbacks.wdbg`.

**Ampliación editorial basada en fuentes externas — Extracción estática del Provider GUID (EventRegister) y detección de ETW Patching**

Al analizar un binario en IDA o Ghidra que interactúa con ETW, existen dos patrones opuestos: la telemetría legítima instrumentada por el desarrollador y el intento de malware de cegar la monitorización del sistema (Microsoft Learn: *EventRegister* y *EtwEventWrite*) *(Hecho confirmado)*:

1. **Localización del Provider GUID en aplicaciones legítimas o instrumentadas:**
   Al buscar referencias cruzadas a `advapi32!EventRegister` (o `ntdll!EtwEventRegister`), la firma en x64 recibe:

   ```
   lea rcx, [rip + GUID_Provider] ; 1.er arg (RCX): Puntero a los 16 bytes del GUID en
   .rdata
   xor edx, edx                   ; 2.º arg (RDX): EnableCallback (opcional)
   xor r8d, r8d                   ; 3.er arg (R8) : CallbackContext
   lea r9, [rip + g_RegHandle]    ; 4.º arg (R9) : Puntero global donde se guarda el
   REGHANDLE
   call cs:EventRegister
   ```

   El valor guardado a través de `R9` (`REGHANDLE`) es el manejador global que **luego usarán todas las llamadas subsiguientes a `EventWrite` / `EtwEventWrite`** para emitir eventos. Leer los 16 bytes apuntados por `RCX` permite cruzar de inmediato el GUID con `logman query providers` en la VM para conocer la identidad y finalidad del proveedor.
2. **Reconocimiento defensivo de *ETW Patching* en User-Mode:**
   Ciertas muestras evasivas intentan silenciar la telemetría del propio proceso (como los eventos del runtime de `.NET CLR` o `AMSI`) resolviendo dinámicamente `ntdll!EtwEventWrite` (o `NtTraceEvent`), cambiando la protección de su página de memoria a `PAGE_EXECUTE_READWRITE` y sobrescribiendo su primer byte con `ret` (`0xC3`) o `xor eax, eax ; ret` (`33 C0 C3`). En el depurador, el analista lo detecta comparando los primeros bytes de `ntdll!EtwEventWrite` en memoria frente a la copia intacta de `ntdll.dll` en disco o monitoreando llamadas a `VirtualProtect` sobre rangos de memoria de `ntdll`.

# Integrador Windows internals

**Optativo y acotado**

Usá una aplicación propia o didáctica, sin malware ni software ajeno. El integrador no crea persistencia: no instala un servicio, no registra tareas ni consumidores WMI y no cambia permisos.

**Propósito**

Unir conceptos de objetos, memoria, registro, COM, IPC, excepciones y telemetría en un informe reproducible que distinga evidencia de hipótesis.

**Prerrequisitos**

- *Obligatorios:* 2D.1, 2D.2 y 2D.3, más las lecciones de los mecanismos que use tu caso (por ejemplo 2D.6 y 2D.7 si usás COM, 2D.10 si usás IPC, 2D.12 si capturás ETW).
- *Recomendados:* 2D completa y 2C; no requiere 2D.8/DCOM ni modificar configuraciones de seguridad.

## Caso de laboratorio

Elegí una aplicación didáctica con un flujo inocuo y observable, idealmente propia. Definí de antemano qué datos se recopilan y qué sistemas quedan fuera. Modelo sugerido: leer una clave de configuración propia, consultar una interfaz COM propia, intercambiar un mensaje de estado por IPC y emitir un evento ETW propio. No agregar autoarranque ni ejecución automática.

## Fichas que reúne el informe

Cada lección de 2D dejó una herramienta de registro. El integrador no inventa otra: reúne las que correspondan a tu caso. Las marcadas como obligatorias son el mínimo; el resto se agrega si tu programa usa ese mecanismo.

| Lección | Ficha o tabla | En el integrador |
|---|---|---|
| 2D.1 | Token, privilegios e integridad del proceso | Obligatoria |
| 2D.2 | Módulos y regiones relevantes | Obligatoria |
| 2D.3 | Clave propia leída y vista consultada (usuario/máquina, 32/64) | Obligatoria |
| 2D.6 | Apartamento de cada hilo, tabla slot/offset/método, puntero directo o proxy | Si usás COM |
| 2D.7 | Observación/inferencia de la activación (servidor, `ThreadingModel`, manifiesto) | Si usás COM |
| 2D.9 | Ficha de evidencia WMI | Solo si inspeccionás suscripciones **existentes**; el integrador no crea ninguna |
| 2D.10 | Revisión del pipe (ACL, primera instancia, remotos, modo, impersonación) | Si usás IPC |
| 2D.11 | Cronología de excepción con primera/segunda oportunidad | Si tu caso incluye una excepción controlada |
| 2D.12 | Ficha de la sesión ETW (nivel, keywords, pérdidas, decodificación) | Obligatoria si capturás ETW |

DCOM (2D.8), servicios (2D.4) y tareas (2D.5) quedan fuera del integrador: exigirían habilitar acceso remoto o crear persistencia.

## Ejemplo trabajado

*(Escenario construido para enseñar el método; no es una observación real ni una muestra del corpus.)*

BlocLab es una aplicación propia que lee su clave `HKCU\Software\BlocLab`, consulta una interfaz COM local y devuelve `READY` por un named pipe. El recorrido de análisis puede documentarse así:

```
Paso 1 — proceso: BlocLab.exe, PID 4120; token estándar del usuario de laboratorio.
Paso 2 — configuración: valor Mode="demo" leído desde HKCU\Software\BlocLab.
Paso 3 — COM: el cliente solicita IID_IFakeStatus al CLSID propio {11111111-2222-3333-4444-
555555555555};
         hilo cliente STA; servidor in-proc ThreadingModel=Both -> puntero directo (vtable en el
módulo propio).
Paso 4 — IPC: el cliente abre \\.\pipe\BlocLabStatus y recibe READY;
         pipe creado con FILE_FLAG_FIRST_PIPE_INSTANCE y PIPE_REJECT_REMOTE_CLIENTS; ACL al logon
SID.
Paso 5 — telemetría: el provider BlocLab emite StatusQuery con resultado READY;
         sesión propia, nivel informativo, 0 eventos perdidos.
Conclusión acotada: esta ejecución coincide con el flujo documentado por el programa.
Alternativa: una capa proxy podría intermediar COM; el evento ETW por sí solo no identifica al
lector del pipe.
Limpieza: detener app, cerrar sesión ETW, borrar traza temporal y comparar/revertir snapshot.
```

La cadena proceso → configuración → interfaz → canal → evento es una **hipótesis de recorrido** que se valida correlacionando observaciones. La coincidencia temporal entre COM y ETW no demuestra causalidad; conserva timestamps y anota qué herramienta produjo cada dato.

## Práctica

1. Registra VM/build, programa, hash del binario propio y snapshot base.
2. Capturá solo una ejecución; observá token, módulo/segmento relevante, acceso a configuración y flujo IPC/COM que esté documentado. Completá las fichas de la tabla de arriba que correspondan.
3. Si añadís ETW, limita la traza al provider propio, detené la sesión y evita conservar payloads sensibles.
4. No ejecutes acciones desconocidas, no cambies servicio/tarea/consumidor ni DACL de componentes del sistema.
5. Cierra procesos, elimina traces/capturas temporales y comprueba las claves/archivos creados por tu programa. Revierte snapshot si el estado no coincide con el inicial.

## Entregable

Informe con alcance, mapa de componentes, evidencias fechadas, tabla observación/interpretación/alternativas, límites, hashes del material propio y checklist de limpieza firmado por quien realizó el lab. Como anexos, las fichas de 2D que aplicaron (al menos las obligatorias), cada una con su fecha y la herramienta que produjo cada dato.

## Repaso

▼ **¿Qué convierte una observación en una conclusión sólida?**

> Repetibilidad, fuente/contexto, evidencia correlacionada y consideración de explicaciones alternativas.

▼ **¿Por qué el integrador evita autoarranque?**

> No hace falta para demostrar los conceptos y agrega cambios persistentes difíciles de limpiar y revisar.

▼ **¿Por qué el integrador no incluye DCOM ni suscripciones WMI nuevas?**

> Porque demostrarlos exigiría habilitar acceso remoto o crear persistencia, y el integrador no cambia la seguridad ni deja configuraciones permanentes.

▼ **¿Cuándo se considera terminado?**

> Cuando el informe es reproducible, sus límites están declarados y cada cambio temporal se eliminó o la VM se revirtió.

**Puerta optativa 2D**

Entregás un análisis acotado, basado en evidencia, y demostración de limpieza. No se aprueba por cantidad de herramientas usadas.

## Fuentes

- Documentación primaria enlazada en 2D.1, 2D.2, 2D.3, 2D.6, 2D.7, 2D.9, 2D.10, 2D.11 y 2D.12.
- **Fundamentos previos:** método de análisis e informe en Etapa 4.

**Etiquetas**

**Núcleo conceptual:** método de análisis e informe. **Conocimiento externo:** integración Windows internals. **Ejemplo ilustrativo:** plantilla BlocLab. **Laboratorio verificado:** no; caso a construir con software propio.

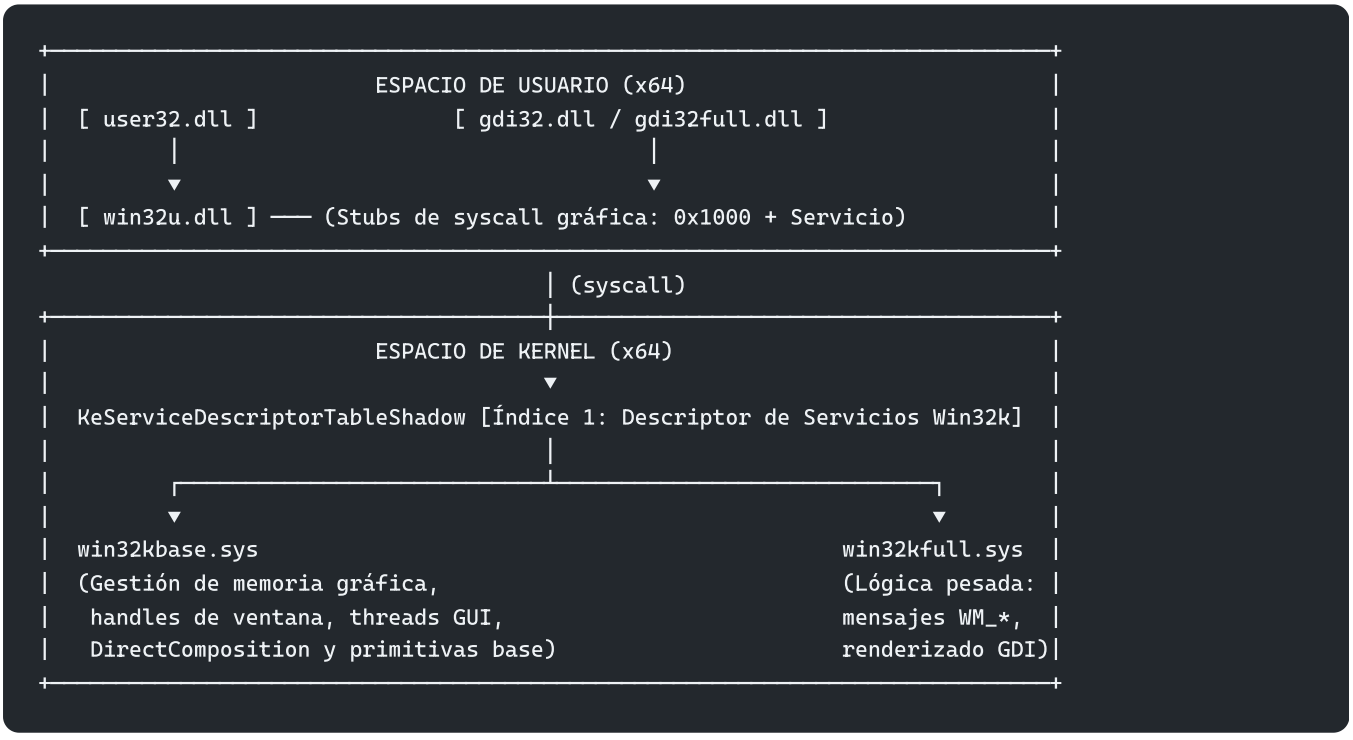
# El Subsistema Gráfico en Modo Kernel (win32k) y la Tabla de Servicios Sombra

> **Propósito y Relevancia**
>
> En la arquitectura de Windows, el modo kernel no solo alberga los servicios de sistema estándar del ejecutivo y del gestor de memoria ( `ntoskrnl.exe` ). También aloja el subsistema de ventanas, interfaz gráfica y gestión de dispositivos de entrada (**GDI y USER**). Este subsistema está implementado en controladores de sistema especiales ( `win32kbase.sys` , `win32kfull.sys` y el driver legado `win32k.sys` ). Con más de 1.200 llamadas al sistema que históricamente han constituido la mayor superficie de ataques de escalada local de privilegios (LPE) en Windows, su análisis es obligatorio para cualquier investigador de seguridad.

---

## 1. Descomposición de Win32k y Arquitectura Modular

En versiones antiguas de Windows (hasta Windows 7 y 8.1), toda la lógica gráfica residía en un único driver monolítico de gran tamaño: `win32k.sys`. Desde Windows 10, Microsoft refactorizó el subsistema en módulos especializados para reducir el acoplamiento y mejorar la telemetría:




### El Módulo de Transición en Modo Usuario: `win32u.dll`

Históricamente, las funciones de `user32.dll` (como `CreateWindowExW`) invocaban directamente la instrucción `syscall`. En Windows 10 y 11 modernos, Microsoft centralizó todos los stubs de llamadas al

sistema gráficas dentro de una DLL de bajo nivel llamada **`win32u.dll`**. Cualquier llamada de alto nivel en `user32.dll` o `gdi32.dll` pasa primero por un stub `NtUser*` o `NtGdi*` dentro de `win32u.dll`.

---

## 2. Despacho por la Tabla Sombra: `KeServiceDescriptorTableShadow`

En la Lección 2.15 vimos cómo las llamadas al sistema nativas (`NtOpenProcess`, `NtAllocateVirtualMemory`) se despachan mediante la tabla global exportada `KeServiceDescriptorTable`. Sin embargo, los servicios gráficos utilizan una tabla extendida no exportada: **`KeServiceDescriptorTableShadow`**.

### Estructura de `KSERVICE_TABLE_DESCRIPTOR` y Navegación en WinDbg

La tabla sombra contiene un arreglo de dos descriptores de servicio (`KSERVICE_TABLE_DESCRIPTOR`), cada uno de 32 bytes (en x64):

| Offset (x64) | Campo | Tipo | Significado y Función |
|---|---|---|---|
| `+0x00` | `Base` | `PULONG_PTR` | Puntero a la tabla de direcciones relativas de las rutinas de servicio (Service Table Base). |
| `+0x08` | `Count` | `PULONG` | Puntero al arreglo de contadores de invocaciones de cada syscall (Service Counter Table Base). |
| `+0x10` | `Limit` | `ULONG` | Cantidad total de llamadas al sistema registradas en la tabla (ej. ~`0x1C0` para `ntoskrnl`, ~`0x500` para `win32k`). |
| `+0x18` | `Number` | `PUCHAR` | Puntero al arreglo que contiene el número de bytes de argumentos pasados en el stack por cada llamada. |

- **Entrada 0 (`KeServiceDescriptorTableShadow[0]`, offset `+0x00`):** Descriptor idéntico a `KeServiceDescriptorTable` para los servicios nativos del ejecutivo de `ntoskrnl.exe`.
- **Entrada 1 (`KeServiceDescriptorTableShadow[1]`, offset `+0x20`):** Descriptor reservado para el subsistema gráfico despachado por `win32kbase.sys` y `win32kfull.sys`.

```
$$ Inspeccionar los descriptores de KeServiceDescriptorTableShadow en WinDbg
kd> dq nt!KeServiceDescriptorTableShadow L8
$$ El primer QWORD en +0x20 es el puntero Base de win32k:
kd> dps poi(nt!KeServiceDescriptorTableShadow + 0x20) L20
```

### Conversión de Números de Servicio (SSN Gráfico)

Las syscalls de Win32k poseen un bit indicador activo (`0x1000`). Cuando una instrucción `syscall` se ejecuta con `EAX = 0x1000 + N`:

1. El despachador `nt!KiSystemCall64` comprueba si el número de servicio excede `0x0FFF`.

2. Si es así, verifica si el hilo actual ya ha sido promovido a **GUI Thread** (es decir, si el campo `KTHREAD->Win32Thread` en `GS:[0x188]` no es nulo).
3. Si el hilo es estándar, el kernel invoca `nt!PsConvertToGuiThread` para asignar el stack de kernel extendido requerido por win32k (un stack de 64 KB en lugar del stack estándar de 24 KB).
4. El kernel toma la entrada 1 de `KeServiceDescriptorTableShadow` y salta a la función correspondiente indexando el offset `N` en la tabla de despacho.

---

## 3. El Fenómeno Crítico: Inversión de Control con `KeUserModeCallback`

La razón principal por la cual Win32k ha sido la mayor fuente histórica de vulnerabilidades de kernel (Use-After-Free y elevación de privilegios) es su necesidad de interactuar con el espacio de usuario mientras procesa llamadas de kernel:

### Mecánica de Inversión

Cuando una función en modo kernel dentro de `win32kfull.sys` necesita notificar a una ventana (por ejemplo, para ejecutar un hook de ventana global o despachar un mensaje `WM_NCCREATE`), el kernel no puede ejecutar la función de ventana directamente en modo kernel.

1. El driver de kernel invoca **`nt!KeUserModeCallback`**.
2. Esta función guarda el estado actual del stack de kernel, prepara un frame de retorno hacia el modo usuario y salta a la rutina `ntdll!KiUserCallbackDispatcher` en el proceso.
3. El código de usuario procesa el mensaje (ejecutando callbacks como `user32!__ClientLoadLibrary`).
4. Al concluir, el modo usuario invoca la syscall nativa `NtCallbackReturn` para devolver el control al driver de kernel en el punto exacto donde se suspendió.

### El Riesgo de Seguridad (Race Conditions y Reentrancia)

Durante el tiempo en que el control está en espacio de usuario a través de `KeUserModeCallback`, el proceso puede ejecutar código malicioso que destruya o libere la ventana o el objeto GDI (`DestroyWindow`) sobre el cual el kernel estaba operando. Cuando el control regresa a `win32kfull.sys`, si el driver asume que el objeto sigue existiendo en el puntero original sin revalidar su estado de bloqueo, se produce un fallo clásico de **Use-After-Free (UAF)** en espacio de kernel.

---

## 4. Mitigaciones Modernas: Win32k Lockdown

Para neutralizar esta inmensa superficie de ataque, Microsoft introdujo en Windows 10/11 la política **Win32k System Call Disablement Policy** (también conocida como **Win32k Lockdown**):

- Mediante la API `SetProcessMitigationPolicy` con la clase `ProcessSystemCallDisablePolicy`, un proceso puede auto-despojarse permanentemente del derecho de invocar llamadas a la tabla sombra.

- Procesos altamente expuestos a contenido no confiable (como los procesos de renderizado de Google Chrome, Microsoft Edge y sandboxes de visualización) activan esta mitigación. Si un exploit intenta invocar cualquier syscall gráfica ( `0x1000+` ), el despachador de kernel lanza inmediatamente una excepción de violación de acceso y termina el proceso.

### Inspección en WinDbg

```
$$ Inspeccionar si un proceso tiene deshabilitadas las llamadas a Win32k
dt nt!_EPROCESS <ProcessAddress> MitigationFlags
$$ El bit 0x04 (DisallowWin32kSystemCalls) indica que el proceso tiene Win32k bloqueado
```

# Reversing de Arranque Temprano, UEFI y Cadena de Carga

> **Propósito y Alcance**
>
> El análisis del sistema operativo no comienza cuando el kernel ya está en ejecución. Para comprender las amenazas más persistentes (Bootkits UEFI, técnicas de desactivación temprana de DSE, y el despliegue del hipervisor VBS antes de `ntoskrnl.exe`), el analista de ingeniería inversa debe dominar el proceso de arranque temprano de Windows en plataformas de 64 bits con firmware **UEFI**. Esta lección diseccionа la cadena de cargadores EFI, el layout de estructuras del firmware, el formato de los módulos DXE y la estructura de transición fundamental: el bloque `LOADER_PARAMETER_BLOCK`.

---

## 1. El Formato PE32+ de las Aplicaciones EFI

Los archivos ejecutables del cargador de arranque de Windows (como `bootmgfw.efi`, `winload.efi` y `hvloader.efi`) no son formatos binarios propietarios exóticos: son archivos estándar **PE32+ (PE de 64 bits)** con características específicas en sus cabeceras:

1. `Subsystem` **en OptionalHeader:**

- `IMAGE_SUBSYSTEM_EFI_APPLICATION` (`10` / `0x000A`): Aplicaciones que se ejecutan directamente bajo el entorno UEFI antes de que el sistema operativo tome el control.
- `IMAGE_SUBSYSTEM_EFI_BOOT_SERVICE_DRIVER` (`11` / `0x000B`): Controladores DXE que extienden los servicios de arranque de la placa madre.

1. **Punto de Entrada EFI:**

La función de inicio de un ejecutable EFI recibe siempre dos parámetros estandarizados en la convención x64 de Microsoft:

```
EFI_STATUS EFIAPI EfiMain(
    IN EFI_HANDLE ImageHandle,       // RCX: Handle del binario cargado en memoria
    IN EFI_SYSTEM_TABLE *SystemTable // RDX: Puntero a la tabla global de servicios UEFI
);
```

### Layout Binario de `EFI_SYSTEM_TABLE` en x64

En un ejecutable UEFI desensamblado, toda interacción con memoria, consola y protocolos se realiza a través de la tabla `SystemTable` pasada en `RDX`. En arquitecturas de 64 bits, su disposición en memoria es fija:

| Offset (x64) | Campo | Tipo | Propósito |
|---|---|---|---|
| `+0x00` | `Hdr` | `EFI_TABLE_HEADER` | Cabecera estándar de 24 bytes (Firma mágica `0x5453595320494249` = `"IBI SYST"`, revisión, tamaño y CRC32). |
| `+0x18` | `FirmwareVendor` | `CHAR16*` | Puntero a cadena Unicode UTF-16 con el nombre del fabricante del BIOS/UEFI. |
| `+0x20` | `FirmwareRevision` | `UINT32` | Versión interna del firmware. |
| `+0x24` | `_Padding` | `UINT32` | Relleno de alineación a 8 bytes en arquitecturas de 64 bits. |
| `+0x28` | `ConsoleInHandle` | `EFI_HANDLE` | Handle del dispositivo de entrada estándar (teclado). |
| `+0x30` | `ConIn` | `EFI_SIMPLE_TEXT_INPUT_PROTOCOL*` | Puntero al protocolo de lectura de caracteres del teclado. |
| `+0x38` | `ConsoleOutHandle` | `EFI_HANDLE` | Handle de la salida de texto (pantalla). |
| `+0x40` | `ConOut` | `EFI_SIMPLE_TEXT_OUTPUT_PROTOCOL*` | Puntero al protocolo de impresión de texto en pantalla. |
| `+0x48` | `StandardErrorHandle` | `EFI_HANDLE` | Handle del dispositivo de error. |
| `+0x50` | `StdErr` | `EFI_SIMPLE_TEXT_OUTPUT_PROTOCOL*` | Puntero a la salida de errores en pantalla. |
| `+0x58` | `RuntimeServices` | `EFI_RUNTIME_SERVICES*` | Puntero a la tabla de servicios en tiempo de ejecución (`gRT`), que persisten tras arrancar el SO (variables NVRAM). |
| `+0x60` | `BootServices` | `EFI_BOOT_SERVICES*` | Puntero a la tabla de servicios de arranque (`gBS`), activa solo hasta que se invoca `ExitBootServices`. |

### El porqué del Padding de 4 bytes (`+0x24`) y Desensamblado en x64

En la especificación UEFI y en la ABI x64 de Microsoft, los punteros de 64 bits (`CHAR16*`, `EFI_HANDLE`, punteros a tablas de servicios) exigen **alineación natural obligatoria a 8 bytes** (`offset % 8 == 0`):

1. `Hdr` mide 24 bytes (`0x18`), ocupando `+0x00` a `+0x18`.
2. `FirmwareVendor` es un puntero (8 bytes), ocupando `+0x18` a `+0x20`.
3. `FirmwareRevision` es un entero de 32 bits `UINT32` (4 bytes), ocupando `+0x20` a `+0x24`.
4. El siguiente miembro declarado es `EFI_HANDLE ConsoleInHandle` (un puntero de 8 bytes). Si el compilador lo ubicara inmediatamente en `+0x24`, rompería la alineación de 8 bytes (ya que `0x24` no es múltiplo de 8).
5. Por lo tanto, el compilador C inserta automáticamente **4 bytes de relleno inactivo** (`_Padding` en `+0x24` a `+0x28`).

6. A partir de `ConsoleInHandle` en `+0x28`, se suceden 7 punteros de 64 bits consecutivos ($7 \times 8 = 56 = \text{0x38}$ bytes): `0x28 + 0x38 = 0x60`.
7. Gracias a este padding riguroso, el puntero crítico **`BootServices`** se ubica indefectiblemente en el offset **`+0x60`**.

### Desensamblado en x64: Cómo el Firmware o Bootkit Recupera `BootServices`

```
; ========================================================================
; Prólogo estándar de una aplicación EFI (bootmgfw.efi / winload.efi / malware UEFI)
; Convención Microsoft x64: RCX = ImageHandle, RDX = SystemTable (EFI_SYSTEM_TABLE*)
; ========================================================================
EfiMain PROC
    mov     qword ptr [rsp + 10h], rdx  ; Salvar SystemTable en shadow space
    mov     qword ptr [rsp + 08h], rcx  ; Salvar ImageHandle
    sub     rsp, 28h

    ; Desreferenciar BootServices desde SystemTable (+0x60)
    mov     rax, qword ptr [rdx + 60h]  ; RAX = SystemTable->BootServices (¡offset exacto +0x60!)
    mov     qword ptr [gBS], rax        ; Almacenar en la variable global gBS

    ; Demostración de invocación de protocolo vía BootServices:
    ; LocateProtocol está en el offset +0x140 dentro de EFI_BOOT_SERVICES
    mov     rax, qword ptr [gBS]
    lea     r8, [pProtocol]             ; Argumento 3: Puntero de salida
    xor     edx, edx                    ; Argumento 2: Registration = NULL
    lea     rcx, [ProtocolGuid]         ; Argumento 1: Protocol GUID
    call    qword ptr [rax + 140h]      ; Invocar gBS->LocateProtocol()

    add     rsp, 28h
    ret
EfiMain ENDP
```

---

## 2. La Cadena de Carga de Windows en Sistemas x64 / UEFI

El proceso de arranque moderno desde el encendido de la máquina hasta la primera instrucción del kernel sigue una secuencia estricta de componentes encadenados y firmados bajo **Secure Boot**:

```
[ Encendido / Reset ]
         |
         ▼
[ Firmware UEFI (SEC -> PEI -> DXE -> BDS) ]
         | (Carga desde partición ESP FAT32: \EFI\Microsoft\Boot\bootmgfw.efi)
         ▼
[ Windows Boot Manager (bootmgfw.efi) ]
         | 1. Parsea la base de datos BCD (\EFI\Microsoft\Boot\BCD)
         | 2. Si BitLocker está activo: desbloquea la clave TPM mediante llamadas EFI
         | 3. Carga y verifica la firma digital del cargador del SO
         ▼
[ Windows OS Loader (winload.efi) ]
         | 1. Configura el mapa preliminar de tablas de páginas de 4 niveles (PML4)
         | 2. Carga la colmena de registro SYSTEM (HKLM\SYSTEM) desde el disco
         | 3. Carga ntoskrnl.exe, hal.dll y drivers con StartType = 0 (SERVICE_BOOT_START)
         | 4. Si VBS está habilitado: invoca a hvloader.efi para iniciar Hyper-V
         | 5. Llama a EFI_BOOT_SERVICES->ExitBootServices() (Termina el firmware)
         ▼
[ Kernel EntryPoint: ntoskrnl.exe!KiSystemStartup(LOADER_PARAMETER_BLOCK* pLpb) ]
```

---

## 3. La Estructura de Transición: `LOADER_PARAMETER_BLOCK`

Cuando `winload.efi` invoca la función de arranque del kernel (`nt!KiSystemStartup`), el hardware ya no tiene acceso a los servicios de UEFI (se ha llamado a `ExitBootServices`). La única vía por la cual el cargador transfiere información vital al kernel es mediante un puntero único pasado en el registro `RCX`: la estructura `LOADER_PARAMETER_BLOCK`.

### Offsets Críticos de `LOADER_PARAMETER_BLOCK` en x64:

- **`+0x010` `LoadOrderListHead` (`LIST_ENTRY`):** Lista doblemente enlazada de estructuras `KLDR_DATA_TABLE_ENTRY` que enumera todos los módulos y drivers cargados en memoria por `winload.efi` (incluyendo `ntoskrnl.exe`, `hal.dll`, `kd.dll` y drivers de arranque).
- **`+0x050` `MemoryDescriptorListHead` (`LIST_ENTRY`):** Mapa de memoria física del sistema clasificado por tipos (memoria utilizable, memoria reservada por firmware, memoria ACPI).
- **`+0x098` `Extension` (`Ptr64 _LOADER_PARAMETER_EXTENSION`):** Puntero a la extensión del bloque de arranque. En Windows 10/11 modernos, este campo contiene las estructuras de configuración de **VBS/HVCI**, el estado de inicialización de **Hyper-V** y los metadatos de integridad de código (*Code Integrity*).
- **`+0x0A0` `BootDriverListHead` (`LIST_ENTRY`):** Lista ordenada de controladores de arranque que deben ser inicializados por `IoInitSystem` antes de montar el sistema de archivos raíz.

### Inspección en WinDbg durante el Arranque Temprano

Si estás depurando una máquina virtual con WinDbg y configuras un breakpoint inicial (`sxe ibp` o `break` antes del kernel):

```
$$ Inspeccionar el bloque de parámetros pasado a KiSystemStartup en RCX
dt nt!_LOADER_PARAMETER_BLOCK @rcx
$$ Volcar la lista de módulos cargados en el arranque
!list -t nt!_KLDR_DATA_TABLE_ENTRY.InLoadOrderLinks -x "dps @$extret+0x30 L2" (poi(@rcx+0x10))
```

---

## 4. Metodología de Análisis de Módulos EFI y Bootkits en IDA / Ghidra

Los bootkits modernos (como BlackLotus o Bootkm) buscan infectar la cadena de arranque antes de que `ntoskrnl.exe` active los mecanismos de protección de PatchGuard o las políticas de EDR.

### Pasos de Reversing para un Binario `.efi`:

1. **Carga en el Desensamblador:** Seleccionar el formato PE. En Ghidra o IDA Pro, utilizar los tipos de datos de UEFI (importando los headers de EDK2 o utilizando el plugin *EFISeek* / *Ghidra-EFI*).
2. **Localización de `SystemTable`:**

En el prólogo de `EfiMain`, identificar la instrucción que salva el registro `RDX` en una variable global. Ese puntero es `gST` (`EFI_SYSTEM_TABLE`). En el offset `+0x60` de `gST` reside el puntero a `gBS` (`EFI_BOOT_SERVICES`).

1. **Identificación de Protocolos Hijackeados:**

Los bootkits suelen instalar ganchos sobre funciones críticas de `EFI_BOOT_SERVICES` antes de que se cargue `winload.efi`:

- Ganchos sobre `LocateProtocol` o `OpenProtocol`: interceptan la carga de protocolos para devolver punteros a rutinas modificadas.
- Ganchos sobre `ExitBootServices`: capturan el momento exacto en que `winload.efi` va a transferir el control al kernel. En este punto, el bootkit parchea en memoria viva las rutinas de validación de firmas de `winload.efi` o inyecta código en `ntoskrnl!KiSystemStartup` para deshabilitar DSE antes de que el kernel arranque.

1. **Verificación Defensiva:** En sistemas corporativos, la integridad de esta cadena se audita mediante **Measured Boot** (el chip TPM registra los hashes SHA-256 de cada componente de arranque en los registros PCR 0 a 7, permitiendo a la red verificar remotamente que ningún binario EFI fue alterado).

# Extensión optativa · Hyper-V y virtualización

> **Extensión separada**
>
> No integra el núcleo de 2D, no es prerrequisito de la Etapa 6 ni forma parte de la aprobación del curso. El objetivo es comprender la arquitectura y los límites de observación; no implementar evasión anti-VM.

## Conceptos

Hyper-V usa un hypervisor y particiones. La **root partition** administra recursos y aloja componentes de administración; las **child partitions** ejecutan sistemas invitados. VMBus ofrece comunicación entre particiones. Los **VSP** del lado root proveen servicios sintéticos y los **VSC** del guest los consumen. Esta arquitectura no es lo mismo que una CPU virtual aislada ni describe todos los detalles internos de un hypervisor.

**VMCS** (Intel) y **EPT** (Intel) / **NPT** (AMD) son estructuras/mecanismos de virtualización dependientes del procesador. Se mencionan como conceptos de lectura avanzada: no son componentes de VMBus ni hacen falta para analizar el curso.

Una aplicación puede observar características del entorno virtual por motivos legítimos —compatibilidad, diagnóstico, soporte—. El ejercicio consiste en describir esas señales y sus falsos positivos, no en modificar o esconderlas.

## Ejemplo trabajado

*(Diagrama conceptual, no salida de un equipo.)*

```
Guest / child partition: app -> VSC
                          ⇅ VMBus
Root partition:          VSP -> recursos del host
Hypervisor:              aislamiento y planificación de particiones
CPU:                     soporte de virtualización (VT-x/AMD-V)
```

Si un binario detecta un adaptador sintético o servicios de integración, eso sugiere un entorno virtual pero no revela por sí solo su configuración de seguridad ni prueba evasión.

## Práctica conceptual

En un host o VM donde Hyper-V ya esté habilitado y tengas autorización, abrí la documentación y la vista de propiedades/configuración disponible. Dibuja root/child, VSC/VSP y VMBus; registra dos señales de virtualización de una aplicación didáctica y explica una alternativa legítima para cada una. No alteres el hypervisor, Secure Boot, VM settings ni el comportamiento de la aplicación.

## Entregable y repaso

Entregá el diagrama y una tabla señal–evidencia–explicación alternativa–límite.

▼ **¿VMBus es lo mismo que VMCS?**

> No. VMBus conecta servicios sintéticos entre particiones Hyper-V; VMCS es una estructura de virtualización asociada a Intel VT-x.

▼ **¿Una señal de VM prueba que el programa evade análisis?**

> No. Puede servir a diagnóstico o compatibilidad; hace falta observar la decisión y el contexto.

**Puerta optativa**

Podés describir root/child, VSP/VSC/VMBus y diferenciarlo de VMCS/EPT/NPT, con límites de lo que una señal permite inferir.

## Fuentes

- Microsoft Learn: Hyper-V Architecture, Hyper-V on Windows.
- Intel: Intel 64 and IA-32 Software Developer Manuals. AMD: AMD64 Architecture Programmer's Manual.

**Etiquetas**

**Observado en CLS:** conceptos de detección de VM en 2B son solo contexto. **Conocimiento externo:** arquitectura Hyper-V y extensiones CPU. **Ejemplo ilustrativo:** diagrama. **Laboratorio verificado:** no; lectura conceptual.

# Bitácora de laboratorio y notas — Tomo II · Kernel, Drivers y Windows Internals

*Esta página cierra el último pliego en paridad par (múltiplo de 2) para impresión profesional a doble faz en gráfica y sirve como registro rápido de parámetros de tu entorno de laboratorio.*

| Parámetro del entorno / VM | Valor configurado en tu laboratorio | Notas / Comandos frecuentes |
|---|---|---|
| **Snapshot base de la VM** | | Verificar red aislada (*Host-Only* / desconectada) antes de abrir muestras |
| **Ruta de símbolos ( `_NT_SYMBOL_PATH` )** | | `srv*C:\Symbols*https://msdl.microsoft.com/download/symbols` |
| **Compilador MSVC / MinGW-w64** | | x64 Native Tools Command Prompt / `cl /Zi /Od` vs `cl /Zi /O2` |
| **VM de depuración Kernel (KDNET)** | | `bcdedit /debug on` · `bcdedit /dbgsettings net hostip:... port:50000` |

## Registro de sesiones, direcciones clave (RVA / VA) e hipótesis

| Fecha / Binario | SHA-256 / Arquitectura | RVA clave ( `OEP` / `main` / `vtable` / `IOCTL` ) | Observaciones y conclusiones verificadas |
|---|---|---|---|
| | | | |
| | | | |
| | | | |
| | | | |
| | | | |
| | | | |